

ISO/IEC 42001 : 2023 인공지능 경영시스템 인증심사원 안내서 V1.0



편저자 오명섭



한국사이버리터러시연구원
KOREA CYBER LITERACY INSTITUTE

<의도적 공백>

머 리 말

4차 산업혁명 시대에 진입하면서 인공지능 기술의 발전은 조직의 운영 방식과 경영 전략에 중대한 변화를 가져왔습니다. 이러한 변화 속에서 조직이 인공지능을 효과적으로 관리하고 활용하기 위한 체계적인 경영시스템이 절실히 요구되고 있습니다. "ISO/IEC 42001:2023 인공지능경영시스템 안내서 V1.0"은 이러한 맥락에서 인공지능 경영시스템에 대한 국제표준을 준수하고, 조직 내부의 인공지능 경영시스템 담당자와 ISO 인증 심사원이 인공지능 시스템을 안전하고 투명하게 운용하고 효과적으로 평가하고 관리하는 데 필요한 핵심 지식을 제공하고자 합니다.

최근 인공지능 기술의 적용이 확산되면서 윤리적이고 책임있는 인공지능 운영의 중요성이 더욱 강조되고 있습니다. 이에 따라 ISO/IEC 42001 : 2023 인증은 조직이 인공지능 시스템의 신뢰성을 높이고, 사회적 책임을 다하며, 법적 요구사항을 충족하는 중요한 역할을 할 것으로 기대하며, 본 안내서는 인공지능 경영시스템의 효과적인 구축 및 운영을 통해 조직이 이러한 목표를 달성하는 데 기여할 것이라 믿습니다.

본 안내서는 한국사이버리터러시연구원이 ISO 9001:2015, 45001:2018 인증심사원 안내서에 이어 세 번째로 출간한 도서로, 인공지능 경영시스템을 효과적으로 구축하고 운영하기 위해 필요한 지식과 기술을 포괄적으로 다룹니다. 이를 통해 인증심사원은 조직의 인공지능 경영시스템을 평가하고, 지속적인 개선을 이끌어낼 수 있을 것이며, 인공지능 경영시스템에 대한 이해가 부족한 입문자부터, 이미 경험이 풍부한 인증심사원 모두에게 유용할 수 있도록 기본 원칙, 실제적인 심사 절차, 효과적인 의사소통 기술, 그리고 일반적인 문제해결 전략을 포함하여, 인공지능 시스템의 안전하고 윤리적인 운영을 위한 핵심 요소들을 명확히 제시하고자 합니다. 또한, 인증심사 과정에서 발생할 수 있는 잠재적 결함에 대한 주의사항도 함께 강조하였습니다.

본 안내서를 집필하는 과정은 ISO 인증심사원으로서의 전문지식 축적과 새로운 도전에 대한 성취의 여정이었습니다. 저자는 본 안내서가 인공지능 경영시스템 운영 및 인증업무에 실질적인 도움이 되기를 바라며, 조직의 인공지능 경영시스템 운영을 향한 여정에 함께하길 기대합니다.

아직 완벽하지는 않지만, ISO/IEC 42001 : 2023 인증심사에 도움이 될 수 있기를 바라며, 내용 중 오류나 개선이 필요한 사항에 대해서는 허심탄회한 의견을 주시면 감사하겠습니다.

감사합니다.

한국사이버리터러시연구원 원장 오명섭 배상

<제 목 차 례>

1.국제표준과 품질경영	1
1.1 표준화 개요	1
1.1.1 표준 및 표준화의 중요성	1
1.2 국제표준	2
1.2.1 국제표준	2
1.2.2 ISO 42001 표준	2
1.2.3 ISO/IEC 22989 표준	2
1.2.4 ISO/IEC 23053 표준	3
1.3 국내표준	3
1.3.1 국내표준	3
2. 품질경영 원칙	4
2.1 일반사항	4
2.1.1 개요	4
2.1.2 기본개념	4
2.2 품질경영원칙	5
2.2.1 고객중시	5
2.2.2 리더십	6
2.2.3 인원의 적극참여	7
2.2.4 프로세스 접근법	8
2.2.5 개선	9
2.2.6 증거기반 의사결정	10
2.2.7 관계관리(경영)	11
3. 용어정의 및 개념도	12
3.1 용어정의	12

3.1.1 사람 또는 인원과 관련된 용어	12
3.1.2 조직과 관련된 용어	12
3.1.3 활동과 관련된 용어	13
3.1.4 프로세스와 관련된 용어	14
3.1.5 시스템과 관련된 용어	14
3.1.6 대상과 관련된 용어	15
3.1.7 결과와 관련된 용어	15
3.1.8 데이터와 관련된 용어	16
3.1.9 고객과 관련된 용어	17
3.1.10 특성과 관련된 용어	17
3.1.11 확인결정과 관련된 용어	18
3.1.12 조치와 관련된 용어	18
3.1.13 심사와 관련된 용어	19
3.2 용어간 개념도	20
3.2.1 사람 또는 인원과 관련된 개념	20
3.2.2 조직과 관련된 개념	20
3.2.3 활동과 관련된 개념	21
3.2.4 프로세스와 관련된 개념	21
3.2.5 시스템과 관련된 개념	22
3.2.6 대상과 관련된 개념	22
3.2.7 결과와 관련된 개념	23
3.2.8 데이터와 관련된 개념	23
3.2.9 고객과 관련된 개념	24
3.2.10 특성과 관련된 개념	24
3.2.11 확인결정과 관련된 개념	25
3.2.12 조치와 관련된 개념	25
3.2.13 심사와 관련된 개념	26

4. 품질 요구사항 27

4.1 요구사항 개요	27
4.2 요구사항 적용범위	28
4.3 인용표준	28
4.4 조직상황	30
4.4.1 조직과 조직 상황의 이해	30
4.4.2 이해관계자의 요구사항과 기대 이해	33
4.4.3 인공지능경영시스템 적용범위 결정	35
4.4.4 인공지능경영시스템	37
4.5 리더십	39
4.5.1 리더십과 의지	39
4.5.2 인공지능 정책	41
4.5.3 조직의 역할, 책임 및 권한	43
4.6 기획	45
4.6.1 리스크와 기회를 다루는 조치	45
4.6.1.1 일반사항	45
4.6.1.2 인공지능 리스크 평가	47
4.6.1.3 인공지능 리스크 대응	49
4.6.1.4 인공지능 시스템 영향도 평가	51
4.6.2 인공지능 목표와 목표 달성 기획	53
4.6.3 변경의 기획	55
4.7 지원	57
4.7.1 자원	57
4.7.2 역량	59
4.7.3 인식	61
4.7.4 의사소통	63
4.7.5 문서화된 정보	65
4.7.5.1 일반사항	65
4.7.5.2 문서화된 정보의 생성 및 현행화	67

4.7.5.3 문서화된 정보의 통제	69
4.8 운용	71
4.8.1 운용 기획 및 관리	71
4.8.2 인공지능 위험평가	73
4.8.3 인공지능 위험대응	75
4.8.4 인공지능 시스템 영향도 평가	77
4.9 성과평가	79
4.9.1 모니터링, 측정, 분석 및 평가	79
4.9.2 내부심사	81
4.9.3 경영검토	83
4.10 개선	85
4.10.1 지속적 개선	85
4.10.2 부적합 및 시정조치	87
5. 참조문서	89

<그림 차례>

그림 1. ISO 9000 표준 사람 또는 인원과 관련된 개념도	20
그림 2. ISO 9000 표준 조직과 관련된 개념도	20
그림 3. ISO 9000 표준 활동과 관련된 개념도	21
그림 4. ISO 9000 표준 프로세스와 관련된 개념도	21
그림 5. ISO 9000 표준 시스템과 관련된 개념도	22
그림 6. ISO 9000 표준 대상과 관련된 개념도	22
그림 7. ISO 9000 표준 결과와 관련된 개념도	23
그림 8. ISO 9000 표준 데이터와 관련된 개념도	23
그림 9. ISO 9000 표준 고객과 관련된 개념도	24
그림 10. ISO 9000 표준 특성과 관련된 개념도	24
그림 11. ISO 9000 표준 확인결정과 관련된 개념도	25
그림 12. ISO 9000 표준 조치와 관련된 개념도	25
그림 13. ISO 9000 표준 심사와 관련된 개념도	26

1. 국제표준과 품질경영

1.1 표준화 개요

1.1.1 표준 및 표준화의 중요성

표준은 재료, 제품, 프로세스 및 서비스가 의도한 목적에 적합하도록 공통의 규칙, 지침, 특성 기준을 정리한 문서화된 합의라고 할 수 있다. 다시 말해 표준은 조직 내부의 업무를 통일된 방식으로 수행하게 하는 기준인 동시에, 조직과 고객, 공급자, 규제기관, 시장이 서로 같은 언어로 의사소통하게 만드는 약속이기도 하다. 표준이 존재하지 않는 환경에서는 같은 용어를 사용하더라도 서로 다른 의미로 해석하기 쉽고, 같은 제품이나 서비스라도 판단 기준이 달라 혼선과 분쟁이 반복될 가능성이 높아진다. 따라서 표준은 단순한 문서가 아니라, 조직 활동의 일관성과 예측 가능성을 확보하는 경영 인프라라고 보아야 한다.

표준화는 이러한 표준을 만들고, 유지하고, 개정하고, 확산시키며, 실제 업무와 시장에서 적용하도록 하는 일련의 체계적 활동이다. 표준화의 대상은 제품 규격에만 한정되지 않는다. 생산공정, 검사방법, 문서관리, 정보보호, 환경관리, 안전관리, 고객응대, 심사기법과 같은 운영의 전 영역이 표준화의 대상이 된다. 따라서 표준화가 잘 이루어진 조직은 업무 방식이 특정 개인의 경험이나 감각에 지나치게 의존하지 않고, 반복 가능한 프로세스를 바탕으로 운영된다.

품질경영의 관점에서 표준과 표준화는 특히 중요하다. 품질은 우연히 만들어지는 결과가 아니라, 사전에 정해진 요구사항을 일관되게 충족시키는 과정에서 형성되는 산출물이기 때문이다. 이때 조직은 무엇을 요구사항으로 볼 것인지, 어떤 순서와 기준으로 업무를 수행할 것인지, 누가 어떤 책임을 질 것인지, 어떤 기록을 남겨야 하는지에 대한 공통 기준을 필요로 한다. 표준화는 바로 이러한 기준을 제공함으로써 품질경영시스템의 골격을 형성한다.

또한, 현대의 표준은 기술 규격을 넘어 경영시스템의 수준으로 확장되고 있다. ISO/IEC 42001과 같은 인공지능경영시스템 표준은 제품 자체의 개별 사양보다, 조직이 고객 요구사항과 법적·규제적 요구사항을 일관되게 충족할 수 있는 체계를 보유하고 있는가를 중시한다. 이러한 접근은 조직의 규모나 업종이 달라도 공통의 관리원칙 아래에서 성과를 비교하고 개선할 수 있게 만든다. 결국 표준은 조직 활동의 기준이고, 표준화는 그 기준을 살아 있는 경영 체계로 정착시키는 과정이라고 정리할 수 있다.

1.2 국제표준

1.2.1 국제표준 개요

국제표준(ISO standards)은 국가·산업·조직 규모를 막론하고 일관된 용어·프로세스·평가 기준을 제공해 세계 시장에서 제품·서비스의 품질·안전·신뢰성을 보장한다. 예컨대 ISO 9001(품질경영시스템)은 공급망 전반에 ‘동일한 품질 언어’를 심어 주며, ISO 14001(환경경영시스템)은 기업이 환경 법규·탄소 목표를 체계적으로 관리하도록 안내한다. 한 다국적 제조기업은 ISO 9001로 공정 품질을 표준화하고, 동시에 ISO 14001로 전 세계 공장의 폐수·에너지 지표를 관리해 지속가능성과 품질 경쟁력을 모두 확보했다.

1.2.2 ISO/IEC 42001 표준

ISO/IEC 42001:2023 표준은 세계 최초의 인공지능 경영시스템(AIMS) 국제표준으로, 조직이 인공지능 시스템을 설계·개발·배포·운용할 때 발생하는 위험·기회·사회적 영향을 HLS 기반 프로세스로 관리하도록 요구한다. 핵심 내용은 인공지능 정책 수립과 거버넌스 책임, 인공지능 리스크·영향평가 절차, 데이터·모델·모니터링 통제, 내부심사·지속개선 메커니즘이다. 이를 통해 조직은 책임감 있고 투명한 인공지능을 실무에 내재화하고, 잠재 규제 대비·신뢰 확보·혁신 가속이라는 세 가지 효과를 동시에 거둘 수 있다.

ISO/IEC 42001 4.1부터 10.2 각 요구사항 및 아래의 부록(Annex)는 ISO 저작권 문제로 본 안내서에 반영하지 않았으며, 추후 개정본 V2.0 출판 시 반영할 예정이다.

부록	원문 제목	한글 제목 제안
Annex A	Reference control objectives and controls	참조 통제목표 및 통제조치
Annex B	Implementation guidance for AI controls	AI 통제 구현 지침
Annex C	Potential AI-related organizational objectives and risk sources	AI 관련 조직 목표 및 위험원 예시
Annex D	Use of the AI management system across domains or sectors	도메인·산업 분야별 AI 관리시스템 활용

1.2.3 ISO/IEC 22989 표준

ISO/IEC 22989:2022는 인공지능 분야의 용어·개념·분류 체계를 표준화한 문서다. 알고리즘·모델·학습·추론 등 핵심 개념을 정립해 기술자·정책입안자·심사원이 공통 언어로 소통하도록 돕는다. ISO 42001 3장(용어정의)와 부록 A 통제 해석 시 공식 참조 문헌으로 지정되어, 인공지능 경영시스템 전 과정의 정의·범위 일관성을 확보하는 기초가 된다.

1.2.2 ISO/IEC 23053 표준

ISO/IEC 23053:2022는 머신러닝을 사용하는 인공지능 시스템의 일반 아키텍처·컴포넌트·데이터 흐름을 설명하는 프레임워크다. 데이터 수집-학습-검증-배포-운용 단계별 주요 기능과 인터페이스를 정의해, 조직이 모델 파이프라인을 설계·문서화·감사할 때 참조 모형으로 활용된다. ISO 42001을 수행할 때 운영통제와 MLOps 프로세스를 정렬하거나, 공급망 협력사와 공통 기술 언어를 맞추는 데 유용하다.

1.3 국내표준

1.3.1 국내표준 개요

국가기술표준원은 국제표준화기구(ISO)와 국제전기기술위원회(IEC)에서 23년 12월 공동으로 발간한 인공지능 경영시스템 국제표준(ISO/IEC 42001)을 KS로 도입한다. 본 안내서 발간 시점인 2025년 4월말 기준 국내표준으로 발간을 준비 중이다.

2. 품질경영 원칙

2.1 일반사항

2.1.1 개요

품질경영개념과 원칙은 급변하는 환경에 의해 제시되는 도전을 충족시킬 수 있는 능력을 조직에게 제공한다. 조직이 현재 처한 상황은 급속한 변화, 시장의 글로벌화 및 주요 자원으로 서 지식의 출현으로 특징짓는다. 품질의 영향은 고객만족을 넘어서서 확대되며, 품질은 조직의 평판에 직접적인 영향을 미칠 수 있다.

사회는 더 좋은 교육을 받게 되고 더 많은 요구를 하게 되며, 이해관계자를 점점 더 영향력이 있도록 만들어 왔다. 품질경영시스템(QMS)의 개발에 사용되는 기본개념과 원칙을 제공함으로써 이 표준은 조직에 대한 사고방식을 보다 광범위하게 제공한다.

모든 개념, 원칙 및 그 상호관계는 서로의 격리가 아닌 전체로서 이해되어야 하며, 어떠한 개별적인 개념이나 원칙도 다른 그것보다 더 중요하지는 않다. 언제 어느 때든 적용에 대한 올바른 균형을 찾는 것이 중요하다.

2.1.2 기본개념

2.1.2.1 품질

기본적으로 품질은 조직의 고유한 특성 집합이 요구 사항을 충족하는 정도를 의미한다. ISO 품질경영시스템은 단지 고객이 요구하는 수준의 제품과 서비스에 대한 만족을 달성할 뿐만 아니라 잠재적으로 이를 능가하도록 보장하는 개선을 위한 지속적인 노력이 포함된다. 이러한 품질경영의 7대 원칙은 다음과 같다.

1. 고객중시 : 품질 관리의 주요 초점은 고객 요구 사항을 충족하고 고객 기대치를 뛰어넘기 위해 노력하는 것이다.
2. 리더십 : 모든 계층의 리더는 목적과 방향의 통일성을 확립하고 사람들이 조직의 품질 목표를 달성하는 데 참여할 수 있는 환경을 조성한다.
3. 인원의 적극 참여 : 조직의 모든 사람이 유능하고 권한을 부여받으며 가치 전달에 참여하는 것이 중요하다.
4. 프로세스 접근 방식 : 활동 및 관련 자원을 프로세스로 관리할 때 원하는 결과를 보다 효율적으로 달성할 수 있다.
5. 개선 : 성공적인 조직은 개선에 지속적으로 중점을 둔다.
6. 증거 기반 의사결정 : 데이터와 정보의 분석 및 평가를 기반으로 한 의사 결정은 원하는 결과를 얻을 가능성이 더 높다.
7. 관계관리(경영) : 지속적인 성공을 위해 조직은 공급업체 등 이해관계자와의 관계를 관리하여 성과에 미치는 영향을 최적화한다.

2.2 품질경영원칙

2.2.1 고객중시

구분	주요내용
설명	품질경영의 가장 중요한 초점은 고객 요구사항을 충족시키고, 고객의 기대를 능가하기 위해 노력하는 것이다.
이론적 근거	- 지속적인 성공은 조직이 고객과 기타 이해관계자의 신뢰를 끌어내고 유지할 때 달성된다. - 고객과의 상호 작용에 대한 모든 측면은 고객에게 더 많은 가치를 창출할 수 있는 기회를 제공한다. - 고객과 기타 이해관계자의 현재와 미래의 요구사항을 이해하는 것은 조직의 지속적인 성공에 기여한다.
주요 이점	- 고객 가치 증대 - 고객 만족 증대 - 고객 충성도 개선 - 사업의 반복성(repeat business) 향상 - 조직 평판 향상 - 고객 기반 확대 - 수익과 시장 점유율 증대
가능한 조치	- 직간접적인 고객을 조직에서 가치를 인정받는 사람들로 인식 - 고객의 현재 및 미래의 요구사항과 기대를 이해 - 조직의 목표를 고객 요구사항과 기대에 연계 - 조직 전반에 걸쳐 고객 요구사항과 기대를 의사소통 - 고객 요구사항과 기대를 충족시키기 위해 제품 및 서비스의 계획, 설계, 개발, 생산, 제공 및 지원 - 고객만족을 측정하고 모니터링하며 적절한 조치를 취함 - 고객만족에 영향을 미칠 수 있는 이해관계자의 요구사항과 적절한 기대를 정하고 조치를 취함 - 지속적인 성공을 달성하기 위해 고객과의 적극적인 관계관리

2.2.2 리더십

구분	주요내용
설명	모든 계층의 리더는 목적과 방향의 통일성을 수립하고, 인원이 조직의 품질 목표 달성에 적극참여하는 여건을 조성한다.
이론적 근거	조직은 목적과 방향의 통일성 조성, 인원의 적극참여를 통하여 목표를 달성하기 위해 조직의 전략, 방침, 프로세스 및 자원을 한 방향으로 정렬할 수 있다.
주요 이점	- 조직의 품질목표 충족에 대한 효과성과 효율성 증대 - 조직의 프로세스에 대해 더 나은 조정 - 조직의 계층과 기능 간의 의사소통 개선 - 바람직한 결과를 제공하기 위하여 조직과 인원의 능력개발 및 개선
가능한 조치	- 조직 전반에 걸쳐 조직의 미션, 비전, 전략, 방침 및 프로세스의 의사소통 - 조직의 모든 계층에서 행동에 대한 공유가치, 공정성 및 윤리적 모델을 창출하고 유지 - 신뢰와 통합된 문화 수립 - 품질에 대해 전 조직적 실행 의지를 장려 - 모든 계층의 리더가 조직의 인원에게 긍정적 모범을 보장 - 인원이 권한과 책임을 갖고 행동하도록 필요한 자원, 교육훈련 및 권한을 제공 - 인원이 조직에 기여할 수 있도록 고무, 격려 및 인정

2.2.3 인원의 적극참여

구분	주요내용
설명	조직 전반에 걸쳐 모든 계층에서 역량과 권한을 갖고 적극참여하는 인원은 가치를 창출하고 전달하기위해 조직의 기능(능력)을 증진시키는데 필수적이다
이론적 근거	- 효과적이고 효율적으로 조직을 관리하기 위하여 모든 계층에서 모든 인원을 포함하고 존중하는 것이 중요하다. - 인식, 권한위임, 역량의 증진은 조직의 품질목표를 달성하는 인원의 동참을 촉진한다.
주요 이점	- 조직에 있는 인원이 조직의 품질목표 이해를 개선하고 달성할 수 있도록 동기를 증대 - 개선활동에 있는 인원의 참여를 증진 - 개별적인 개발, 숙련 및 창조를 증진 - 인원의 만족을 증진 - 조직 전반에 걸쳐 신뢰와 협력을 증진 - 조직 전반에 걸쳐 공공의 가치와 문화에 대한 관심 증대
가능한 조치	- 개별적인 공헌의 중요성에 대한 이해를 촉진하기위해 인원과 의사소통 - 조직 전반에 걸쳐 협력을 촉진 - 개방된 토론과 지식 및 경험의 공유를 촉진 - 성과에 대한 제약조건을 결정하고 두려움 없이 숙련하는 인원에게 권한부여 - 인원의 기여, 학습 및 개선을 인식하고 인정 - 개인 목표에 대한 성과의 자체평가 가능 - 인원의 만족을 평가하고 결과를 의사소통하며 적절한 조치를 취했는지에 대한 조사수행

2.2.4 프로세스 접근법

구분	주요내용
설명	일관성 있고 예측 가능한 결과는 결합력 있는 시스템으로 활동을 이해하고 상호 관련이 있는 프로세스로 관리될 때 더욱 효과적이고 효율적으로 달성된다.
이론적 근거	- 품질경영시스템은 상호 관련된 프로세스로 구성되었다. - 이 시스템에 의해 결과가 도출되는 방법의 이해는 조직이 시스템과 성과를 최적화할 수 있다.
주요 이점	- 개선에 관한 핵심프로세스와 기회에 노력을 집중하는 능력을 증진 - 정렬된 프로세스의 시스템을 통해 일관되고 예측 가능한 결과 도출 - 효과적인 프로세스관리, 자원의 효율적인 활용을 통해 성과를 최적화시키고 상호작용하는 장애를 감소 - 조직이 일관성, 효과성 및 효율성에 대한 이해관계자에게 신뢰제공이 가능
가능한 조치	- 시스템의 목표는 조직이 달성하고자 하는 필요한 프로세스를 정의 - 프로세스를 관리하기 위한 권한, 책임 및 의무를 수립 - 조직의 가능성을 이해하고 조치가 취해지기 전에 자원 제약의 결정 - 상호 의존하는 프로세스를 결정하고 시스템 전반에 걸쳐 개별적인 프로세스 변경에 영향을 끼치는지 분석 - 조직의 품질목표를 효과적이고 효율적으로 달성하기 위해 시스템으로 프로세스와 프로세스의 상호 관계를 분리 - 필요한 정보를 보장하는 것은 프로세스 운영 및 개선과 전반적인 시스템의 성과를 모니터링, 분석 및 평가하는 것이 가능 - 프로세스의 결과와 품질경영시스템의 전반적인 결과에 영향을 미칠 수 있는 리스크를 관리

2.2.5 개선

구분	주요내용
설명	성공적인 조직은 개선에 지속적인 초점을 맞춘다.
이론적 근거	조직이 현재 수준의 성과를 유지하고, 내부 및 외부 조건의 변화에 대응하며 새로운 기회를 창조하기 위해서 개선은 필수적이다.
주요 이점	- 프로세스 성과, 조직의 능력 및 고객만족 증대 - 예방조치 및 시정조치 전에 근본원인 조사 및 결정의 중요성 증진 - 내부 및 외부 리스크와 기회를 예측하고 대응하는 능력의 증진 - 점진적이고 획기적인 개선 모두의 고려를 증진 - 개선을 위한 학습의 활용을 개선 - 혁신을 위한 강화된 추진력 증진
가능한 조치	- 조직의 모든 계층에서 개선목표의 수립을 촉진 - 개선목표를 달성하기 위한 기본적인 도구 및 방법론의 적용 방법에 대한 모든 계층인원을 교육훈련 - 개선 프로젝트의 성공적인 촉진과 완결을 위한 역량을 갖춘 인원을 보장 - 조직 전반에 걸쳐 개선 프로젝트를 실행하는 프로세스의 개발 및 전개 - 개선 프로젝트의 기획, 실행, 완료 및 결과의 추적, 검토 및 심사 - 신규 또는 수정된 제품 및 서비스와 프로세스의 개발에 개선을 고려하여 통합 - 개선의 인식 및 인정

2.2.6 증거기반 의사결정

구분	주요내용
설명	데이터와 정보의 분석 및 평가에 기반을 둔 의사결정은 원하는 결과를 도출할 가능성이 더욱 높아진다.
이론적 근거	- 의사결정은 복잡한 과정이 될 수 있고, 항상 약간의 불확실성을 수반한다. - 의사결정은 주관적일 수 있는 해석뿐만 아니라, 여러 유형과 자원의 입력을 포함한다. - 원인과 결과 관계와 잠재적인 의도되지 않은 결과를 이해하는 것이 중요하다. - 의사결정에 있어서 사실 증거 및 데이터 분석은 객관성과 신뢰성을 높인다.
주요 이점	- 의사결정 프로세스의 개선 - 프로세스 성과 및 목표 달성 능력을 개선 - 운영상의 효과성과 효율성 개선 - 의견과 의사결정을 검토, 도전 및 변경하는 능력을 향상 - 과거 의사결정의 효과성을 실증하는 능력을 향상
가능한 조치	- 조직의 성과를 실증하는 주요 지표의 결정, 측정 및 모니터링 - 모든 필요한 데이터를 관련 인원에게 제공 가능 - 데이터와 정보는 충분히 정확하고 신뢰성이 있고 안전성을 보장 - 적절한 방법을 활용한 데이터와 정보의 분석 및 평가 - 필요에 따라 인원이 데이터를 분석 및 평가하는 역량을 보장 - 경험과 직관과의 균형을 맞추어 증거에 기반한 의사결정과 조치

2.2.7 관계관리(경영)

구분	주요내용
설명	지속적인 성공을 위해 조직은 공급자와 같은 이해관계자의 관계를 관리한다.
이론적 근거	- 관련된 이해관계자는 조직의 성과에 영향을 미친다. - 조직의 성과에 대한 이해관계자의 영향을 최소화하도록 모든 이해관계자의 관계를 관리할 경우, 지속적인 성공인은 더욱 달성되기 용이하다. - 공급자와 공급자 네트워크와의 관계관리가 특히 중요하다.
주요 이점	- 각 이해관계자와 관련된 기회와 제약사항에 대한 대응을 통해 조직과 조직의 관련 이해관계자의 성과 증진 - 이해관계자와 함께 목표와 가치의 공통 이해 - 자원과 역량의 공유, 품질관련 리스크 관리에 의해 이해관계자의 가치를 창출하는 능력 향상 - 제품 및 서비스의 안정적인 흐름을 제공하는 관리된 공급망
가능한 조치	- 관련 이해관계자(공급자, 파트너, 고객, 투자자, 종업원 또는 사회 전체) 및 조직과의 관계를 명확히 결정 - 관리할 필요가 있는 이해관계자 관계를 정하고 우선순위 결정 - 단기적 이익이 장기적 고려와 균형되는 관계를 구축 - 관련 이해관계자와 정보, 전문지식 및 자원을 수집하여 공유 - 개선 주도권을 증진하기 위하여 적절하게 이해관계자의 성과 피드백을 제공하고 성과를 측정 - 공급자, 파트너 및 그 밖의 이해관계자와의 공공개발 및 개선활동 수립 - 공급자, 파트너에게 개선과 성과를 격려하고 인정

3. 용어정의 및 개념도

3.1 용어정의

3.1.1 사람 또는 인원과 관련된 용어

- 최고경영자 : 최고 계층에서 조직을 지휘하고 관리하는 사람 또는 그룹
- 품질경영시스템 컨설턴트 : 자문 또는 정보 제공으로 품질경영시스템 실현에 대해 조직을 지원해 주는 사람
- 형상책임자 : 형상에 대해 의사결정을 하는 책임과 권한이 부여된 사람 또는 사람들의 집단
- 분쟁해결자 : 분쟁을 해결함에 있어 당사자들을 지원하기 위해 DRP 공급자에 의해 지정된 개인
 - * DRP : Distribution Requirement Planning (유통소요계획)
- 근로자 : 조직의 관리하에서 업무/작업 또는 업무 관련 활동을 수행하는 인원/사람
- 참여 : 활동, 이벤트 또는 상황에 참가
- 적극참여 : 공유된 목표를 달성하기 위한 활동에 참여하고 공헌함
- 거버닝 바디(Governing body) : 조직의 성과와 준수에 대해 책임을 지는 사람 또는 사람들의 집단
 - * 중소 조직은 거버닝바디가 최고경영자와 동일할 수 있음.

3.1.2 조직과 관련된 용어

- 조직 : 조직의 목표 달성에 대한 책임, 권한 및 관계가 있는 자체의 기능을 가진 사람 또는 사람의 집단
- 조직상황 : 직의 목표 달성과 개발에 대한 조직의 접근법에 영향을 줄 수 있는 내부 및 외부 이슈의 조합
- 이해관계자 : 의사결정 또는 활동에 영향을 줄 수 있거나, 영향을 받을 수 있거나 또는 그들 자신이 영향을 받는다는 인식을 할 수 있는 사람 또는 조직
- 고객 : 개인 또는 조직을 위해 의도되거나 그들에 의해 요구되는 제품 또는 서비스를 받을 수 있거나 제공받는 개인 또는 조직
- 공급자 : 제품 또는 서비스를 제공하는 조직
- 외부공급자 : 조직의 일부분이 아닌 공급자
- DRP 공급자 : 외부 분쟁 해결 프로세스를 제공하고 운영하는 개인 또는 조직
- 작업장 : 인원이 업무 목적으로 근무하거나 업무를 위하여 이동할 필요가 있는 조직의 관리 하에 있는 장소
- 측정학적 기능 : 측정관리시스템을 정의하고 실행할 운영적 및 기술적 책임이 있는 기능
- 협회 : 회원조직 또는 사람들로 구성된 조직

3.1.3 활동과 관련된 용어

- 활동 : 어떤 것을 수행함
- 활동 (프로젝트 관리) : 프로젝트에서 파악된 가장 작은 업무 대상
- 경영 : 조직을 지휘하고 제품을 관리하는 조정 활동
- 품질경영 : 품질에 대한 경영
- 개선 : 성과를 향상시키기 위한 활동
- 지속적 개선 : 성과를 향상시키기 위하여 반복하는 활동
- 프로젝트관리 : 프로젝트의 모든 측면에 관한기획, 조직, 모니터링, 관리 및 보고, 프로젝트 목표를 달성하기 위하여 프로젝트에 참여한 모든 인원에 대한 동기부여
- 변경관리 : 형상 정보에 대한 공식적인 승인 후,결과를 관리하기 위한 활동들
- 형상대상 : 최종 사용 기능을 만족하는 형상 내의 대상
- 형상관리 : 형상을 지시하고 관리하기 위한 조정 활동
- 품질기획 : 품질목표를 세우고 품질목표를 달성하기 위하여 필요한 운용 프로세스 및 관련 자원을 규정하는 데 중점을 둔 품질경영의 일부
- 품질보증 : 품질요구사항이 충족될 것이라는 신뢰를 제공하는 데 중점을 둔 품질경영의 일부
- 품질관리 : 품질요구사항을 충족하는 데 중점을 둔 품질경영의 일부
- 품질개선 : 품질요구사항을 충족시키는 능력을 증진하는 데 중점을 둔 품질경영의 일부
- 기계 학습(machine learning) : 계산 기술을 통해 모델 매개변수를 최적화하는 절차로서 모델 행동은 데이터 또는 경험을 반영
- 강화 학습(reinforcement learning) : 환경과 상호작용을 통해 보상을 최대화하기 위해 최적의 순서로 이루어지는 조치에 대한 학습
- 인공지능 리스크평가(AI risk assessment) : 인공지능 정책·목표에 따라 인공지능 리스크를 식별·분석·평가하는 프로세스
- 인공지능 리스크처리 (AI risk treatment) : 리스크평가 결과에 근거해 통제(controls)를 선정·설계·이행·검증하는 프로세스
- 인공지능 시스템 영향평가 (AI system impact assessment, AISIA) : 인공지능 시스템이 개인·집단·사회에 미칠 잠재적 영향을 식별·평가·대응하는 공식 문서화된 프로세스

3.1.4 프로세스와 관련된 용어

- 프로세스 : 입력을 사용하여 의도된 결과를 만들어 내는 상호 관련되거나 상호 작용하는 활동의 집합

- 절차 : 활동 또는 프로세스를 수행하기 위해 규정된 방식
- 프로젝트 : 착수일과 종료일이 있는 조정되고 관리되는 활동의 집합으로 구성되어 시간, 비용 및 자원의 제약을 포함한 특정 요구사항에 적합한 목표를 달성하기 위해 수행되는 고유의 프로세스
- 품질경영시스템 실현 : 품질경영시스템 수립, 문서화, 실행, 유지 및 지속적으로 개선하는 프로세스
- 역량/적격성 획득 : 역량을 갖추는 프로세스
- 설계 및 개발 : 대상에 대한 요구사항을 보다 상세한 요구사항으로 변환시키는 프로세스의 집합
- 외주처리 : 외부 조직이 조직의 기능 또는 프로세스의 일부를 수행
- 계약 : 구속력이 있는 합의

3.1.5 시스템과 관련된 용어

- 시스템 : 상호 관련되거나 상호작용하는 요소들의 집합
- 경영시스템 : 방침, 목표를 수립하고 그 목표를 달성하기 위한 프로세스를 수립하기 위한 상호 관련되거나 상호 작용하는 조직 요소의 집합
- 인공지능 시스템 (artificial intelligence system) : 인간이 정의한 다양한 목적의 수행을 위해 콘텐츠, 예측, 추천, 의사결정을 생성하는 공략적으로 개발된 시스템
- 인공지능 경영시스템 (AI management system, AI MS) : 조직이 인공지능과 관련된 방침·목표를 수립하고 이를 달성하기 위해 요구되는 프로세스·통제·상호작용을 확립·이행·유지·지속적으로 개선하는 경영시스템
- 사물인터넷(Internet of things) : 물리적 세계와 가상 세계의 정보를 처리하고 이에 반응하는 서비스와 함께 상호 연결된 개체, 사람, 시스템 및 정보 자원의 인프라
- 기반구조 : 조직의 운영에 필요한 시설, 장비 및 서비스의 시스템
- 측정학적 확인 : 측정장비가 의도된 용도에 대한 요구사항에 적합함을 보장하는데 필요한 운영의 집합
- 측정관리시스템 : 측정 프로세스의 관리와 측정학적 확인을 달성하는 데 필요한 상호 관련되거나 상호 작용하는 요소들의 집합
- 품질경영시스템 : 품질에 관한 경영시스템의 일부
- 방침 : 최고경영자에 의해 공식적으로 표명된 조직의 의도 및 방향
- 품질방침 : 품질에 관한 방침
- 안전보건 방침 : 근로자의 작업과 관련된 상해 및 건강상 장애를 예방하고 안전하고 건강한 작업장을 제공하기 위한 방침
- 비전 : 최고경영자에 의해 표명된 조직이 되고 싶어하는 것에 대한 열망

- 미션 : 최고경영자에 의해 표명된 조직의 존재하는 목적
- 전략 : 장기 또는 종합적인 목표를 달성하기 위한 계획

3.1.6 대상과 관련된 용어

- 대상 : 인지할 수 있거나 생각할 수 있는 것
- 품질 : 대상의 고유 특성의 집합이 요구사항을 충족시키는 정도
- 신인성 : 요구되는 만큼, 요구되는 경우 수행할 수 있는 능력
- 혁신 : 가치를 실현하거나 재분배하는 새로운 또는 변화된 대상
- 등급 : 동일한 기능으로 사용되는 대상에 대하여 상이한 요구사항으로 부여되는 범주 또는 순위
- 요구사항 : 가치를 실현하거나 재분배하는 새로운 또는 변화된 대상
- 품질요구사항 : 품질에 관련된 요구사항
- 법적 요구사항 : 법적 기관이 규정한 의무 요구사항
- 규제적 요구사항 : 법적 기관으로부터 위임받은기관이 규정한 의무 요구사항
- 제품형상 정보 : 제품설계, 실현, 검증, 운영 및 지원에 대한 요구사항 또는 기타 정보
- 적합 : 요구사항의 충족
- 부적합 : 요구사항의 불충족
- 결함 : 의도되거나 규정된 용도에 관련된 부적합
- 능력 : 해당 결과에 대한 요구사항의 충족
- 추적성 : 대상의 이력, 적용 또는 위치를 추적하는 능력

3.1.7 결과와 관련된 용어

- 결과 : 일이나 사건의 마지막 상태(사전적 용어)
- 결과/산출물 : 프로세스의 결과
- 효율성 : 달성된 결과와 사용된 자원간의관계
- 효과성 : 계획된 활동이 실현되어 계획된 결과가 달성되는 정도
- 제품 : 조직과 고객 간의 어떠한 행위도 없이 생산될 수 있는 조직의 결과
- 서비스 : 조직과 고객 간의 필수적으로 수행되는 적어도 하나의 활동을 가지는 조직의 결과
- 목표 : 달성되어야 할 결과
- 품질목표 : 품질에 관련된 목표
- 안전보건목표 : 안전보건 방침과 일관되게 특정한 결과를 달성하기 위해 조직이 설정한 목표
- 성과 : 측정 가능한 결과

- 안전보건 성과 : 근로자에 대한 상해 및 건강상 장애 예방의 효과성과 관련된, 그리고 안전하고 건강한 작업장의 제공과 관련된 성과
- 성취 : 목표의 달성
- 지속적인 성취 : 일정 기간 동안에 걸친 성취
- 상해/부상 및 건강상 장애 : 사람의 신체적, 정신적 또는 인지적 상태에 대한 악영향
- 위험요인 : 상해 및 건강상 장애(3.18)를 가져올 잠재적인 요인
- 리스크 : 불확실성의 영향
- 안전보건 리스크 : 업무/작업과 관련하여 위험한 사건 또는 노출의 발생 가능성과 사건 또는 노출로 야기될 수 있는 상해 및 건강상 장애 심각성의 조합
- 안전보건 기회 : 안전보건 성과의 개선을 가져올 수 있는 상황 또는 상황의 집합

3.1.8 데이터와 관련된 용어

- 데이터 : 대상에 대한 사실
- 정보 : 의미있는데이터
- 정보시스템 : 조직 내에서 사용되는 의사소통 채널의 네트워크
- 문서 : 정보 및 정보가 포함된 매체
- 시방서(specification) : 요구사항을 명시한 문서
- 품질매뉴얼 : 조직의 품질경영시스템에 대한 시방서
- 품질계획서 : 특정 대상에 대해 적용시점과 책임을 정한 절차 및 연관된 자원에 관한 시방서
- 특정사안 : 품질계획서의 주제
- 기록 : 달성된 결과를 명시하거나 수행된 활동의 증거를 제공하는 문서
- 형상 상태 기록 : 제품형상 정보, 제안된 변경의 상태 및 승인된 변경의 실행상태에 관한 공식적인 기록 및 보고
- 문서화된 정보 : 조직에 의해 관리되고 유지되도록 요구되는 정보 및 정보가 포함되어 있는 매체
- 프로젝트관리계획서 : 프로젝트의 목표를 만족시키는 데 필요한 것을 명시한 문서
- 객관적 증거 : 사물의 존재 또는 사실을 입증하는 데이터
- 검증 : 규정된 요구사항이 충족되었음을 객관적 증거의 제시를 통하여 확인하는 것
- 실현성 확인 : 특정하게 의도된 용도 또는 적용에 대한 요구사항이 충족되었음을 객관적 증거의 제시를 통하여 확인하는 것
- 데이터 품질(Data quality) : 특정 맥락에서 조직이 정한 데이터 요구사항을 해당 데이터가 충족하는 특성
- 인공 신경망(artificial neural network) : 입력 데이터를 받아 출력을 생성하는 조정 가능한 가중치 링크로 연결된 하나 이상의 신경세포 층의 네트워크

- 탐색적 데이터 분석(exploratory data analysis) :데이터의 두드러진 특성을 결정하고 품질을 평가하기 위한 데이터에 대한 초기 검사
- 광학 문자 인식(optical character recognition) : 입력, 인쇄 또는 손으로 쓴 텍스트의 이미지를 기계로 인코딩된 텍스트로 변환하는 것
- 얼굴인면 인식(face recognition) : 저장된 사람의 얼굴 이미지와 실제 얼굴의 이미지를 비교하여 일치 여부를 나타내는 자동 패턴 인식 및 사람이 실존하는 경우, 얼굴에 해당되는 사람의 신원을 식별할 수 있는 기술
- 감정 분석(sentiment analysis) : 긍정적인 감점에서 부정적인 감정에 이르기까지 감정의 범위를 결정하기 위해 텍스트, 말 또는 이미지로 표현된 의견을 계산적으로 컴퓨터를 통해 식별하고 분류하는 작업
- 개인정보(personal data) : 정보와 해당 정보가 관련된 자연인 간의 연결을 설정하는 데 사용할 수 있거나, 자연인과 직접 또는 간접적으로 연결되거나 연결될 수 있는 모든 정보
- 적용선언서 (Statement of applicability, SoA) : 식별된 모든 통제(controls)와 그 포함·제외 사유를 문서화한 기록

3.1.9 고객과 관련된 용어

- 고객 : 개인 또는 조직을 위해 의도되거나 그들에 의해 요구되는 제품 또는 서비스를 받을 수 있거나 제공받는 개인 또는 조직
- 고객서비스 : 제품 또는 서비스의 전과정에 걸친 고객과 조직간의 상호 작용
- 고객만족 : 고객의 기대가 어느 정도까지 충족되었는지에 대한 고객의 인식
- 고객만족행동강령 : 고객만족 향상을 목표로 그 행위와 관련하여 조직이 고객에게 한 약속과 관련 규정
- 피드백 : 제품, 서비스, 또는 불만처리 프로세스에 대한 의견, 논평 및 관심의 표현
- 불만/불평 : 제품 또는 서비스에 관련되거나, 대응 또는 해결이 명시적 또는 묵시적으로 기대되는 불만처리 프로세스 자체에 관련되어 조직에 제기된 불만족의 표현
- 분쟁 : 불만으로부터 발생되어 DRP 공급자에게 제출된 의견 차이

3.1.10 특성과 관련된 용어

- 특성 : 구별되는 특징
- 품질특성 : 요구사항과 관련된 대상의 고유 특성
- 측정학적 특성 : 측정결과에 영향을 미칠 수 있는 특성
- 형상 : 제품형상 정보에 정의된 제품 또는 서비스의 상호 연계된 기능적, 물리적 특성

- **형상 베이스라인** : 제품 또는 서비스의 전 과정에 걸쳐서 활동의 기준으로 사용되는 특성 시점에서의 제품 또는 서비스의 특성을 구성하는 제품형상 정보
- **인적 요인** : 고려 중인 대상에 영향을 미치는 사람의 특성
- **역량/적격성** : 의도된 결과를 달성하기 위해 지식 및 스킬을 적용하는 능력

3.1.11 확인결정과 관련된 용어

- **확인결정** : 하나 또는 하나 이상의 특성 및 그들 특성값을 찾아내기 위한 활동
- **검토** : 수립된 목표 달성을 위한 대상의 적절성, 충족성 또는 효과성에 대한 확인결정
- **모니터링** : 시스템, 프로세스, 제품, 서비스 또는 활동의 상태를 확인결정
- **측정** : 값을 정하는 프로세스
- **측정 프로세스** : 양적인 값을 정하는 업무의 집합
- **측정장비** : 측정 프로세스를 실현하는데 필요한 측정기기, 소프트웨어, 측정표준, 표준물질이나 보조기구 또는 그 조합
- **진도평가** : 프로젝트 목표의 달성에 대해 진행된 진도를 평가
- **검사** : 규정된 요구사항에 대한 적합의 확인결정
- **시험** : 특정하게 의도된 용도 또는 적용을 위한 요구사항에 따른 확인결정

3.1.12 조치와 관련된 용어

- **조치** : 어떤 것을 달성하기 위한 활동(사전적 용어)
- **허가** : 공식 권한을 주는 조치(사전적 용어)
- **통제** : 리스크를 유지하거나 변경하기 위해 취하는 조치·정책·프로세스·장치 등의 총칭
- **특채** : 규정된 요구사항에 적합하지 않은 제품 또는 서비스를 사용하거나 불출하는 것에 대한 허가
- **규격완화** : 실현되기 전의 제품 또는 서비스가 원래 규정된 요구사항을 벗어나는 것에 대한 허가
- **불출/출시/해제** : 프로세스의 다음 단계 또는 다음 프로세스로 진행하도록 허가
- **예방조치** : 잠재적 부적합 또는 기타 원하지 않는 잠재적 상황의 원인을 제거하기 위한 조치
- **시정조치** : 부적합의 원인을 제거하고 재발을 방지하기 위한 조치
- **시정** : 발견된 부적합을 제거하기 위한 행위

- 재등급 : 최초 요구사항과 다른 요구사항에 적합하도록 부적합한 제품 또는 서비스의 등급을 변경하는 것
- 재작업 : 부적합 제품 또는 서비스에 대해 요구사항에 적합하도록 하는 조치
- 수립 : 부적합한 제품 또는 서비스에 대해 의도된 용도에 쓰일 수 있도록 하는 조치
- 폐기 : 부적합한 제품 또는 서비스에 대해 원래의 의도된 용도로 쓰이지 않도록 취하는 조치

3.1.13 심사와 관련된 용어

- 심사 : 심사기준에 충족되는 정도를 결정하기 위하여 객관적인 증거를 수집하고 객관적으로 평가하기 위한 체계적이고 독립적이며 문서화된 프로세스
- 결합심사 : 한 피심사원에 둘 이상의 경영시스템이 함께 수행되는 심사
- 합동심사 : 둘 이상의 심사 조직에 의해 한 피심사원에게 수행하는 심사
- 심사의뢰자 : 심사를 요청하는 조직 또는 개인
- 피심사자 : 심사를 받는 조직
- 안내자 : 심사팀을 지원하기 위하여 피심사자가 지명한 인원
- 심사팀 : 공식 권한을 주는 조치(사전적 용어)
- 심사원 : 심사를 수행하는 인원
- 기술전문가 : 심사팀에 특정한 지식 또는 전문성을 제공하는 사람
- 참관인 : 심사팀과 동행하지만 심사원의 역할을 하지 않는 사람
- 심사 프로그램 : 특정한 기간 동안 계획되고 특정한 목적을 위하여 관리되는 하나 또는 그 이상의 심사의 조합
- 심사결론 : 심사목표 및 모든 심사 발견사항을 고려한 심사 결과
- 심사기준 : 객관적인 증거를 비교하는 기준으로 사용되는 방침, 절차 또는 요구사항의 조합
- 심사범위 : 심사의 영역과 경계
- 심사계획서 : 심사와 관련된 활동과 준비사항을 기술한 문서
- 심사 발견사항 : 심사기준에 대하여 수집된 심사증거를 평가한 결과
- 심사증거 : 심사기준에 관련되고 검증할 수 있는 기록, 사실의 기술 또는 기타 정보

3.2 용어간 개념도

* 용어간 개념도는 ISO 9001 용어를 기준으로 작성되었다. ISO/IEC 42001 용어를 반영한 개념도는 V1.1 업데이트 버전으로 출간할 예정이다.

3.2.1 사람 또는 인원과 관련된 개념

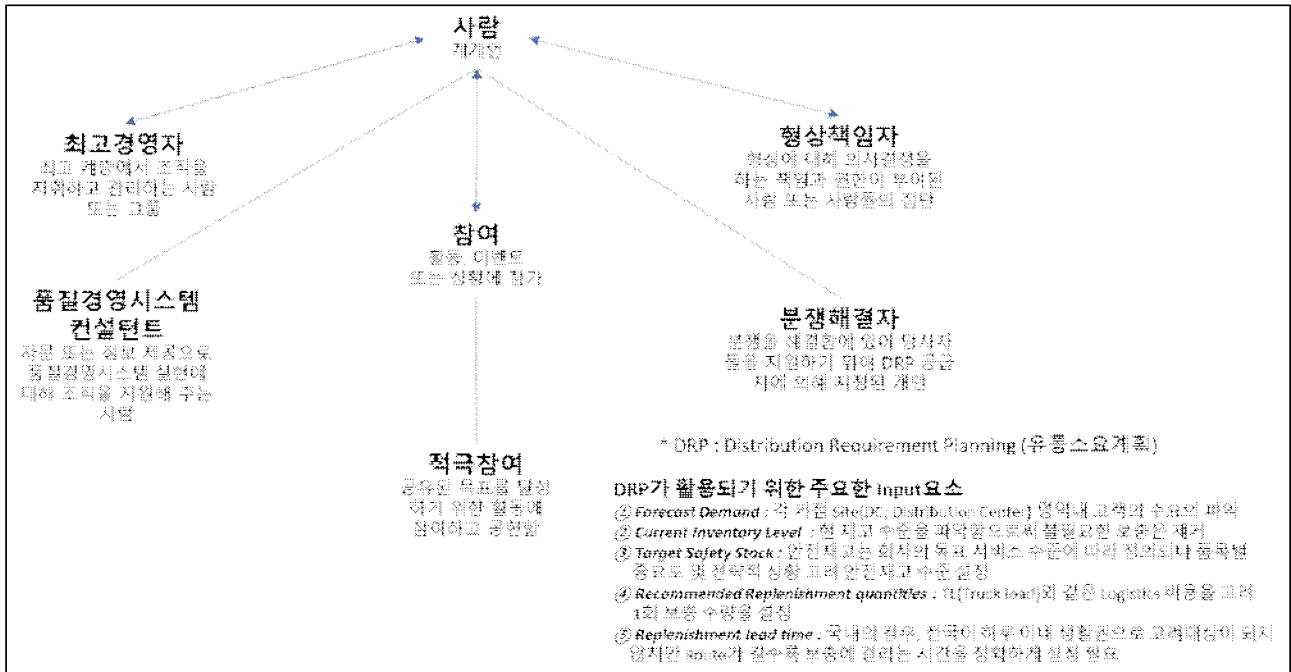


그림 1. ISO 9000 표준 사람 또는 인원과 관련된 개념도

3.2.2 조직과 관련된 개념

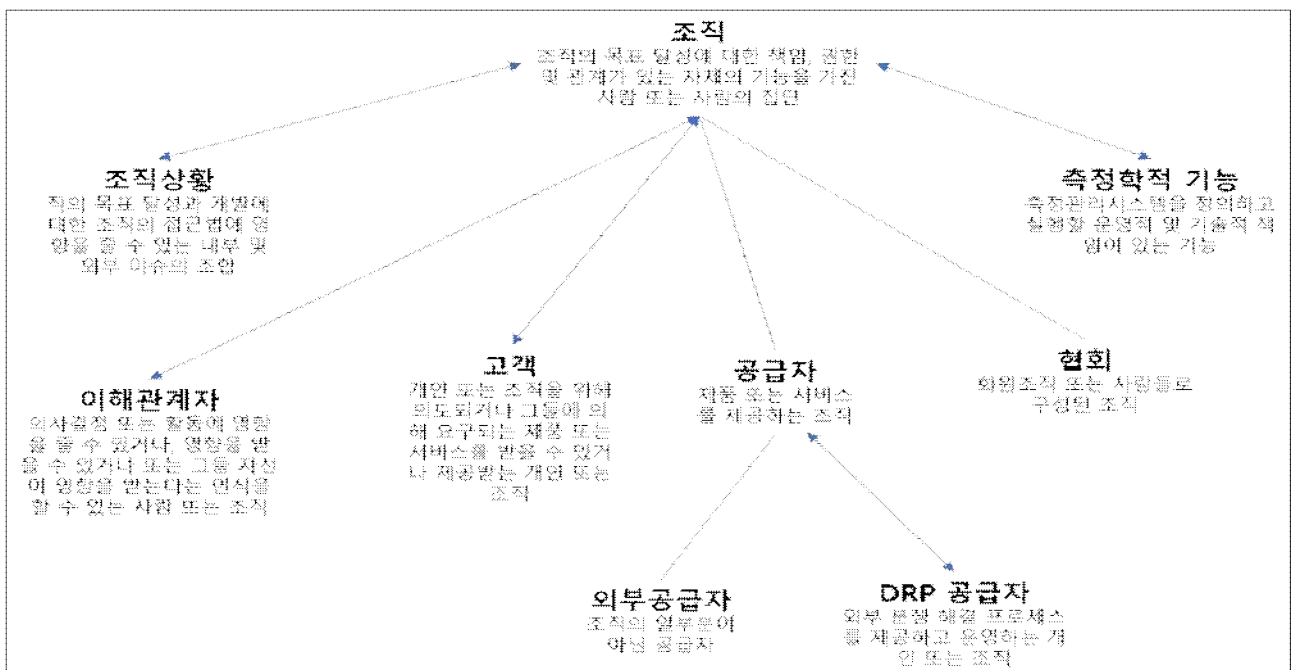


그림 2. ISO 9000 표준 조직과 관련된 개념도

3.2.3 활동과 관련된 개념

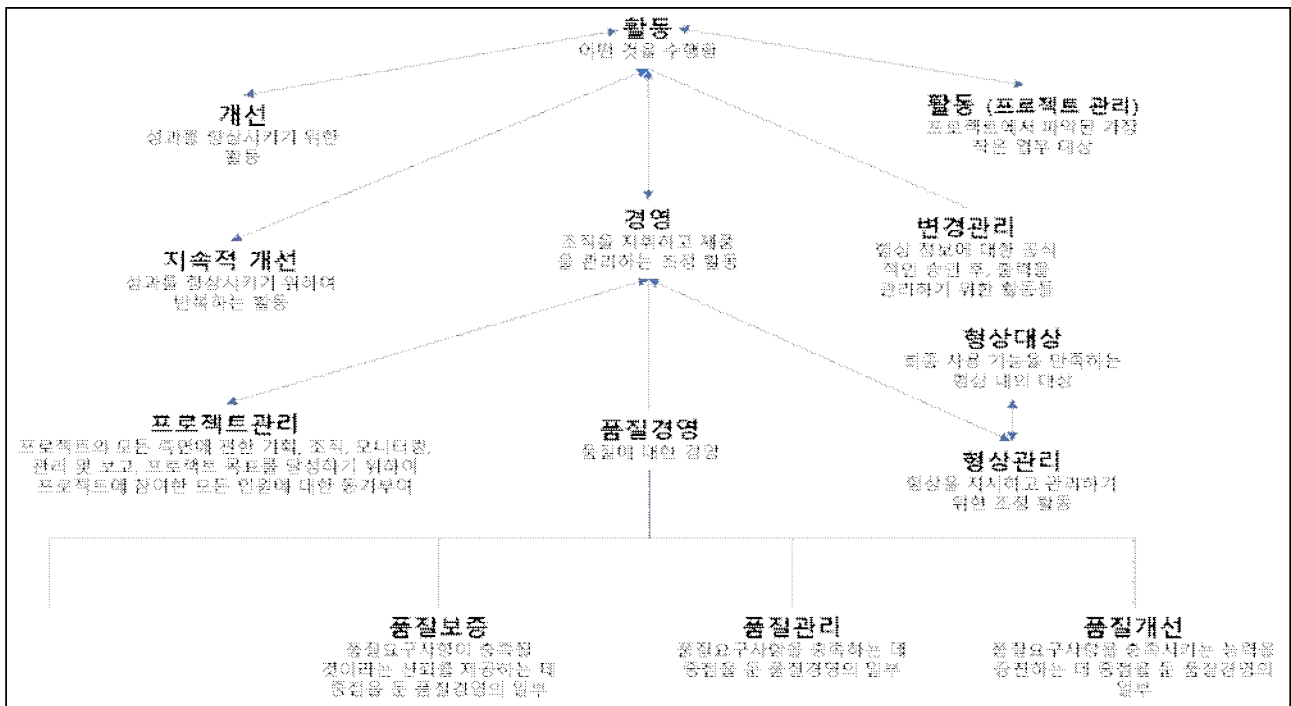


그림 3. ISO 9000 표준 활동과 관련된 개념도

3.2.4 프로세스와 관련된 개념

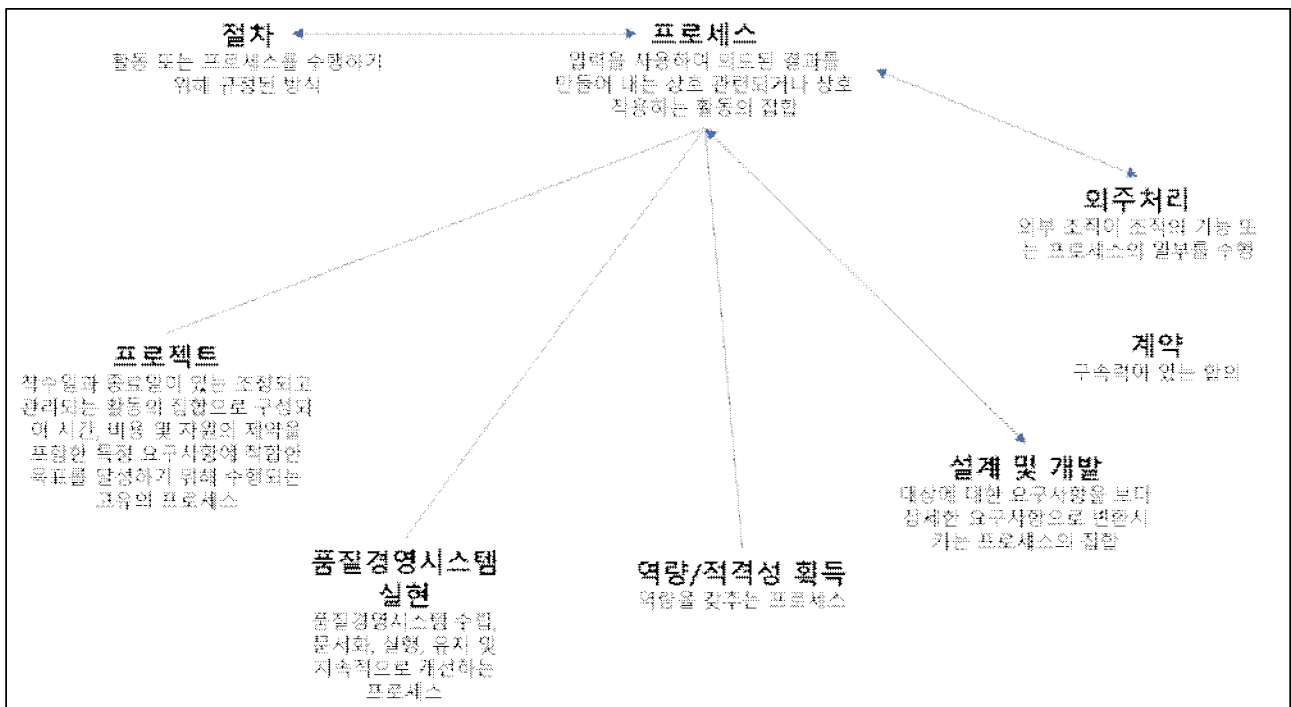


그림 4. ISO 9000 표준 프로세스와 관련된 개념도

3.2.5 시스템과 관련된 개념

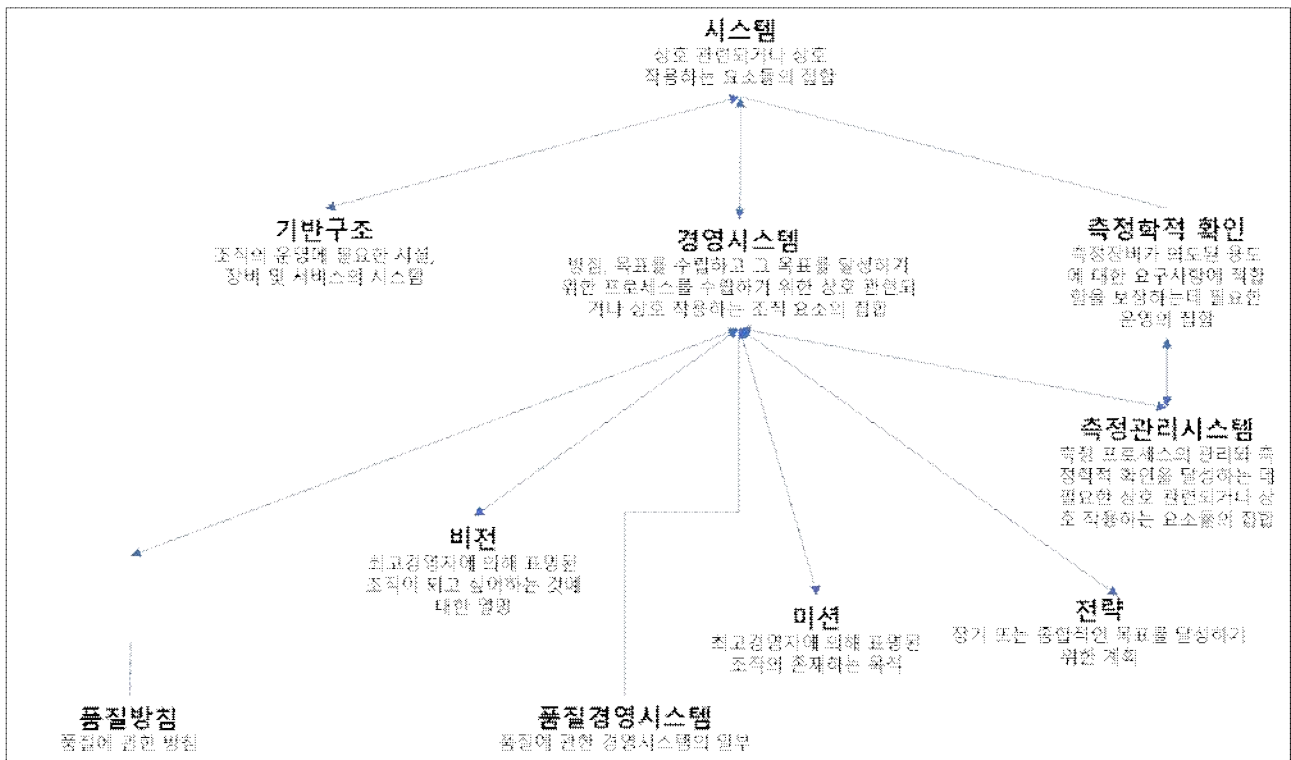


그림 5. ISO 9000 표준 시스템과 관련된 개념도

3.2.6 대상과 관련된 개념

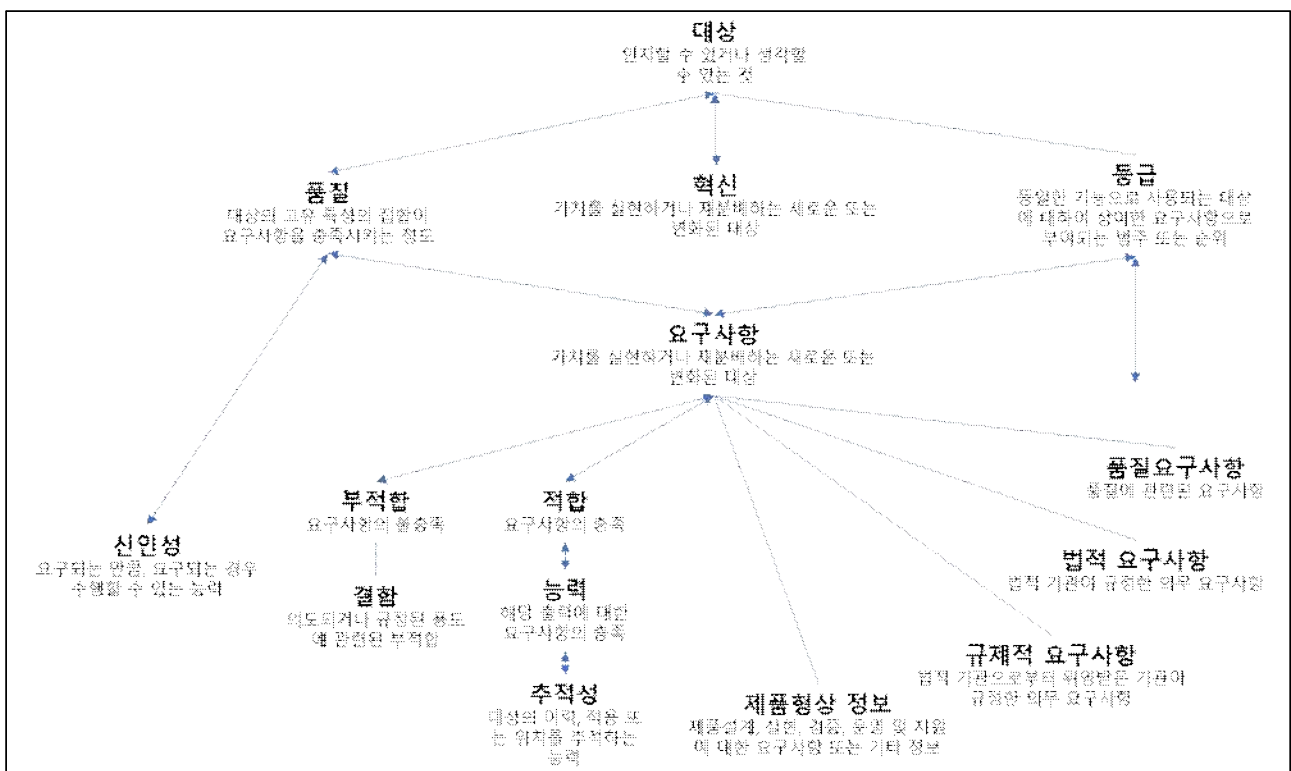


그림 6. ISO 9000 표준 대상과 관련된 개념도

3.2.7 결과와 관련된 개념

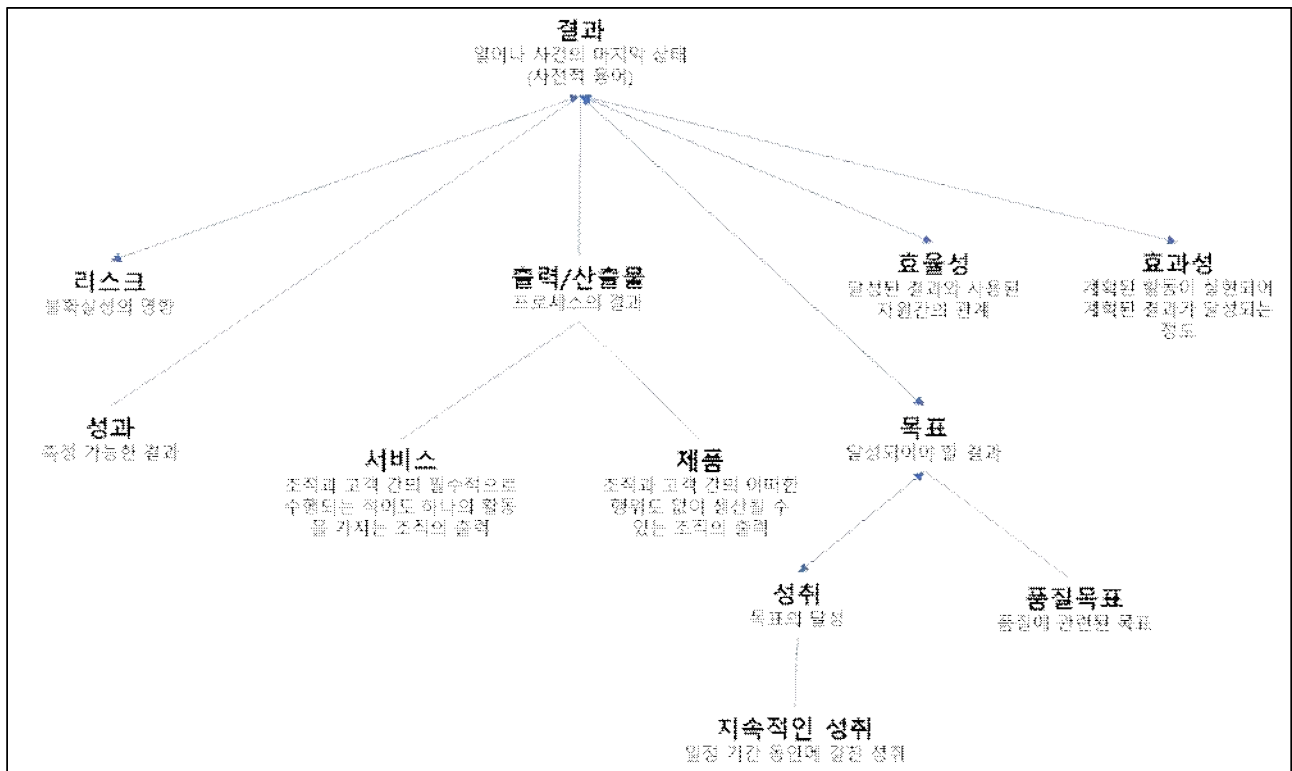


그림 7. ISO 9000 표준 결과와 관련된 개념도

3.2.8 데이터와 관련된 개념

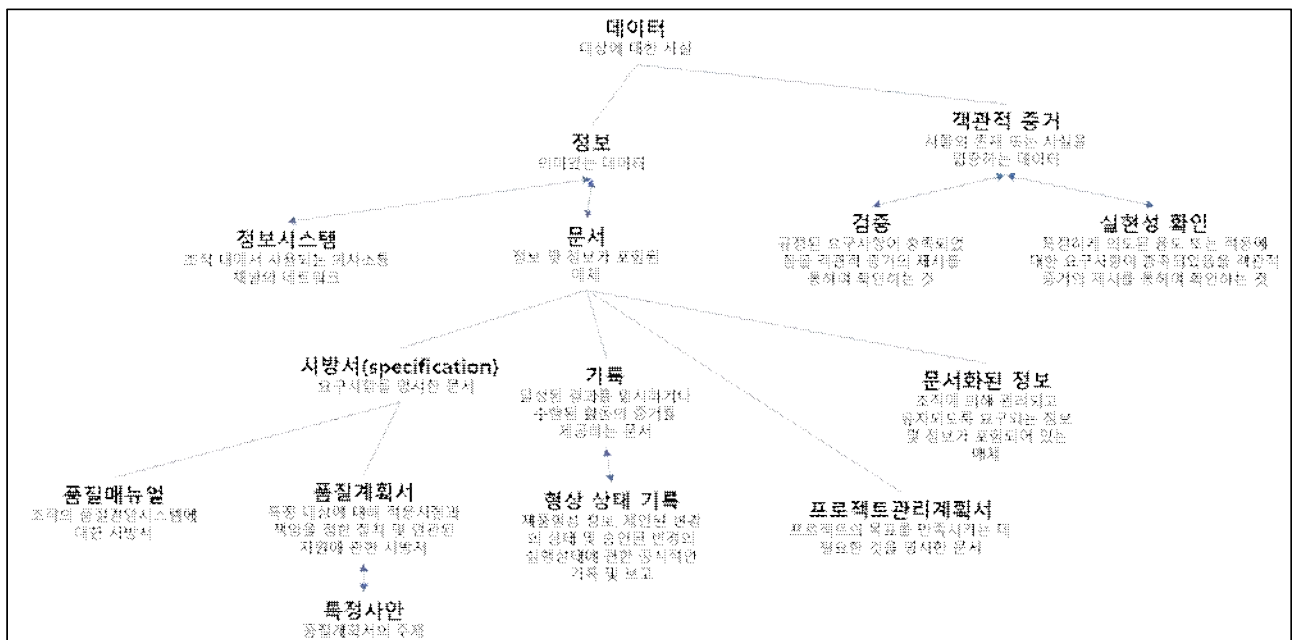


그림 8. ISO 9000 표준 데이터와 관련된 개념도

3.2.9 고객과 관련된 개념

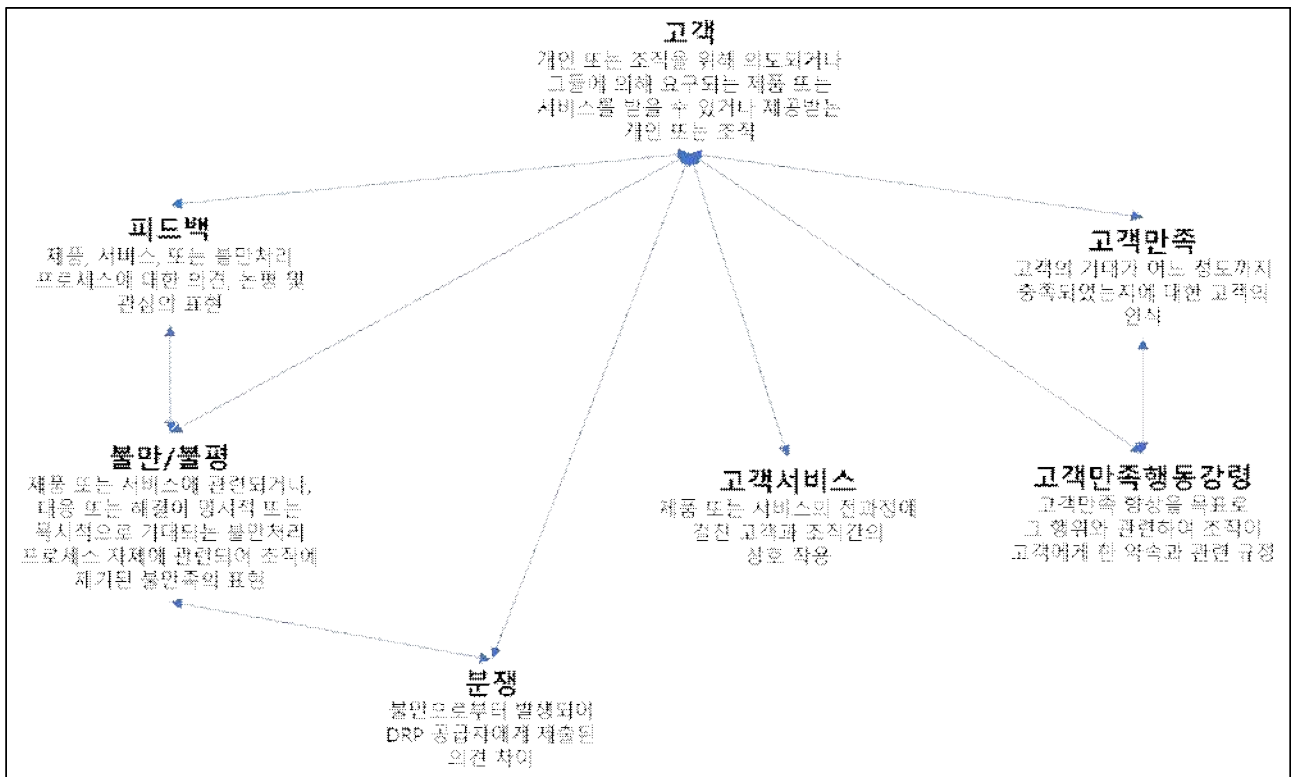


그림 9. ISO 9000 표준 고객과 관련된 개념도

3.2.10 특성과 관련된 개념

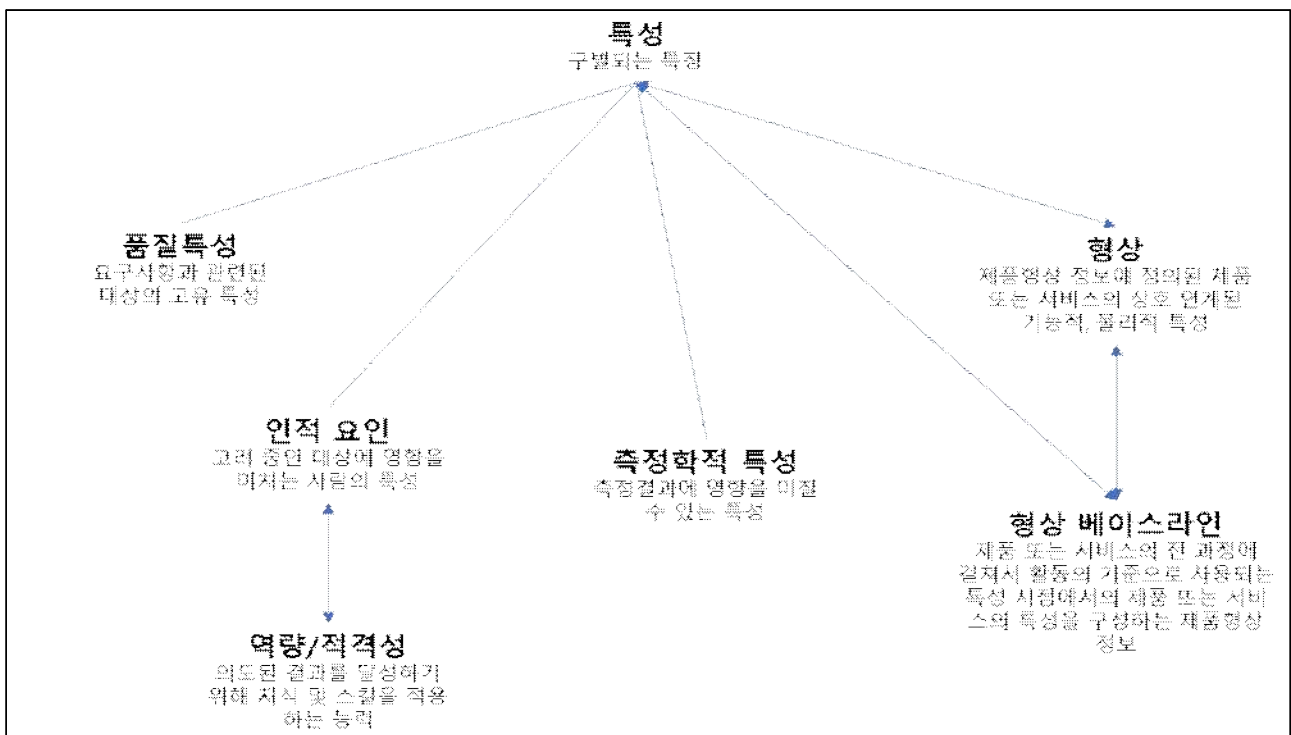


그림 10. ISO 9000 표준 특성과 관련된 개념도

3.2.11 확인결정과 관련된 개념

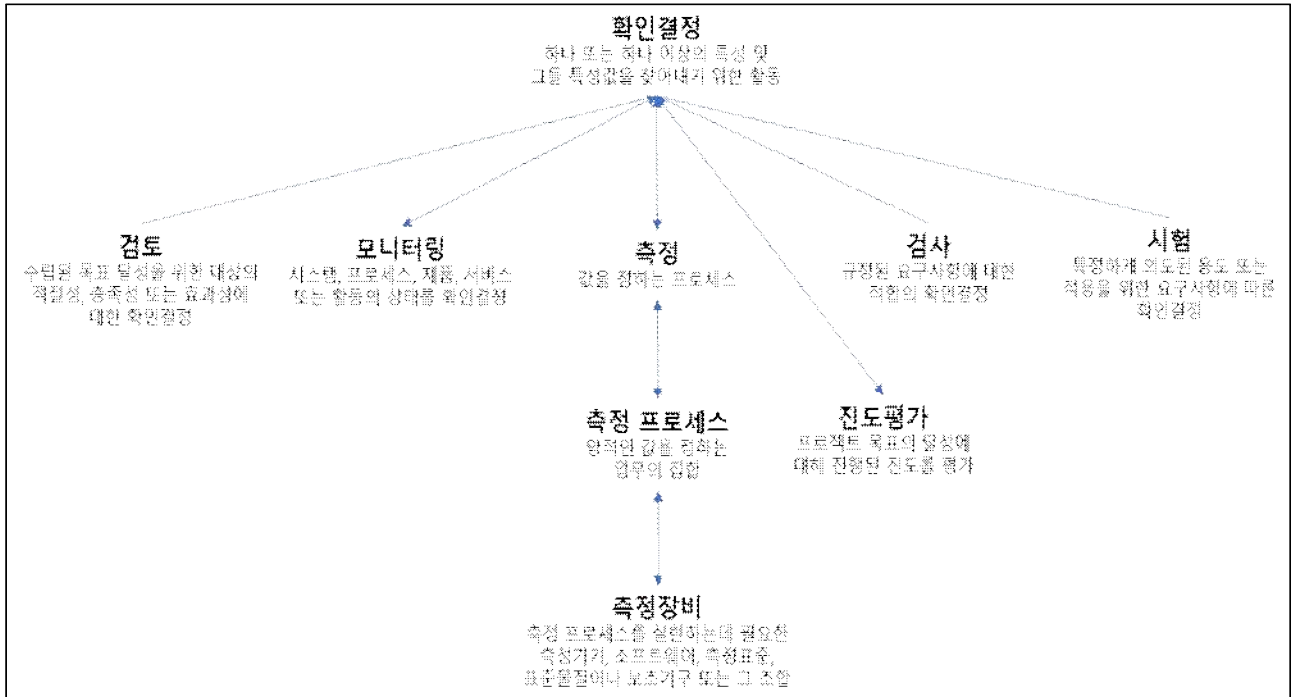


그림 11. ISO 9000 표준 확인결정과 관련된 개념도

3.2.12 조치와 관련된 개념

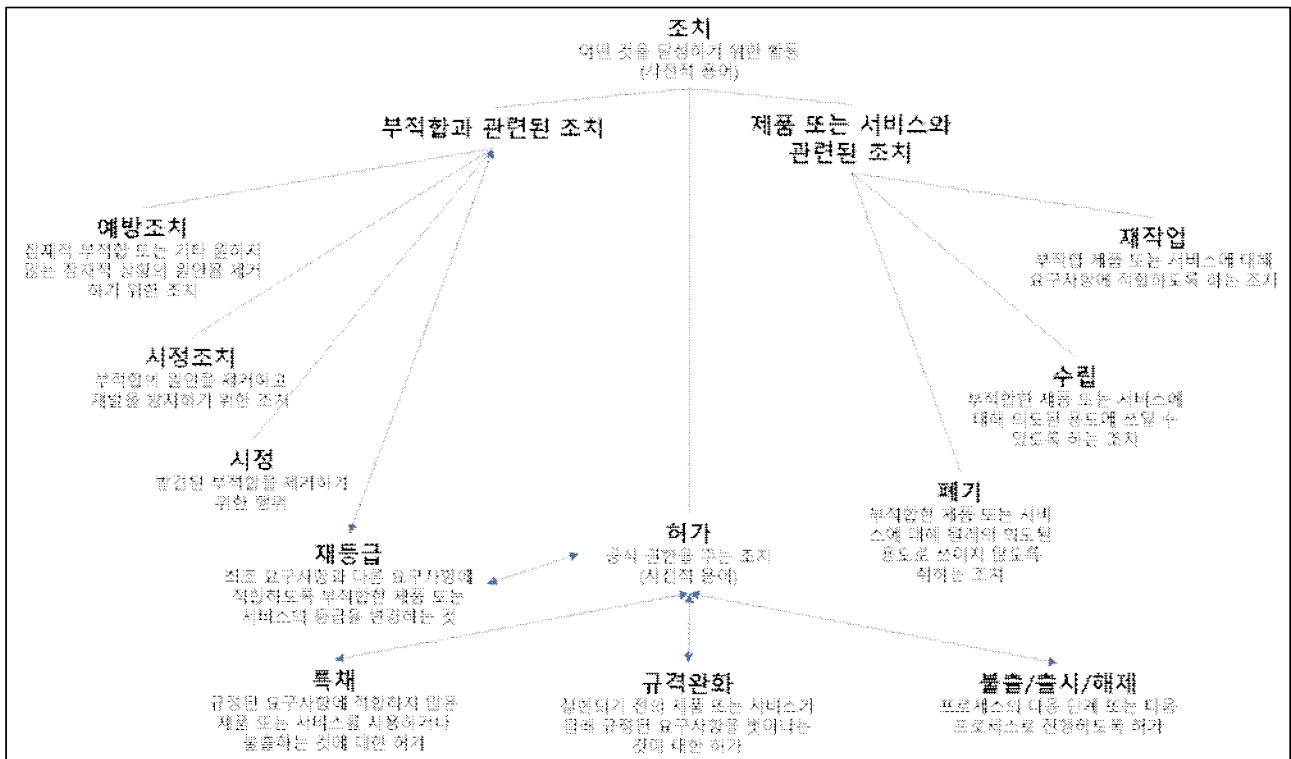


그림 12. ISO 9000 표준 조치와 관련된 개념도

3.2.13 심사와 관련된 개념

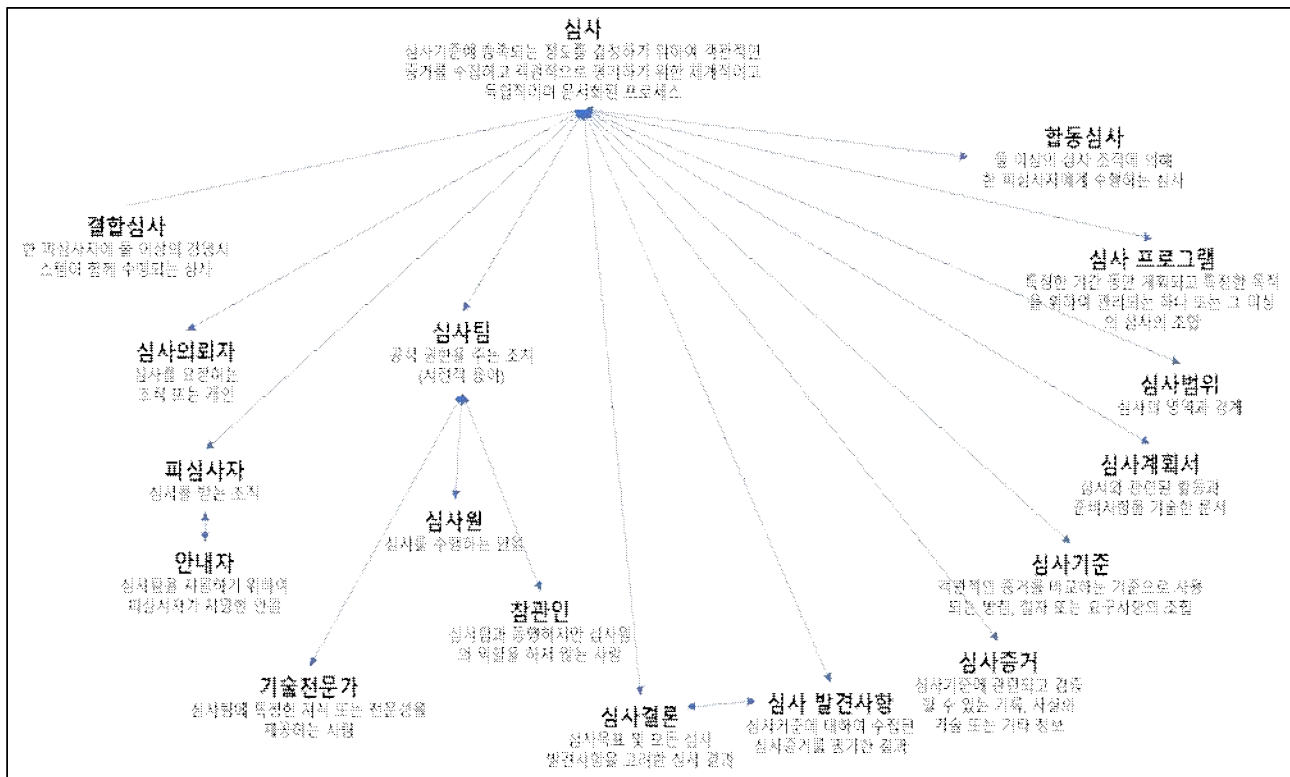


그림 13. ISO 9000 표준 심사와 관련된 개념도

4. 품질 요구사항

4.1 요구사항 개요

ISO/IEC 42001:2023 표준은 조직이 인공지능(인공지능) 시스템을 책임감 있게 개발·제공·활용하도록 지원하는 최초의 인공지능 경영시스템(AIMS) 국제표준이다. 표준은 ISO 9001:2001과 동일한 HLS(High-Level Structure)를 따르며, 조직이 인공지능 고유의 위험과 영향을 통합적으로 관리하도록 7가지(조직의 상황, 리더십, 계획, 지원, 운영, 성과평가, 개선) 상위구조로 요구사항을 제시한다.

- 조직의 상황 : 조직은 내부·외부 이슈와 이해관계자 요구를 파악하고, 기후변화 관련성까지 고려하여 인공지능 경영시스템의 경계와 적용범위를 정해야 한다. 이때 조직이 인공지능 생태계에서 수행하는 역할(제공자·개발자·사용자 등)을 명확히 규정하면 각 요구사항의 적용 깊이를 결정하는 데 도움이 된다.
- 리더십 : 최고경영진의 책임과 의지를 강조한다. 최고경영진은 인공지능 정책을 수립하고 이를 조직의 전략방향과 연계하여 자원을 배분하며, 책임과 권한을 부여해 책임 있는 인공지능 문화가 뿌리내리도록 주도해야 한다. 또한 지속적 개선을 독려하고 인공지능 경영시스템 성과를 정기적으로 보고받을 의무가 있다.
- 계획 : 위험과 기회를 구조적으로 다룬다. 조직은 우선 인공지능 리스크 기준을 설정한 뒤, 반복 가능하고 일관된 인공지능 리스크평가를 수행하고, 결과에 따라 리스크처리 계획과 통제를 설계·이행해야 한다. 동시에 인공지능 시스템 영향평가(AISIA)를 통해 개인·사회에 미칠 잠재적 결과를 검토하고, 이를 조직의 인공지능 목표와 연결해야 한다.
- 지원 : 인공지능 경영시스템 유지에 필요한 자원과 역량을 다룬다. 조직은 데이터·도구·컴퓨팅 자원과 전문 인력을 확보하고, 인공지능 정책·절차를 효과적으로 전달하기 위한 커뮤니케이션 체계를 갖추며, 모든 핵심 프로세스와 결정·기록을 문서화된 정보로 통제해야 한다.
- 운영 : 계획된 통제를 실제 업무에 녹여 실행·감독하는 단계다. 조직은 인공지능 시스템 개발·배포·운영 전 주기에 걸쳐 정의된 통제를 적용하고, 변경이나 사고 발생 시 즉시 리스크를 재평가해 대응해야 한다. 외부 공급자나 파트너가 관여하는 경우에도 동일한 수준의 통제가 유지되도록 관리 체계를 마련해야 한다.
- 성과 평가 : 조직은 인공지능 경영시스템이 의도한 결과를 달성하는지 모니터링·측정·분석하고, 정기적인 내부심사와 경영검토를 통해 적합성과 효과성을 검증한다. 이 과정에서 성능·편향·투명성 등 정량·정성 지표를 함께 활용해 개선 기회를 도출한다.
- 개선 : 지속적 향상을 위한 메커니즘이다. 조직은 부적합 발생 시 즉각 시정조치를 취하고, 인공지능 경영시스템 전반의 적합성·효율성을 주기적으로 재점검하여 지속적 개선을 추진해야 한다.

4.2 요구사항 적용범위

ISO/IEC 42001:2023 표준의 적용범위는 조직이 구축-운영하려는 인공지능 경영시스템의 경계와 적용성을 공식적으로 규정하는 과정이다. 표준 요구사항을 충실히 충족하도록 다음의 요소를 고려하는 것이 중요하다.

- 이해관계자 요구사항 및 조직의 역할 식별 : 조직은 먼저 외부·내부 이슈(법·규제, 경쟁 환경, 조직 거버넌스, 인공지능 시스템의 의도된 목적 등)와 이해관계자 요구를 식별한다. 그 다음에 인공지능 시스템에서 수행하는 조직의 역할(제공자·개발자·사용자 등)을 구체화해야 한다. 이러한 선행 작업은 적용범위를 설정할 때 포함·제외될 활동과 프로세스를 합리적으로 결정하는 입력값이 된다.
- 인공지능 경영시스템의 경계와 적용범위 결정 : 인공지능 기술이 실제로 사용·제공·개발되는 사업 부문, 조직 단위, 지역, 제품·서비스, 인공지능 수명주기 단계(데이터 수집-설계-검증-배포-모니터링 등)를 명시하고, 경계 밖 활동이라 하더라도 인공지능 경영시스템 요구가 영향을 미칠 수 있는 경우(예: 글로벌 데이터 센터의 모델 재학습) 이들 활동을 어떻게 관리할지 설명하는 내용이 포함된다. 이처럼 결정된 적용범위는 문서화된 정보로 유지되어야 하며, 관련 이해관계자에게 공개 가능하도록 준비해야 한다.
- 적용범위 제외 : ISO/IEC 42001 표준 요구사항(경영시스템, 리더십, 계획, 운영, 평가, 개선)을 임의로 제외할 수 없으며, 다만 Annex A의 통제(controls)중 일부는 리스크 평가 결과에 따라 “불필요”하다고 판단되면 적용선언서(SoA)에 제외 사유를 기록하여 정당화할 수 있다. 이때 제외가 조직의 인공지능 정책 달성 능력이나 대외 책임을 약화시켜서는 안 된다.
- 비즈니스 전략과의 일치 : 결정된 적용범위는 조직의 전략적 방향 인공지능 정책(5.2)과 일치해야 하며, 모든 해당 법적·규제 요구(개인정보보호법 등)를 충족하도록 설계되어야 한다. 또한, 신제품 출시, 조직 재편, 규제 변경과 같은 변화가 발생할 경우 적용범위를 주기적으로 재검토하여 적시 수정해야 한다.
- ISO/IEC 42001의 적용범위 결정은 단순한 경계선 표기가 아니라 인공지능 위험과 영향 관리를 위한 거버넌스 범위를 명료히 하고, 이에 따라 필요한 통제와 책임을 할당하는 핵심 절차다. 상기 지침을 토대로 범위 문서를 작성·유지하면, 향후 인증 심사뿐 아니라 내부·외부 이해관계자와의 소통에서도 일관성과 신뢰성을 확보할 수 있다.

4.3 인용표준

ISO/IEC 42001:2023 인공지능 경영시스템 요구사항에서 "인용 표준"은 조직의 인공지능 경영시스템 문서 및 관행 내에서 참조되는 특정 국제표준, 지역 또는 국가 표준을 의미한다. 아래와 같은 인용표준은 인공지능 경영시스템에 대한 벤치마크를 제공하며 프로세스가 인정된 지침 및 기준을 충족하는지 확인하는 데 필수적이다.

- ISO 42001 : 인공지능경영시스템의 구축, 실행, 유지 및 지속적 개선에 필요한 요구사항에 대한 표준을 제공한다. 본 표준은 조직이 인공지능 시스템을 책임감 있게 개발·제공·활용 하도록 지원하는 최초의 인공지능 경영시스템(AIMS) 국제표준이다.
- ISO 19011 : 효과적이고 효율적인 심사 수행을 위한 지원을 제공하는 심사 관리 시스템에 대한 지침을 제공한다.
- ISO 9001 : 조직 전반의 품질경영 원칙·프로세스를 규정한 범용 품질경영시스템에 대한 지침을 제공한다.
- ISO/IEC 22989 : 인공지능 분야의 기본 용어·개념·구조를 정의한 핵심 지침을 제공한다.
- ISO 27001 : 정보보호 관리시스템(ISMS) 요구사항과 통제항목에 대한 핵심 지침을 제공한다.
- KS Q ISO 42001 (제정 예정) : 국가기술표준원에서 인공지능 경영시스템(AIMS) 국가표준 (KS)으로 제정을 추진 중이나, 25년 4월 현재 제정되지 않았다.
- 분야별 표준 : 조직의 산업에 따라 자동차용 ISO/TS 16949 또는 의료기기용 ISO 13485와 같은 다양한 분야별 표준도 부분적으로 포함될 수 있다.

4.4 조직상황

4.4.1 조직과 상황의 이해

구분	분류번호	영역	법적/의무/권고사항
	• 4.1	• 조직상황	• 법적/의무/권고 요구사항
요구정의	• ISO/IEC 42001 4.1 조직과 상황의 이해 참조		
조직담당자 중점사항	• 외부·내부 이슈 체계적 식별 ✓ 인공지능 시스템과 관련된 법령·규제, 산업동향, 경쟁환경, 이해관계자 요구를 목록화하고 업데이트 주기 설정 • 기후변화 등 거시적 이슈 포함 여부 판단 ✓ 표준은 “기후변화가 관련 이슈인지 결정할 것”을 명시하므로, 탄소·전력 사용량 등 인공지능 운영의 환경적 영향을 검토 • 인공지능 시스템 목적·역할 정의 ✓ 조직이 인공지능 제공자인지, 사용자·통합자인지 등 역할(Role)을 문서화해 각 역할별 책임·권한을 매핑 • 이해관계자 분석 ✓ 고객, 규제기관, 데이터 제공자, 인공지능 모델 사용자, 데이터 주체 등을 구분하여 요구사항 매트릭스를 작성 • 인공지능 경영시스템 범위 결정에 필요한 데이터 수집 ✓ ISO/IEC 42001 4.3의 범위 정의를 지원할 수 있도록 시스템·사업부·제품군 단위별 영향·책임 범위를 사전 정리 • 위험(Risk)·기회(Opportunity) 연계 자료 준비 ✓ 식별한 외부·내부 이슈가 6.1 리스크 평가단계에서 어떻게 이어질지 로드맵을 마련 • 지속적 모니터링 프로세스 설계 ✓ 시장·법령 변화 감지 → 영향평가 → 인공지능 경영시스템 개정까지 흐름을 BPMN(Business Process Model and Notation) 등으로 시각화하여 실행 책임자를 지정 * BPMN : 조직의 업무 프로세스를 그래픽으로 표현하기 위한 국제 표준 (ISO/IEC 19510)		
인증심사원 중점사항	• 문서화 적정성 ✓ 외부·내부 이슈, 이해관계자 요구, 역할·책임이 최신 문서로 관리되고, 상위 정책·리스크 평가·목표와 논리적으로 연계되는지 확인 • 증거 기반성 ✓ 이슈 식별 근거(시장 조사, 규제 분석, 벤치마킹 등)와 업데이트 로그가 존재하는지 확인		

	• 포괄성 & 우선순위화 ✓ 기술·윤리·법률·경제·환경 차원을 모두 포함했는지, 리스크·기회 평가 기준이 명확한지 확인 • 기후변화 고려 여부 ✓ ‘관련 없음’으로 판단했다면 합리적 근거·승인 기록이 있는지 확인 • 인공지능 역할 정의의 명확성 ✓ ISO 22989 역할 분류에 따라 조직이 수행·위탁하는 역할이 제대로 식별 및 위험관리가 되었는지 확인 • 범위(Scope)의 타당성 ✓ 4.3 범위 문서가 4.1·4.2 결과와 연결되고, 제외 영역의 정당화가 명확한지 확인 • 경영진 참여도 ✓ 경영 검토, 예산·자원 지원, 정책 승인 등 리더십 증거가 있는지 확인 • 변경 관리 프로세스 ✓ 새로운 외부·내부 이슈 발생 시 인공지능 경영시스템 개정 절차가 작동한 이력이 있는지 확인
결함사례	• 사례 1. (불충분한 이슈 파악) ✓ 주요 결함 : 조직이 법·규제 변경(EU AI Act, 국내 산업진흥법 등)이나 기술 트렌드(LLM 도입, 그린 인공지능 요구) 같은 외부 이슈, 그리고 데이터센터 전력 증가·조직 재편 등의 내부 이슈를 체계적으로 파악·기록하지 못함. ✓ 심사원 관찰 : 외부·내부 이슈 목록이 최신화되지 않아 지난 1년간 업데이트 로그가 없음. ✓ 권고/시정 : 정기 스캔(예: 월간 규제 브리프, 분기 기술 벤치마크)을 절차서에 반영하고 결과를 리스크 레지스터·경영 검토 보고서로 연결. • 사례 2. (이해관계자 요구 미반영) ✓ 주요 결함 : 인공지능 모델 사용자·데이터 주체·규제기관의 기대사항(투명성 리포트, 삭제 권 보장 등)을 수집했으나, 목표·프로세스·성능 지표에 반영하지 않아 실행력이 없음. ✓ 심사원 관찰 : 이해관계자 매트릭스는 작성되어 있으나, 관련 조치(예: 설명가능성 지수 개선 목표)가 경영 목표·운영 절차와 매핑되지 않음. ✓ 권고/시정 : 이해관계자 요구를 KPI·내부 감사 체크리스트·서비스 수준 합의서(SLA)로 구체화하고, 실행 증거(로그·보고서)를 확보.

	• 사례 3. (위험 및 기회관리 부족) ✓ 주요 결함 : 식별된 위험(예: 데이터 편향, 모델 오류 전파)과 기회(예: 새로운 시장 진입) 평가가 정성적 메모에 그쳐 우선순위·대응계획(RTO, 완화 조치)이 부재. ✓ 심사원 관찰 : 위험평가 매트릭스가 ISO 31000 방법론을 따르지 않으며, 대응 프로세스(BCP)가 문서화되지 않음. ✓ 권고/시정 : ISO 42001 6.1과 연계하여 발생가능성(Likelihood) × 영향도(Impact) 기반 정량 스코어링, 담당 부서·실행 일정·검증 메트릭을 포함한 위험대응계획(Risk Treatment Plan) 작성 및 주기적(분기) 리뷰.
--	--

4.4.2 이해관계자의 요구사항과 기대 이해

구분	분류번호	영역	법적/의무/권고사항
	• 4.2	• 조직상황	• 의무/권고 요구사항
요구정의	• ISO/IEC 42001 4.2 이해관계자의 요구사항과 기대 이해 참조		
조직담당자 중점사항	• 이해관계자 목록 정의 ✓ 제공자·생산자·고객·파트너·인공지능 주체·규제당국 등 표준이 제시한 범주를 기본으로 이해관계자 목록 작성 • 요구·기대 수집 및 분류 ✓ 법·계약·윤리·투명성·서비스수준·기후변화 관련 요구를 설문·워크숍·계약 검토 등으로 수집하고 버전 관리 • 채택 여부 결정 ✓ “인공지능 경영시스템으로 수용 / 별도 프로세스로 대응 / 제외(근거 기록)” 3단 구분 후 승인 로그 유지 • 추적성(Traceability) 확보 ✓ 요구 → 인공지능 목표(6.2) → 리스크 통제로 이어지는 매트릭스 유지 • 변경관리 연동 ✓ 이해관계자·규제 변화 발생 시 SOP로 문서·통제·목표 동시 업데이트, 이력은 경영검토(9.3) 입력 자료로 사용 • 투명성·피드백 채널 설계 ✓ 시스템 정보 제공, 사용자 안내, 외부 신고 핫라인 등 Annex B.8 통제 구현		
인증심사원 중점사항	• 이해관계자 식별 · 포괄성 ✓ 이해관계자 목록이 ISO/IEC 42001 권장 범주(제공자·생산자·고객·파트너·인공지능 주체·규제당국)를 모두 포함하는지 확인 ✓ 조직 특수 이해관계자(주주·지역사회·산업협회 등) 추가 여부 점검 • 요구사항 결정 프로세스 · 객관성 ✓ 요구 수용/제외 기준이 서면화돼 있고 합리적 근거·승인 로그가 존재하는지 검토 ✓ 요구 수집 방식(설문·인터뷰·계약 검토 등)과 빈도·책임자 명확성 확인 • 추적성(Traceability) 검증 ✓ 이해관계자 요구 → 인공지능 목표(6.2) → 리스크 통제 간 매핑표 존재 여부 확인 ✓ 추적성 매트릭스가 최신이며 변경 이력이 로그로 남아 있는지 샘플링		

	• 문서 · 기록 상태 ✓ 이해관계자 목록, 추적 매트릭스, 커뮤니케이션·피드백 로그가 최신·승인·버전 관리 상태인지 점검 ✓ 문서 접근권한·보관·보존 기간 등 문서 관리 절차 준수 여부 확인 • 변경관리 및 경영검토 연계 ✓ 외부 규제·이해관계자 요구 변화 후 인공지능 경영시스템·문서·통제 갱신 사례가 존재하는지 확인 ✓ 변경관리 프로세스가 경영검토(9.3) 입력 자료로 사용되는지, 리뷰 주기·책임자가 명확한지 검증 • 투명성·정보제공 통제 이행 ✓ Annex A.8 ‘시스템 정보 제공’ 통제 구현(예: UI 알림, 공개 리포트) 여부 및 실제 작동 여부 샘플링 ✓ 이해관계자 불만·사고 신고 핫라인 등 피드백 루프가 운영 중이고 대응 로그가 있는지 확인
결함사례	• 사례 1. (이해관계자 누락) ✓ 결함 : 조직이 규제기관(금융·의료 감독기관) 또는 인공지능 피해 우려 시민단체를 이해관계자 목록에서 제외함. ✓ 심사원 관찰 : 이해관계자 목록에 ‘규제당국’ 항목이 없고, 해당 요구사항·보고 채널도 미정의. ✓ 권고/시정 : 목록 즉시 갱신, 요구사항 수집 워크숍 개최, 보고 절차(SLA)·연락 창구를 문서화. • 사례 2. (요구-통제 미연계) ✓ 결함 : 사용자 “인공지능 결정 근거 제시” 요구를 수집했으나 UI 기능·Annex A.8 통제에 반영하지 못함. ✓ 심사원 관찰 : 요구사항 매트릭스에는 기록이 있으나 제품 릴리스 문서와 UX 가이드에 해당 기능 부재. ✓ 권고/시정 : 기능 로드맵에 요구 반영, 변경관리 번호 부여, 릴리스 전 검증 체크리스트 추가. • 사례 3. (요구사항 업데이트 부재) ✓ 결함 : EU 인공지능 Act 등 외부 규제 변경 이후 18 개월간 이해관계자 관리대장(Stakeholder Register)와 요구 문서 미갱신. ✓ 심사원 관찰 : 경영검토(9.3) 의제에서 “이해관계자 요구 변화” 항목이 반복적으로 누락. ✓ 권고/시정 : 요구사항 검토 주기를 ‘분기 1회’로 SOP에 명시, 변경 발생 시 인공지능 경영시스템 자동 개정 및 증적 저장 프로세스 구축.

4.4.3 인공지능 경영시스템 적용 범위 결정

구분	분류번호	영역	법적/의무/권고사항
	• 4.3	• 조직상황	• 의무 요구사항
요구정의	ISO/IEC 42001 4.3 인공지능 경영시스템 적용 범위 결정 참조		
조직담당자 중점사항	- 범위 문서(Statement of Scope) 작성 ✓ 인공지능 경영시스템이 적용될 조직 경계(사업장·부서·법인)와 대상 활동·제품·서비스·인공지능 시스템을 명확히 서술 - 외부·내부 이슈 및 이해관계자 요구 반영 ✓ 조직과 상황의 이해(4.1)에서 식별한 이슈와 이해관계자의 요구사항과 기대 이해(4.2) 요구사항을 검토해 범위 결정 근거로 기록 - 역할·책임 기반 적용 범위 정의 ✓ 조직이 수행하는 인공지능역할(제공자·생산자·고객·파트너·인공지능주체·규제당국)을 명시하고 역할별 책임·통제 연결 - 예외(Exclusion) 관리 ✓ 범위에서 제외한 영역의 제외 사유·위험 영향·관리 방법을 문서화 - 다른 경영시스템과 정합성 확보 ✓ ISO9001, ISO/IEC27001 등 기존 MS 범위와 상충 여부를 검토해 통합 범위 매트릭스 작성 - 변경관리 및 주기적 검토 ✓ 조직 구조·제품 포트폴리오·규제 환경 변경 시 범위 문서를 갱신하고, 업데이트 이력을 경영검토(9.3)에 제출		
인증심사원 중점사항	- 범위 문서 완전성 ✓ 서명·버전·승인 포함 여부 및 조직·지리·기술·제품 경계의 구체성 확인 4.1·4.2 고려 적정성 ✓ 외부·내부 이슈와 이해관계자 요구가 범위 결정 근거로 서술돼 있는지 검토 - 경계·적용성 명확성 ✓ 포함·제외 사업장 및 인공지능시스템이 현장 실태와 일치하는지 샘플링 확인 - 예외 정당성 ✓ 제외 영역의 위험·기회 분석, 통제 대안, 승인 로그 존재 여부 점검		

	• 문서·기록 관리 ✓ 이해관계자 범위(SoS) 최신 버전 관리 상태 및 접근·보존 절차 준수 확인 • 변경관리 및 경영검토 연계 ✓ 조직·제품 변경 후 범위 갱신 사례, 경영검토 반영 증적, 리뷰 주기·책임자 명확성 확인
결함사례	• 사례 1. (경계 정의 불명확) ✓ 결함 : 범위 문서가 “인공지능관련 부서 전체”처럼 광범위하여 실제 해당·비해당 활동 구분 불가 ✓ 심사원 관찰 : IoT부서가 인공지능시스템을 운영하지만 범위 문서에 미기재 ✓ 권고/시정 : 사업장·부서·제품 단위로 상세 경계 재정의 후 승인 • 사례 2. (부당한 예외 설정) ✓ 결함 : 위험도가 높은 인공지능의사결정 지원 서비스(On-prem 버전)를 “파일럿”이라며 범위에서 제외 ✓ 심사원 관찰 : 예외 사유·위험 평가·통제 대안 문서가 없음 ✓ 권고/시정 : 예외 정당성 및 위험 영향 분석 작성, 필요 시 범위 재포함 또는 별도 통제 적용 • 사례 3. (범위 문서 미갱신) ✓ 결함 : 인수·합병으로 신규 인공지능연구소가 추가됐지만 12개월간 범위 문서 미수정 ✓ 심사원 관찰 : 경영검토에서 범위 적합성 검토 항목 누락, 변경관리 기록 없음 ✓ 권고/시정 : SOP에 범위 검토 주기를 분기 1회로 명시하고, 조직 구조 변경 시 즉시 업데이트 및 기록

4.4.4 인공지능 경영시스템

구분	분류번호	영역	법적/의무/권고사항
	• 4.4	• 조직상황	• 의무 요구사항
요구정의	ISO/IEC 42001 4.4. 인공지능 경영시스템 참조		
조직담당자 중점사항	- 인공지능 경영시스템 구축·운영 총괄 책임 지정 ✓ 경영층이 인공지능 경영시스템 정책 승인 및 자원(인력, 예산, 인프라) 배정 - 프로세스 식별 및 상호작용 정의 ✓ 인공지능 라이프사이클(데이터 취득-개발-배포-운영-폐기)별 프로세스와 인터페이스를 프로세스 맵으로 문서화 - PDCA(Plan-Do-Check-Act) 적용 ✓ 계획(목표·지표)→운영→모니터링·내부감사→개선 루프를 SOP에 반영 - 문서화 요구 충족 ✓ 필요한 정책, 절차, 지침, 기록(운영 로그, 감사 결과)을 “문서화된 정보”로 정의하고 버전 관리 - 역량 및 인식 확보 ✓ 인공지능 관련 역할별 필요 역량을 정의하고 교육·훈련·외부 자격으로 충족 여부를 기록 - 리스크·기회 반영 ✓ 4.1/4.2/6.1에서 식별한 리스크·기회가 인공지능 경영시스템 프로세스와 통제에 통합되어 있는지 확인 - 다른 경영시스템과 통합 운영 ✓ ISO 9001, ISO/IEC 27001, ISO 45001 등 기존 시스템과 중복·충돌 최소화를 위해 공동절차·공유 기록 설계 - 지속적 개선 메커니즘 ✓ 성과 지표 리뷰, 내부 감사, 경영검토(9.3)를 통해 인공지능 경영시스템 효과성을 주기적으로 평가·개선		
인증심사원 중점사항	- 인공지능 경영시스템 프로세스 문서 존재 여부 ✓ 프로세스 맵, 책임·권한, 상호작용이 명확히 기술돼 있는지 확인 - 자원 및 책임 배정 적정성 ✓ 경영층 승인 문서, 예산·인력 승인 기록, 역할 설명서 존재 여부 검토		

	• PDCA 사이클 이행 ✓ 인공지능 목표 및 KPI 설정 → 실행 기록 → 성과 모니터링 → 내부 감사·개선 조치 증적 샘플링 • 문서화된 정보 관리 상태 ✓ 정책·절차·운영 기록이 최신 버전 관리, 접근 통제, 보존 기간 준수 여부 확인 • 역량·의식 증적 ✓ 인공지능 담당자 교육 이수 내역, 전문 자격, 역량 매트릭스 맞춤형 점검 • 리스크·기회 통합 여부 ✓ 4.1/4.2/6.1 결과가 프로세스·통제에 연결된 근거(리스크 레지스터 링크 등) 확인 • 다른 MS와 정합성 검증 ✓ 품질·정보보호·안전 MS와 절차 충돌 또는 중복 여부, 통합 문서·공유 기록 샘플링 • 지속적 개선 실적 ✓ 경영검토 의사록, 개선 조치 완료 로그, KPI 추세 등 개선 증적 평가
결함사례	• 사례 1. (프로세스 미정의) ✓ 결함 : 인공지능 라이프사이클 프로세스 간 인터페이스가 정의돼 있지 않아 책임 공백 발생 ✓ 심사원 관찰 : 데이터 거버넌스 팀과 모델 운영 팀 간 R&R 문서 부재, 이슈 발생 시 책임 공방 ✓ 권고/시정 : 프로세스 맵 작성, 인터페이스 지점 책임자 지정, SOP 업데이트 • 사례 2. (문서화된 정보 관리 부실) ✓ 결함 : 정책·절차는 최신이나 운영 기록(테스트 결과, 배포 로그)이 미보존·무버전화 ✓ 심사원 관찰 : 모델 버전 이력과 배포 승인 로그가 스프레드시트로만 관리되어 무결성 부족 ✓ 권고/시정 : 기록 보존·버전 관리 절차 수립, 중앙 저장소(형상 관리 시스템) 사용 • 사례 3. (자원·역량 부족) ✓ 결함 : 인공지능 경영시스템 운영 담당자의 데이터 윤리 교육 미수료, 예산 미배정으로 모델 모니터링 도구 미구축 ✓ 심사원 관찰 : 교육 수료증·예산 배정 문서 부재, 모니터링 지표 수집 불가 ✓ 권고/시정 : 역량 매트릭스에 따른 연간 교육 계획 수립, 관련 도구 예산 승인 후 도입

4.5 리더십

4.5.1 리더십과 의지

구분	분류번호	영역	법적/의무/권고사항
	• 5.1	• 리더십	• 의무 요구사항
요구정의	• ISO/IEC 42001 5.1. 리더십과 의지 참조		
조직담당자 중점사항	• 인공지능 경영시스템 정책 수립·승인 ✓ 경영층이 인공지능 경영시스템 방침을 공식 문서로 제정하고 조직의 전략 방향과 연계해 승인 • 전략 통합·지속가능성 연계 ✓ 인공지능 경영시스템 목표를 조직 비전·사업 전략·ESG 및 기후변화 목표와 연계해 문서화 • 책임·권한 부여 및 역할 모델링 ✓ 인공지능 책임자(Chief 인공지능 Officer 등) 지정, 각 부서 R&R 명시, 보고 라인 설정 • 자원·예산 지원 ✓ 기술·인력·교육·도구·인프라 예산을 편성하고 승인 문서 보관 • 문화 조성 및 의사소통 ✓ 윤리적 인공지능 문화를 촉진하는 캠페인, 교육, 내부 커뮤니티 운영 계획 수립 • 리스크·기회 관리 참여 ✓ 경영층이 주요 인공지능 리스크·기회 평가 회의에 참석하고 의사결정 기록 • 내부감사·경영검토 주도 ✓ 경영층이 내부감사 결과를 검토하고 인공지능 경영시스템 개선 조치 승인		
인증심사원 중점사항	• 정책 승인 증적 ✓ 경영진 서명된 인공지능 경영시스템 방침, 전략 문서, 조직 목적과의 정합성 확인 • 자원·예산 배정 기록 ✓ 예산 집행 내역, 인력·기술 투자 계획, 승인 로그 샘플링 • 책임·권한 명확성 ✓ 조직도, 직무기술서, 승인 문서로 R&R 구체성 검증 • 경영층 참여 증거 ✓ 리스크·기회 보고서, 내부감사 의결록, 경영검토(9.3) 회의록 샘플링		

	• 의사소통·문화 증적 ✓ 캠페인 자료, 사내 교육 이수 현황, 커뮤니티 활동 로그 확인 • 지속적 개선 리더십 ✓ 개선 과제에 대한 경영층 승인·추진 현황, KPI 개선 추세 확인
결함사례	• 사례 1. (정책 미승인) ✓ 결함 : 인공지능 경영시스템 정책이 초안 상태로 6 개월간 경영층 승인 없이 운영 중 ✓ 심사원 관찰 : 방침 문서에 경영진 서명·날짜 부재, 사내 게시도 미실시 ✓ 권고/시정 : 경영층 승인 후 즉시 공표, 문서관리 절차에 따라 버전·배포 기록 유지 • 사례 2. (자원 지원 부족) ✓ 결함 : 인공지능 모델 모니터링 도구 도입 예산 미편성, 담당자 1인 과 부하 ✓ 심사원 관찰 : 예산 요청서 반려 기록, 업무 지연으로 운영 로그 누락 ✓ 권고/시정 : 예산 재편성, 인력 충원 또는 외부 서비스 계약 후 승인 문서 보관 • 사례 3. (경영검토 불참) ✓ 결함 : 최근 두 차례 내부감사 결과 보고 시 경영층 미참석, 개선 결정 미보류 ✓ 심사원 관찰 : 경영검토 회의록에 최고경영자 서명·참석 기록 없음 ✓ 권고/시정 : 경영검토 일정 재조정, 경영층 참석 의무화, 개선 실행 책임 명시

4.5.2 인공지능 정책

구분	분류번호	영역	법적/의무/권고사항
	• 5.2	• 리더십	• 의무 요구사항
요구정의	• ISO/IEC 42001 5.2 인공지능 정책 참조		
조직담당자 중점사항	• 정책 작성 및 승인 ✓ 경영층이 인공지능 정책을 공식 문서로 제정·서명하고, 법규·윤리·조직 전략과 정합성을 검토 후 승인 • 정책 내용 구성 ✓ 정책에 인공지능 목적·원칙, 법규 준수, 역할·책임, 리스크 관리, 투명성·설명 가능성, 지속가능성(기후 포함) 등에 대한 조직의 약속을 명시 • 이해관계자 요구 반영 ✓ 4.2에서 수집한 이해관계자 요구와 기대를 정책 항목별로 매핑하여 포함 • 정책 배포 및 접근성 ✓ 전 직원이 쉽게 접근할 수 있도록 인트라넷·교육·게시판 등을 통해 정책을 배포·공지 • 정기 검토 및 갱신 ✓ 최소 연 1회 또는 법·기술·조직 변화 시 정책을 검토·개정하고 버전·승인 로그를 관리 • 관련 문서와의 연계 ✓ 정책을 인공지능 경영시스템 목표(6.2), 절차(SOP), 위험 통제(Annex A/B)와 연결하여 실무 문서 간 일관성을 유지		
인증심사원 중점사항	• 정책 승인 증적 ✓ 경영진 서명·날짜가 포함된 최신 버전 정책 문서 존재 여부 확인 • 정책 내용 적합성 ✓ 법규 준수, 윤리 원칙, 역할·책임, 리스크·투명성 등 필수 항목이 포함되어 있는지 검토 • 이해관계자 요구 반영성 ✓ 정책이 4.2 요구사항을 반영했음을 보여주는 매핑 문서·로그 확인 • 배포 및 접근성 ✓ 직원 대상 공지·교육 자료, 인트라넷 게시 기록을 샘플링하여 접근성 검증 • 정책-목표-통제 추적성 ✓ 인공지능 목표, SOP, Annex A/B 통제와 정책 간의 연계 문서 (Traceability Matrix) 확인		

	• 검토·갱신 이력 ✓ 정책 검토 일정, 개정 사유, 버전·승인 로그 등 변경관리 기록 점검
결함사례	• 사례 1. (정책 부재) ✓ 결함 : 조직이 인공지능 활동을 수행하면서도 공식 인공지능 정책 문서를 제정하지 않음 ✓ 심사원 관찰 : 방침 초안만 존재, 경영진 승인·배포 기록 부재 ✓ 권고/시정 : 즉시 정책 제정·승인·공표, 문서관리 절차 수립 • 사례 2. (내용 불충분) ✓ 결함 : 정책에 역할·책임과 투명성 약속은 있으나 리스크 관리·법규 준수 항목이 누락 ✓ 심사원 관찰 : 법규 준수 관련 조항, Annex A 통제 매핑 부재 ✓ 권고/시정 : 필수 항목 추가, 정책-통제 매트릭스 작성 • 사례 3. (미배포·미갱신) ✓ 결함 : 정책이 2년간 업데이트되지 않았고, 신규 직원에게 공유되지 않음 ✓ 심사원 관찰 : 인트라넷 최신 버전에 정책 파일 없음, 교육 기록 부재 ✓ 권고/시정 : 정책 배포 채널 재정비, 연 1회 검토 주기 명시, 교육 프로그램 포함

4.5.3 조직의 역할, 책임 및 권한

구분	분류번호	영역	법적/의무/권고사항
	• 5.3	• 리더십	• 의무 요구사항
요구정의	• ISO/IEC 42001 5.3. 조직의 역할, 책임 및 권한 참조		
조직담당자 중점사항	• 역할 구조 정의 ✓ 제공자·생산자·통합자·운영자·고객 등 ISO 22989 인공지능 역할 분류를 기준으로 조직 내 역할을 식별 • 책임·권한 할당 ✓ 각 역할별 책임(R)·권한(A)·보고선(L)을 RACI 매트릭스로 문서화하고 경영층 승인 로그를 남김 • 직무기술서(JD) 갱신 ✓ 인공지능 개발자, 데이터 거버넌스 담당, 모델 위험관리자 등 핵심 직무의 역량·의무를 JD에 반영 • 권한 위임 및 승인 절차 ✓ 모델 배포·중단, 데이터 접근, 모델 변경 등 고위험 행동에 대한 승인 체계를 SOP로 마련 • 조직도·프로세스 맵 연동 ✓ 조직도에 인공지능 역할을 표시하고 각 프로세스 단계에 책임 부서를 매핑 • 권한·책임 주기적 검토 ✓ 조직 구조 변경, 역할 추가 시 직무기술서·RACI 매트릭스를 업데이트하고 승인 기록을 유지 • 책임 충돌 관리 ✓ 모델 개발자와 검증자 역할 분리 등 이해상충 방지를 위한 Segregation of Duties(SOD) 규칙을 설정		
인증심사원 중점사항	• • 역할 식별 완전성 ✓ ISO/IEC 22989 기준 역할과 조직 실무 역할이 모두 반영돼 있는지 확인 • 책임·권한 문서화 ✓ RACI 매트릭스·직무기술서·조직도에 책임·보고선이 명확히 기재돼 있는지 검토 • 승인·위임 체계 검증 ✓ 모델 배포·중단, 데이터 접근 등 고위험 작업 승인 로그를 샘플링해 절차 이행 여부 확인 • Segregation of Duties ✓ 개발·검증·운영 역할 분리, 이해상충 완화 조치가 실제로 적용되는지 현장 인터뷰·기록 확인		

	• 변경관리 연계 ✓ 조직 개편 후 역할·책임 문서가 갱신됐는지, 승인·배포 기록이 있는지 점검 • 역량·교육 연동 ✓ 각 역할에 요구되는 역량·교육 요건이 직무기술서·교육 기록과 일치하는지 확인
결함사례	• 사례 1 (역할 누락) ✓ 결함 : 인공지능 운영자가 실시간 모니터링을 수행하지만 RACI 매트릭스에 미등재. ✓ 심사원 관찰 : 운영 이슈 발생 시 담당 부서 혼선, 책임 소재 불명확. ✓ 권고/시정 : RACI 매트릭스 갱신, 운영자 책임·보고선 명시 후 승인·배포. • 사례 2 (권한 승인 절차 부재) ✓ 결함 : 데이터 과학자가 임시 패치를 직접 운영 환경에 배포, 변경 승인 로그 없음. ✓ 심사원 관찰 : 배포 기록 누락, 모델 성능 저하로 서비스 장애 발생. ✓ 권고/시정 : 배포 승인 워크플로 도입, 고위험 변경 시 이중 승인·기록 의무화. • 사례 3 (책임 충돌) ✓ 결함 : 동일 인력이 모델 개발·검증·승인을 모두 수행, SOD 미적용. ✓ 심사원 관찰 : 검증 단계 독립성 부족, 오류 발견이 지연됨. ✓ 권고/시정 : 개발·검증 역할 분리, 외부 또는 다른 팀 검증 프로세스 설정.

4.6 기획

4.6.1 리스크와 기회를 다루는 조치

4.6.1.1 일반사항

구분	분류번호	영역	법적/의무/권고사항
	• 6.1.1	• 기획	• 의무 요구사항
요구정의	• ISO/IEC 42001 6.1.1 일반사항 참조		
조직담당자 중점사항	• 리스크·기회 식별 프레임 구축 ✓ ISO 31000, NIST 인공지능 RMF 등 방법론을 택해 식별 → 분석 → 평가절차를 절차서로 정의 • 평가 기준·우선순위 설정 ✓ 영향(Impact)·발생가능성(Likelihood)·시간축(Urgency) 점수체계를 표준화해 정의 • 리스크·기회 레지스터 유지 ✓ 식별 항목, 점수, 대응 옵션, 책임자, 기한, 현황을 포함한 Risk & Opportunity Register를 상시 업데이트 • 법·윤리·기술·환경 차원 통합 ✓ 법적 제재, 편향·정확성, 탄소발자국, 사회적 수용성 등을 동일 프레임에 포함 • 대응(Treatment) 전략 문서화 ✓ 회피·완화·전이·수용 옵션을 평가해 선정 근거와 실행 계획·KPI를 기록 • 라이프사이클 연계 ✓ 데이터 취득·모델 개발·배포·운영·폐기 단계별 고유 리스크·기회를 레지스터에 매핑 • 변경 및 사건 트리거 ✓ 모델 업데이트, 규제 변경, 사고 발생 시 리스크 평가 자동 재실행 SOP를 정의		
인증심사원 중점사항	• 식별 방법론 적합성 ✓ 선택한 프레임워크(ISO 31000 등)가 절차서에 명확히 기술됐는지 확인 • 평가 기준·점수체계 검증 ✓ 영향x가능성 매트릭스, 우선순위 공식, 임계값이 문서화·승인되었는지 검토 • 리스크·기회 레지스터 샘플링 ✓ 항목·점수·대응·책임자·상태 필드가 완전하며 최근 업데이트 로그가 있는지 확인		

	• 법·윤리·환경 포함성 ✓ 법규·편향·프라이버시·환경 리스크가 레지스터에 존재하는지, 누락 항목 여부 확인 • 대응 계획 실행 증적 ✓ 완화 조치 실행 로그, KPI 추적, 책임자 보고서를 샘플링해 실효성 평가 • 라이프사이클 매핑 검증 ✓ 데이터·모델·운영 단계별 고유 리스크가 등록·갱신되는지 현장 인터뷰·기록 확인 • 변경관리 연계 ✓ 모델 변경·사고 발생 후 리스크 평가 재실행 기록과 조치 로그를 추적
결함사례	• 사례 1. (리스크·기회 목록 불완전) ✓ 결함 : 레지스터가 성능·보안 위험만 포함, 법·윤리·환경 리스크 누락. ✓ 심사원 관찰 : EU 인공지능 Act 위반 잠재 리스크가 문서에 없음. ✓ 권고/시정 : 법·윤리·환경 항목 추가, 다차원 점수체계 적용 후 승인. • 사례 2. (평가 기준 미정의) ✓ 결함 : Impact·Likelihood 정의 없이 “High/Medium/Low” 근거 불명확. ✓ 심사원 관찰 : 등급 산정 근거 문서 부재, 책임자별 평가 편차 발생. ✓ 권고/시정 : 점수 계산 공식·임계값 문서화, 교육 후 재평가 실시. • 사례 3. (대응 계획 미이행) ✓ 결함 : 고위험 모델 편향 완화 조치 ‘예정’ 상태로 6 개월간 미실행. ✓ 심사원 관찰 : 조치 기한 경과, KPI 지표 악화, 보고서 누락. ✓ 권고/시정 : 책임자 재지정, 실행 기한 재설정, 월간 진행 보고 의무화.

4.6.1 리스크와 기회를 다루는 조치

4.6.1.2 인공지능 리스크 평가

구분	분류번호	영역	법적/의무/권고사항
	• 6.1.2	• 기획	• 의무 요구사항
요구정의	• ISO/IEC 42001 6.1.2 인공지능 리스크 평가 참조		
조직담당자 중점사항	• 평가 범위 확정 ✓ 시스템·데이터·인공지능 라이프사이클 단계별로 평가 대상(모델, 데이터셋, 프로세스)을 정의하고 문서화 • 위험 시나리오 식별 ✓ 데이터 품질·편향, 설명가능성 결함, 프라이버시 침해, 보안 공격, 환경 영향 등 인공지능 특유 위험 요인을 나열 • 평가 방법 선택 ✓ ISO 31000, NIST 인공지능 RMF, ISO/IEC TR 24028 등의 기법을 선택해 점수체계(Impact × Likelihood)와 산정 공식을 수립 • 본질적(Inherent)·잔여(Residual) 리스크 산정 ✓ 기존 통제 이전·이후 위험을 모두 계산하여 우선순위를 부여하고 수용 기준을 명확히 설정 • 불확실성·가중치 고려 ✓ 데이터·모델 불확실성을 신뢰구간·가중치로 반영해 점수 왜곡을 방지 • 전문가·이해관계자 참여 ✓ 다양한 분야 전문가와 사용자·규제기관 의견을 워크숍·델파이 방식으로 반영해 편향 최소화 • 결과 기록 및 승인 ✓ 평가표, 근거, 계산 로그, 책임자 서명을 포함하는 “인공지능 Risk Assessment Report”를 작성·보관		
인증심사원 중점사항	• 범위·시나리오 완전성 ✓ 평가 대상 시스템·데이터·단계를 명확히 정의했고, 대표적 인공지능 위험 시나리오가 누락 없이 포함됐는지 확인 • 평가 방법 적합성 ✓ 공식화된 점수체계와 ISO 31000·NIST 인공지능 RMF 등 표준 기법 적용 근거가 문서에 있는지 검토 • 본질적·잔여 리스크 계산 ✓ 기존 통제 고려 전후 점수가 구분되며, 수용 기준·임계값이 승인 문서로 증빙되는지 확인		

	• 불확실성 처리 ✓ 신뢰구간·가중치 등 불확실성 요인이 점수에 반영됐는지, 근거가 명시됐는지 검증 • 이해관계자 참여 로그 ✓ 워크숍 기록, 서면 의견, 서명 등 다양한 참여 증적이 존재하는지 샘플링 • 기록·승인 상태 ✓ 인공지능 Risk Assessment Report 최신 버전·승인 서명·버전 관리 상태를 점검
결함사례	• 사례 1. (평가 범위 협소) ✓ 결함 : 프라이버시 위험만 평가하고 모델 편향·보안 위험 미포함. ✓ 심사원 관찰 : 위험 시나리오 목록이 GDPR 위반만 다름, 공격·환경 영향 누락. ✓ 권고/시정 : 위험 시나리오 전체 재식별, 편향·보안·환경 항목 추가 후 재평가. • 사례 2. (점수체계 근거 없음) ✓ 결함 : “고·중·저” 구분만 사용, Impact·Likelihood 정의·공식 부재. ✓ 심사원 관찰 : 동일 위험 항목 평가자마다 등급 차이, 일관성 결여. ✓ 권고/시정 : 수치화 공식·임계값 문서화, 평가자 교육 후 재 실시. • 사례 3. (잔여 리스크 미산정) ✓ 결함 : 기존 통제 효과를 반영하지 않아 본질적 리스크 점수만 기록. ✓ 심사원 관찰 : 보완 통제 도입 후 위험 감소 여부 불명, 수용 결정 불가. ✓ 권고/시정 : 통제 적용 후 잔여 리스크 재평가, 수용·추가 조치 결정 기록.

4.6.1 리스크와 기회를 다루는 조치

4.6.1.3 인공지능 리스크 대응

구분	분류번호	영역	법적/의무/권고사항
	• 6.1.3	• 기획	• 의무 요구사항
요구정의	• ISO/IEC 42001 6.1.3 인공지능 리스크 대응 참조		
조직담당자 중점사항	• 대응 옵션 결정 ✓ 회피(Avoid), 완화(Mitigate), 전이(Transfer), 수용(Accept) 4가지 옵션을 ISO 31000 기준으로 정의하고, 각 리스크에 적합한 방안을 선택해 Risk Register에 기록 • 완화 통제 설계·배포 ✓ 선택된 ‘완화’ 리스크에 대해 Annex A/B 통제, 기술·조직 절차, 모니터링 지표(KPI) 등을 포함한 Action Plan을 작성하고 책임자·예산·기한을 지정 • 전이·보험·계약 조치 ✓ ‘전이’ 선택 시 보험 가입, SLA·계약 조항 삽입 등 실제 전가 수단을 실행하고 근거 문서를 보관 • 잔여 리스크 수용 절차 ✓ 완화 후 남은 잔여 리스크가 수용 기준 이하인지 검증하고, 경영층 서명으로 공식 수용 결정을 문서화 • 실행 추적 및 검증 ✓ 대응 조치 완료 여부를 Action Log로 관리하고, KPI·내부감사·벤치마크 등으로 효과성을 검증·업데이트 • 변경·재평가 트리거 ✓ 통제 실패, 환경 변화, 사고 발생 시 자동으로 리스크 대응 계획을 재평가·수정하도록 SOP에 반영		
인증심사원 중점사항	• 대응 계획 존재·승인 ✓ 고·중 위험 항목마다 서면 Action Plan이 작성되고 경영층 승인 서명이 있는지 확인 • 대응 옵션 적합성 ✓ 위험 등급·조직 리스크 허용도에 비취 선택한 옵션(회피·완화 등)이 합리적인지 검토 • 통제 구현 증거 ✓ Annex A/B 통제, 기술 조치, 계약·보험 서류가 실제로 이행·보관돼 있는지 샘플링		

	• 잔여 리스크 수용 근거 ✓ 수용 기준·임계값 문서, 경영층 서명, 정기 재검토 일정이 존재하는지 확인 • 효과성 모니터링 ✓ KPI 추세, 내부감사·테스트 결과, CAPA(시정 및 예방조치) 로그를 통해 통제 효과 평가 • 변경관리 연계 ✓ 사고나 환경 변화 후 대응 계획이 갱신되고 Action Log가 업데이트되었는지 점검
결함사례	• 사례 1. (대응 계획 부재) ✓ 결함 : ‘고’ 위험으로 평가된 모델 편향 항목에 대해 Action Plan이 작성되지 않음. ✓ 심사원 관찰 : Risk Register에는 ‘To Do’ 표시만 있고 책임자·기한·통제 없음. ✓ 권고/시정 : 즉시 대응 옵션 선택, 통제·기한·책임자 포함한 Action Plan 승인·배포. • 사례 2. (통제 효과 미검증) ✓ 결함 : 모니터링 스크립트 배포 후 KPI 검증·로그 리뷰가 실시되지 않아 효과 불명. ✓ 심사원 관찰 : 배포 기록만 있고 KPI 추세·테스트 결과 문서 부재. ✓ 권고/시정 : KPI 정의·측정 주기 설정, 월간 효과성 보고서 작성·검토 절차 추가. • 사례 3. (잔여 리스크 무단 수용) ✓ 결함 : Residual Risk가 허용 기준 초과인데도 부서장이 구두로 “괜찮다” 결정. ✓ 심사원 관찰 : 경영층 서명·근거 문서 없이 수용 표시, 재평가 일정 없음. ✓ 권고/시정 : 수용 임계값·승인 권한 재확인, 경영층 서면 승인·정기 재평가 일정 확립.

4.6.1 리스크와 기회를 다루는 조치

4.6.1.4 인공지능 시스템 영향도 평가

구분	분류번호	영역	법적/의무/권고사항
	• 6.1.4	• 기획	• 의무 요구사항
요구정의	• ISO/IEC 42001 6.1.4 인공지능 시스템 영향도 평가 참조		
조직담당자 중점사항	• 인공지능 시스템 영향도 평가 프로세스 수립 ✓ 평가 목적·범위·책임·빈도를 절차서로 정의하고 경영층 승인 • 평가 지표 및 등급 체계 정의 ✓ 사용자 규모, 의사결정 자동화 수준, 잠재 피해(법적·윤리·안전·환경)를 수치화해 등급(예: 낮음/중간/높음/매우 높음) 체계를 문서화 • 정량·정성 데이터 수집 ✓ 로그·사용자 통계, 사고·컴플레인 기록, 전문가 의견을 함께 활용해 객관성을 확보 • 이해관계자 참여 및 투명성 확보 ✓ 영향도가 ‘높음’ 이상인 경우 사용자·규제기관·내부 윤리위원회 의견을 평가 과정에 포함하고 결과를 공개 • 평가 결과 보고 및 승인 ✓ “인공지능 Impact Assessment Report”를 작성해 책임자·경영층 서명을 받고, 위험 통제 계획과 연동 • 주기적 재평가 및 변경관리 ✓ 모델 변경, 서비스 확장, 법·규제 변화 시 영향도 평가를 즉시 재수행하고 레포트 버전을 갱신		
인증심사원 중점사항	• 영향도 평가 범위·기준 적정성 ✓ 절차서에 목적·범위·등급 기준이 명확히 서술돼 있고, 적용 대상 시스템 전반을 포괄하는지 확인 • 등급 체계 문서화 및 일관성 ✓ 영향도 산정 공식·임계값이 문서화돼 있으며, 샘플 시스템 간 평가 결과가 일관적인지 검토 • 데이터 근거·객관성 ✓ 로그, 사용자 수, 사고 기록 등 정량 근거와 전문가 의견 등 정성 근거가 함께 사용됐는지 확인 • 이해관계자 참여 증적 ✓ ‘높음’ 이상 등급 사례에서 사용자·규제기관 의견 수렴 로그와 공개 보고 자료 존재 여부를 샘플링		

	• 결과 활용도 ✓ 영향도 등급이 위험 통제, KPI, 외부 보고, 개선 계획에 실제로 반영되었는지 추적 • 갱신 주기 및 변경관리 ✓ 모델 변경·사업 확장 후 평가를 재수행한 기록과 버전·승인 로그가 있는지 점검
결함사례	• 사례 1. (평가 미실시) ✓ 결함 : 신규 대규모 사용자 대상 챗봇 도입 시 영향도 평가를 생략. ✓ 심사원 관찰 : 절차서에 평가 의무가 있으나 해당 프로젝트 보고서에 평가 결과 없음. ✓ 권고/시정 : 즉시 영향도 평가 수행, 결과 보고 및 통제 계획 수립 후 경영층 승인. • 사례 2. (등급 기준 근거 부족) ✓ 결함 : “중간” 등급 산정에 사용된 임계값·근거 미기재, 평가자마다 편차 발생. ✓ 심사원 관찰 : 등급 결정 공식을 찾을 수 없고 회의록에도 언급 없음. ✓ 권고/시정 : 산정 공식·임계값 문서화, 교육 후 동일 기준 재평가 실시. • 사례 3. (결과 미반영) ✓ 결함 : ‘매우 높음’ 등급을 받은 얼굴인식 시스템에 추가 통제·보고 조치 미적용. ✓ 심사원 관찰 : 위험 통제 계획에는 항목이 있으나 실행 로그·KPI 업데이트 없음. ✓ 권고/시정 : 지정 통제 즉시 이행, KPI·모니터링 대시보드 업데이트, 완료 로그 저장.

4.6.2 인공지능 목표와 목표 달성 기획

구분	분류번호	영역	법적/의무/권고사항
	• 6.2	• 기획	• 의무 요구사항
요구정의	• ISO/IEC 42001 6.2 인공지능 목표와 목표 달성 기획 참조		
조직담당자 중점사항	• 목표 설정 및 정책 연계 ✓ 인공지능 정책(5.2)·리스크·기회(6.1)를 고려하여 SMART(Specific, Measurable, Achievable, Relevant, Time-bound) 형태의 목표를 정의하고 문서화 • KPI·측정 지표 정의 ✓ 정확도, 편향 지수, 설명가능성 지수, 에너지 효율, 사용자 만족도 등 정량 KPI를 설정하고 산출 방법을 명시 • 목표 달성 계획 수립 ✓ 책임자·자원·예산·일정·중간 마일스톤을 포함한 Implementation Plan을 작성하고 경영층 승인 • 리스크·기회 반영 ✓ 각 목표 달성 과정에서 발생할 리스크·기회(6.1) 대응 조치를 계획서에 포함 • 모니터링·평가 주기 정의 ✓ KPI 측정 주기(예: 월·분기)와 보고 형태(대시보드, 경영회의)를 절차서에 규정 • 커뮤니케이션 및 인식 제고 ✓ 목표와 진행 상황을 인트라넷, 타운홀, 메일링 등으로 전 직원·이해관계자에게 정기 공유 • 변경관리·재조정 ✓ 환경 변화·리스크 변화 시 목표와 계획을 재검토·수정하고 버전·승인 로그를 유지		
인증심사원 중점사항	• 목표-정책 일관성 ✓ 인공지능 목표가 정책 및 조직 전략·ESG 목표와 정합성을 보이는지 확인 • SMART 요건 충족 ✓ 목표가 구체성·측정 가능성·달성 가능성·관련성·기한성을 갖췄는지 검토 • KPI 정의·산출 근거 ✓ 각 KPI의 정의, 데이터 원천, 계산 공식, 임계값이 문서화됐는지 확인 • 실행 계획 적정성 ✓ 책임자·자원·예산·일정이 Implementation Plan에 명시되고 승인되었는지 검토 • 리스크·기회 통합 ✓ 목표 달성 계획이 6.1 리스크·기회 대응 조치와 연결돼 있는지 샘플링		

	• 모니터링·보고 중적 ✓ KPI 대시보드, 회의록, 경영층 보고서 등 진행 상황 모니터링 로그를 확인 • 변경관리 이력 ✓ 목표·KPI가 환경 변화에 따라 갱신되고 버전·승인 기록이 유지되는지 점검
결함사례	• 사례 1. (SMART 미충족) ✓ 결함 : “인공지능 활용 선도 조직이 되겠다”와 같이 측정불가·기한 미정 목표 설정. ✓ 심사원 관찰 : KPI·기한·책임자 부재, Implementation Plan 없음. ✓ 권고/시정 : 구체·정량·기한 요소 포함한 SMART 목표 재설정, 계획서 작성 후 승인. • 사례 2. (KPI 근거 부족) ✓ 결함 : ‘편향 지수 ≤ 0.05’ KPI 설정했으나 산출 공식·데이터 원천 미기재. ✓ 심사원 관찰 : 계산 방식이 팀마다 달라 지표 신뢰성 부족. ✓ 권고/시정 : KPI 정의서 작성, 데이터 파이프라인·계산 스크립트 표준화. • 사례 3. (진행 모니터링 미실시) ✓ 결함 : KPI 측정·보고 주기 ‘월 1회’로 규정됐으나 3개월간 대시보드 최신화 미흡. ✓ 심사원 관찰 : 경영회의 자료에 KPI 현황 공백, 개선 결정 지연. ✓ 권고/시정 : 데이터 수집 자동화, 대시보드 업데이트 SLA 설정, 경영보고 재개.

4.6.3 변경의 기획

구분	분류번호	영역	법적/의무/권고사항
	• 6.3	• 기획	• 의무 요구사항
요구정의	ISO/IEC 42001 6.3. 변경의 기획 참조		
조직담당자 중점사항	- 변경 트리거 정의 및 기록 ✓ 모델 업데이트, 데이터 소스 변경, 법·규제 개정, 사고 발생 등 트리거를 목록화하고 로그로 보존 - 영향 평가 및 승인 절차 ✓ 품질·법적 준수·보안·환경 영향을 평가하고, 책임자·경영층 다단계 승인 워크플로를 SOP로 규정 - 자원·일정 계획 ✓ 변경 작업에 필요한 인력, 예산, 도구, 일정을 Implementation Plan에 추가하고 승인 - 커뮤니케이션 및 이해관계자 통보 ✓ 변경 범위·일정·영향을 내부 팀과 외부 이해관계자(고객·규제기관)에 사전 공유 - 문서·기록 업데이트 ✓ 정책, 절차, Risk Register, Traceability Matrix, 버전 로그를 동시에 갱신 - 테스트·검증 계획 ✓ 변경 후 성능·편향·보안 회귀 테스트와 롤백 전략을 수립 - 변경 후 검토·교훈 반영 ✓ 변경 완료 후 Post-Implementation Review를 실시해 교훈을 인공지능 경영시스템에 반영		
인증심사원 중점사항	- 변경 관리 절차서 존재 ✓ 트리거→평가→승인→실행→검토 단계가 문서화돼 있는지 확인 - 트리거 로그 샘플링 ✓ 최근 변경 사례의 트리거·시간·책임자 기록이 일관적으로 남아 있는지 검증 - 영향 평가·승인 증거 ✓ 평가 보고서, 다단계 전자 서명, Risk Register 연계 로그를 확인 - 문서 및 버전 업데이트 ✓ 정책·SOP·레지스터가 변경 직후 업데이트되고 버전 관리 상태인지 샘플링 - 테스트·롤백 로그 ✓ 성능 회귀·편향·보안 테스트 결과와 비상 롤백 절차 실행 여부 확인 - Post-Implementation Review ✓ 변경 후 검토 회의록, 교훈 집약 문서, 추가 개선 과제 기록이 존재하는 지 점검		

결함사례	• 사례 1. (승인 절차 생략) ✓ 결함 : 데이터셋 업데이트를 담당자가 직접 배포, 경영층 승인 로그 없음. ✓ 심사원 관찰 : SOP에 서명 단계가 규정돼 있으나 변경 이슈 티켓에 빈칸. ✓ 권고/시정 : 승인 워크플로 재교육, 전자 서명 의무화, 감사 추적 강화. • 사례 2. (영향 평가 부실) ✓ 결함 : 모델 재학습 후 편향·환경 영향 평가를 생략하여 리스크 미파악. ✓ 심사원 관찰 : Impact Assessment 폼에 'N/A' 표시, 근거 없음. ✓ 권고/시정 : 평가 템플릿에 필수 항목 설정, 편향·환경 지표 재평가 실시. • 사례 3. (문서 업데이트 누락) ✓ 결함 : 변경 완료 후 Risk Register·Traceability Matrix가 구버전 그대로. ✓ 심사원 관찰 : 레지스터 'Last Updated' 필드가 12 개월 전 날짜. ✓ 권고/시정 : 문서 갱신 SOP 강화, 변경 완료 시 자동 버전업 트리거 적용.
------	--

4.7 지원

4.7.1 자원

구분	분류번호	영역	법적/의무/권고사항
	• 7.1	• 지원	• 의무 요구사항
요구정의	ISO/IEC 42001 7.1. 자원 참조		
조직담당자 중점사항	자원 수요 식별 - 인공지능 경영시스템 목표·리스크·프로세스를 기준으로 인력·기술·인프라·재무 자원 수요를 산정하고 문서화 인력 확보 및 역량 관리 - 데이터 과학자, DevOps, 윤리 전문가 등 역할별 역량 요구사항을 정의하고 채용·교육·외부 자격으로 충족 기술·인프라 제공 - 데이터 저장소, GPU 클러스터, 모델 모니터링 도구 등 필수 인프라를 구축·유지하고 가용성 모니터링 지표를 설정 재무 예산 편성 - 연간·분기 예산에 인공지능 경영시스템 운영·개선 비용을 반영하고 승인·집행 로그를 보존 외부 공급자(서비스·SaaS·클라우드) 관리 - 공급자 선정 기준, SLA, 보안·프라이버시 요구사항을 계약서에 명시하고 주기적 성과 평가를 수행 자원 검토 주기 - 경영검토(9.3) 시 자원 적합성·충분성을 평가하고 부족분 보완 계획을 수립 문서화된 정보 유지 - 인력 매트릭스, 인프라 리스트, 예산·계약 문서, 유지보수 로그를 최신 상태로 관리		
인증심사원 중점사항	자원 식별·계획의 완전성 - 인력·기술·인프라·예산이 인공지능 경영시스템 필요사항을 모두 충족하도록 계획되었는지 확인 승인·집행 기록 - 예산 편성·승인 로그, 인프라 구매·유지보수 계약, 채용 승인 문서 샘플링 역량·교육 증적 - 역할별 역량 매트릭스, 교육 이수 기록, 자격증 사본을 통해 인력 자원 적정성 검증		

	• 인프라 가용성·성능 ✓ GPU·저장소 모니터링 지표, 다운타임 로그, 유지보수 기록 확인 • 외부 공급자 관리 ✓ 계약서에 SLA·보안 요구 포함 여부, 공급자 성과 평가·교정조치 로그 샘플링 • 자원 검토 및 개선 ✓ 경영검토 회의록에서 자원 부족 지적·조치 결정, 개선 실행 기록 확인
결함사례	• 사례 1. (인력 부족) ✓ 결함 : 데이터 거버넌스 담당이 공석으로 인공지능 경영시스템 핵심 프로세스 지연. ✓ 심사원 관찰 : 인력 수급 계획 미작성, 업무 분담표 공백. ✓ 권고/시정 : 채용 우선순위 재조정, 외부 인력 파견·교육 계획 수립. • 사례 2. (예산 미배정) ✓ 결함 : 모델 모니터링 SaaS 구독 만료 후 갱신 예산 미편성. ✓ 심사원 관찰 : 예산 요청 문서 반려, 모니터링 지표 수집 중단. ✓ 권고/시정 : 긴급 예산 편성, 예산 주기 계획에 인공지능 경영시스템 항목 고정 반영. • 사례 3. (인프라 유지보수 미흡) ✓ 결함 : GPU 서버 펌웨어 업데이트 지연으로 안전 패치 미적용 상태 지속. ✓ 심사원 관찰 : 유지보수 일정·로그 부재, 보안 취약성 경고 메모만 존재. ✓ 권고/시정 : 유지보수 캘린더·자동 알림 설정, 패치 완료 로그 및 검증 테스트 기록.

4.7.2 역량

구분	분류번호	영역	법적/의무/권고사항
	• 7.2	• 지원	• 의무 요구사항
요구정의	• ISO/IEC 42001 7.2. 역량 참조		
조직담당자 중점사항	• 역할별 역량 요구사항 정의 ✓ 인공지능 제공자·개발자·데이터 거버넌스·윤리 전문가 등에 필요한 지식·기술·경험을 직무기술서(JD)에 구체적으로 명시 • 역량 평가 및 격차 분석 ✓ 연 1회(이상) 자체 평가·시험·인터뷰로 현 역량을 측정하고, 요구사항과의 Gap 분석표를 작성 • 교육·훈련 계획 수립 ✓ 격차를 해소하기 위해 내부 워크숍, 공인 교육, MOOC, 컨퍼런스 참석을 포함한 연간 교육훈련 계획을 편성 • 외부 자격·인증 관리 ✓ 데이터 보호법 전문가, 클라우드 보안, 윤리 감사 등 필수 자격증 유지 및 만료 알림 체계를 운영 • 지식 관리·전수 ✓ 코드 리뷰, 브라운백, 위키·지식 저장소를 통해 베스트 프랙티스와 교훈을 조직적으로 공유 • 효과성 평가 및 기록 ✓ 교육 후 테스트, OKR/KPI 향상, 프로젝트 성과 등으로 교육 효과를 측정하고 결과를 교육 기록 시스템에 보존		
인증심사원 중점사항	• 역량 요구·실제 대응성 ✓ 직무기술서 vs 현인력 스킬 매핑표로 요구사항 충족도를 확인 • 격차 분석·교육 계획 ✓ Gap 분석 보고서, 연간 교육훈련 계획, 예산·승인 기록 존재 여부를 검토 • 교육·자격 증적 ✓ 교육 이수 증서, 시험 결과, 자격증 사본, 만료 알림 로그를 샘플링 • 효과성 평가 ✓ 교육 후 테스트 점수, KPI 변화, 프로젝트 성공률 자료로 성과 유무를 확인 • 지식 전수·보존 ✓ 위키, 코드 리뷰 로그, 사내 세미나 자료로 지식 공유 체계가 작동하는지 점검 • 변경관리 연계 ✓ 역할·기술 변화 시 JD·역량 요구·교육 계획이 동시에 갱신됐는지 버전 기록을 확인		

결함사례	• 사례 1. (역량 기준 불명확) ✓ 결함 : 인공지능 윤리 심의자 역할이 필수 역량을 정의하지 않아 인력 선발·교육이 무계획적으로 이뤄짐. ✓ 심사원 관찰 : JD에 “윤리 전문성 필요”만 기재, 세부 지표 없음. ✓ 권고/시정 : 역량 매트릭스에 윤리 프레임워크·법규 지식·리스크 평가 경험 등을 구체화. • 사례 2. (교육 기록 부재) ✓ 결함 : 데이터 과학자 교육을 비공식 멘토링으로만 진행, 공식 이수증 없음. ✓ 심사원 관찰 : 교육 시스템에 해당 직원의 최근 3년간 이수 기록 0건. ✓ 권고/시정 : 멘토링도 교육 로그에 등록, 연간 교육 시간·내용을 문서화·승인. • 사례 3. (자격증 만료) ✓ 결함 : 클라우드 보안 자격증(CCSP) 만료 후 갱신 미실시, 클라우드 인공지능 서비스 감사 업무 지속. ✓ 심사원 관찰 : 자격증 관리 시스템에서 ‘Expired’ 경고, 조치 로그 없음. ✓ 권고/시정 : 자동 알림·갱신 프로세스 강화, 업무 임시 정지·대체 인력 배치.
--------------------	--

4.7.3 인식

구분	분류번호	영역	법적/의무/권고사항
	• 7.3	• 지원	• 의무 요구사항
요구정의	• ISO/IEC 42001 7.3. 인식 참조		
조직담당자 중점사항	• 인공지능 경영시스템 정책·목표 인지 ✓ 모든 임직원이 인공지능 정책(5.2)과 목표(6.2)를 이해하도록 초기 온보딩·연 1회 리마인드 교육을 실시 • 역할·책임 이해 ✓ 직원이 자신의 인공지능 관련 R&R과 변경·보고 의무를 명확히 인식하도록 직무별 브리핑·매뉴얼을 제공 • 규제·윤리 영향 고지 ✓ 인공지능 법령·윤리 위반 시 조직·개인에 미칠 법적·재정·평판 리스크를 사례 중심으로 교육 • 리스크·기회와 연계 ✓ 직원이 일상 업무에서 발견한 인공지능 리스크·개선 아이디어를 리스크 레지스터(6.1)에 제보할 수 있는 채널을 운영 • 커뮤니케이션 채널 확보 ✓ FAQ, 사내 포럼, Slack·Teams 채널 등으로 인공지능 관련 질문·토론 공간을 유지 • 인식 효과 평가 ✓ 교육 전후 퀴즈, 설문, 사고·근접사고 보고 건수를 분석해 인식 수준을 측정하고 개선		
인증심사원 중점사항	• 정책·목표 인식 증적 ✓ 교육 자료, 온보딩 체크리스트, 임직원 설문 결과로 정책·목표 인지 여부 확인 • 역할·책임 이해도 ✓ 샘플 직원 인터뷰에서 자신의 인공지능 역할·보고 라인을 정확히 설명하는지 검증 • 규제·윤리 리스크 인식 ✓ 교육 콘텐츠에 법·윤리 위반 사례와 제재 내용이 포함돼 있고, 퀴즈 결과가 목표치 이상인지 점검 • 리스크·기회 제보 채널 ✓ 익명 제보함, 포럼, 티켓 시스템 등 운영 실적(제보 건수·조치 로그) 확인		

	• 효과성 평가 자료 ✓ 교육 전후 퀴즈 점수, 사고·근접사고 통계 변동, 설문 결과 등으로 인식 향상 여부 검증 • 지속 개선 루프 ✓ 평가 결과가 교육 콘텐츠·빈도 조정에 반영됐는지, 버전·승인 기록 확인
결함사례	• 사례 1. (정책 인식 부족) ✓ 결함 : 직원 3인 인터뷰 결과 “인공지능 정책이 있는지 모른다” 응답. ✓ 심사원 관찰 : 온보딩 자료에 인공지능 정책 항목 누락, 인트라넷 게시 위치 불명. ✓ 권고/시정 : 정책 링크 포함 온보딩 키트 업데이트, 연 1회 e-러닝 의무화. • 사례 2. (역할·책임 오해) ✓ 결함 : 모델 운영 담당자가 데이터 편향 이슈 발견 보고 의무를 인지하지 못함. ✓ 심사원 관찰 : 직무 매뉴얼에 ‘편향 보고’ 항목 빠짐, 보고 루트 미정. ✓ 권고/시정 : 직무별 매뉴얼·RACI 표 수정, 편향 발견 시 24시간 이내 보고 절차 교육. • 사례 3. (교육 효과 미검증) ✓ 결함 : 인공지능 윤리 교육을 실시했으나 퀴즈·설문 없이 출석만 기록. ✓ 심사원 관찰 : 효과성 지표 부재, 교육 후 사고 건수 변동 분석 없음. ✓ 권고/시정 : 사전·사후 평가 도입, KPI(사고 보고 건수·퀴즈 점수)로 교육 효과 측정 및 보고.

4.7.4 의사소통

구분	분류번호	영역	법적/의무/권고사항
	• 7.4	• 지원	• 의무 요구사항
요구정의	• ISO/IEC 42001 7.4. 의사소통 참조		
조직담당자 중점사항	• 의사소통 전략 수립 ✓ 인공지능 경영시스템 이해관계자(임직원·고객·규제당국·파트너)를 구분하고 목적·빈도·매체를 정의한 Communication Plan을 문서화 • 내부 의사소통 채널 ✓ 인트라넷 게시판, 뉴스레터, Slack/Teams, 타운홀 미팅 등으로 정책·리스크·변경 사항을 주기적으로 공유 • 외부 의사소통·투명성 ✓ 웹사이트, 투명성 보고서, 릴리스 노트, 고객 서신을 통해 인공지능 시스템 목적·제한사항·수정 내역을 공개 • 책임 및 승인 체계 ✓ 대외 발표·보도자료·규제기관 제출물은 인공지능 Communications Officer 검토 후 경영층 승인 절차 유지 • 언어·형식 적합성 ✓ 기술 수준별(전문가·일반 사용자) 언어, 접근성(장애인 접근 표준) 요구를 고려한 메시지 템플릿을 사용 • 기록 유지 및 감사 추적 ✓ 의사소통 내용, 날짜, 수신자, 승인 로그를 Communication Register에 저장하여 감사 가능하도록 관리 • 효과 측정 및 개선 ✓ 열람률, 피드백, 문의·불만 건수 등 KPI를 분석해 의사소통 계획을 주기적으로 조정		
인증심사원 중점사항	• 계획·전략 존재 여부 ✓ 이해관계자별 Communication Plan이 서면화·승인돼 있는지 확인 • 채널·빈도 실행 실적 ✓ 내부 뉴스레터, 투명성 보고서 발간 로그 등 계획 대비 실행 증적을 샘플링 • 승인·책임 체계 ✓ 대외 발표물에 인공지능 Communications Officer·경영층 서명이 있는지, 승인 기록이 보존되는지 검토 • 메시지 적합성·명확성 ✓ 샘플 문서에서 목적·한계·데이터 사용 정보가 명확히 기술됐는지, 이해관계자 수준에 맞는 언어인지 확인		

	• 기록·감사 추적성 ✓ Communication Register에 날짜·내용·수신자·승인 로그가 완전하게 남아 있는지 점검 • 효과성 평가·개선 ✓ KPI(열람률·피드백) 분석 결과, 개선 조치·계획이 문서화·실행됐는지 검증
결함사례	• 사례 1. (계획 미수립) ✓ 결함 : 인공지능 관련 의사소통이 ad-hoc으로 진행, 공식 Communication Plan 부재. ✓ 심사원 관찰 : 이해관계자별 채널·빈도·책임 정의 문서를 찾을 수 없음. ✓ 권고/시정 : 이해관계자 매핑 후 Communication Plan 수립·경영층 승인·배포. • 사례 2. (승인 절차 누락) ✓ 결함 : 규제기관 질의 회신을 팀장이 단독 작성·발송, 승인 로그 없음. ✓ 심사원 관찰 : 인공지능 Communications Officer·경영진 서명 공란, 메일 발송 기록만 존재. ✓ 권고/시정 : 대외 의사소통 승인 워크플로 재교육, 전자 서명 의무화. • 사례 3. (기록 미보존) ✓ 결함 : 투명성 보고서 과거 버전과 고객 통보 메일이 저장되지 않아 감사 추적 불가. ✓ 심사원 관찰 : Communication Register 최근 6 개월치만 존재, 이전 기록 삭제. ✓ 권고/시정 : 보존 기간 정책 수립, 중앙 레포지토리 백업, 레지스터 자동 저장 설정.

4.7.5 문서화된 정보

4.7.5.1 일반사항

구분	분류번호	영역	법적/의무/권고사항
	• 7.5	• 지원	• 의무 요구사항
요구정의	• ISO/IEC 42001 7.5.1 일반사항 참조		
조직담당자 중점사항	• 문서화 요구사항 파악 ✓ 표준이 요구하는 필수 문서(정책, 절차, 계획, 기록)와 조직 자체 정의 문서를 식별·목록화 • 문서 수명주기 관리 ✓ 생성 → 검토 → 승인 → 배포 → 보존/폐기 단계별 책임·기한을 절차서로 규정 • 식별·버전 관리 ✓ 제목, 문서 번호, 버전, 작성·승인 날짜, 작성자·승인자 정보를 메타데이터로 포함 • 접근·보안·무결성 ✓ 권한 기반 접근제어(ACL), 변경 기록(Revision history) 및 백업·복구 전략을 운영 • 보존 기간 설정 ✓ 법적·계약적 요구와 조직 정책에 따라 문서 유형별 최소 보존 기간을 정의 • 포맷·매체 표준화 ✓ PDF/A, Markdown, 전자 체계 등 승인된 포맷과 온·오프라인 매체 기준을 지정 • 변경관리 연동 ✓ 조직·프로세스·규제 변경 시 관련 문서 자동 갱신 워크플로를 설정하고 로그를 보존		
인증심사원 중점사항	• 문서 목록·식별 완전성 ✓ 필수 문서가 누락 없이 목록화되고, 식별 메타데이터가 일관성 있게 적용됐는지 확인 • 검토·승인 기록 ✓ 최근 버전의 작성·검토·승인 서명, 날짜 로그가 존재하는지 샘플링 • 버전·변경 이력 관리 ✓ 변경 기록이 추적 가능하며, 이전 버전이 보존·식별되는지 검증 • 접근통제·보안 ✓ 권한·ACL 설정, 백업·복원 테스트, 무결성 검증 로그를 확인		

	• 보존·폐기 정책 준수 ✓ 문서 유형별 보존 기간, 폐기 절차 문서와 실제 실행 로그를 비교·점검 • 규제·계약 요구 충족 ✓ 법·계약이 요구하는 특정 기록(예: 감사 로그)이 보존·보호되고 있는지 확인
결함사례	• 사례 1. (버전 관리 부재) ✓ 결함 : 정책 문서에 버전·작성자·승인자 항목이 빈칸, 변경 기록 없음. ✓ 심사원 관찰 : 동일 파일이 여러 공유 드라이브에 중복 저장. ✓ 권고/시정 : 중앙 문서관리 시스템 도입, 버전·메타데이터 필드 필수화. • 사례 2. (보존 기간 미정의) ✓ 결함 : 인공지능 모델 테스트 기록의 법적 보존 기간이 설정되지 않아 6개월 후 자동 삭제. ✓ 심사원 관찰 : 삭제 로그 확인, 규제 요구 3년 보존 불이행. ✓ 권고/시정 : 보존 기간 매트릭스 작성, 자동 삭제 설정 수정, 백업 복구. • 사례 3. (접근통제 허술) ✓ 결함 : 모든 직원이 Risk Register 편집 권한을 보유, 무단 수정 가능. ✓ 심사원 관찰 : ACL 설정 'Everyone: Edit', 변경 이력 누락. ✓ 권고/시정 : 최소 권한 원칙 적용, 편집권한 담당자 제한, 감사 로그 활성화.

4.7.5 문서화된 정보

4.7.5.2 문서화된 정보의 생성 및 현행화

구분	분류번호	영역	법적/의무/권고사항
	• 7.5	• 지원	• 의무 요구사항
요구정의	• ISO/IEC 42001 7.5.2 문서화된 정보의 생성 및 현행화 참조		
조직담당자 중점사항	• 작성 기준·템플릿 정의 ✓ 정책·절차·기록별로 제목·버전·메타데이터·서식(폰트·레이아웃)을 표준 템플릿에 규정 • 작성 책임·권한 지정 ✓ 문서 유형별 초안 작성자, 검토자, 승인자(RACI)를 지정하고 직무기술서에 반영 • 검토·교차 검증 절차 ✓ 기술·윤리·법무 등 관련 부서가 교차 리뷰하도록 워크플로를 설정하고 리뷰 체크리스트를 사용 • 승인·서명 워크플로 ✓ 전자 서명·버전 고정 후 중앙 저장소에 배포하며 서명 로그를 변경 불가 형태로 보관 • 현행화 주기 및 트리거 ✓ 최소 연 1회 정기 검토와 조직·법규·프로세스 변경 시 즉시 업데이트하도록 SOP에 명시 • 변경 이력·추적성 보존 ✓ 변경 이유, 작성·승인자, 변경 전·후 버전을 자동 기록하여 감사 추적을 가능하게 유지 • 문서 생성 자동화 도구 활용 ✓ 템플릿·승인 흐름을 문서관리 시스템(DMS)에 자동화하여 휴먼 에러를 감소		
인증심사원 중점사항	• 템플릿·작성 규격 준수 ✓ 샘플 문서가 조직 표준 템플릿·메타데이터 규정을 모두 따르는지 확인 • 검토·승인 로그 ✓ 작성자·검토자·승인자의 전자 서명·날짜가 기록돼 있고 위조 방지 조치가 있는지 검증		

	• 변경 이력·추적성 ✓ 변경 전·후 차이, 사유, 승인 로그가 자동 보존돼 버전 간 추적이 가능한지 샘플링 • 현행화 주기 이행 ✓ 연간 검토 일정 및 최근 업데이트 기록이 계획 대비 준수됐는지 확인 • 다부서 교차 검토 증적 ✓ 리뷰 체크리스트, 코멘트 로그, 해결 기록을 통해 교차 검증 절차 실효성 평가 • 중앙 저장·배포 일관성 ✓ 중앙 DMS와 팀별 사본 간 버전이 일치하는지, 오래된 문서가 사용되지 않는지 점검
결함사례	• 사례 1. (템플릿 미사용) ✓ 결함 : 개발팀이 신규 절차서를 자유 형식으로 작성해 메타데이터·버전 정보 누락. ✓ 심사원 관찰 : 중앙 DMS에 동일 주제 문서가 두 형식으로 혼재. ✓ 권고/시정 : 표준 템플릿 재교육, DMS 업로드 시 템플릿 자동검사 기능 활성화. • 사례 2. (승인 절차 누락) ✓ 결함 : 긴급 패치 안내서가 검토·승인 서명 없이 바로 배포됨. ✓ 심사원 관찰 : 승인 칸 공란, 배포 날짜·수신자만 기재. ✓ 권고/시정 : 전자 서명 필드 필수화, 승인 누락 시 배포 불가 규칙 설정. • 사례 3. (현행성 불일치) ✓ 결함 : 현장 부서가 2년 전 버전 절차서를 사용, 최신 통제 요구 미반영. ✓ 심사원 관찰 : 중앙 DMS에는 최신 1.4 버전, 현장 책자는 1.1 버전. ✓ 권고/시정 : 구버전 자동 검색·알림 기능 도입, 현장 문서 교체 주기 및 확인 로그 유지.

4.7.5 문서화된 정보

4.7.5.3 문서화된 정보의 통제

구분	분류번호	영역	법적/의무/권고사항
	• 7.5	• 지원	• 의무 요구사항
요구정의	• ISO/IEC 42001 7.5.3 문서화된 정보의 통제 참조		
조직담당자 중점사항	• 저장·보존 통제 ✓ 중앙 문서관리시스템(DMS)에만 원본을 저장하고, 중복 사본은 읽기 용으로 두며 주기적 백업·복구 테스트를 실시 • 접근·배포 통제 ✓ 역할 기반 접근제어(RBAC)로 열람·편집·삭제 권한을 구분하고, 외부 공유 시 암호화·만료 링크를 사용 • 변경·말소 통제 ✓ 문서 수정·폐기 시 이력·승인을 자동 기록하고, 폐기된 버전은 읽기 전용 아카이브로 이전 • 무결성·위조 방지 ✓ 해시값·전자서명으로 원본 무결성을 검증하고, 중요 기록은 불변 스토리지(WORM)에 보관 • 물리·환경 보호 ✓ 오프라인 보관 문서는 잠금 캐비닛·출입통제 구역에 저장하고, 화재·침수 대비 방재 설비를 점검 • 외부 제공·재제공 절차 ✓ 규제기관·고객 요청 시 문서 제공 절차, 승인 단계, 로그 보존 방법을 SOP에 명시 • 감사·모니터링 ✓ 접근·변경 로그를 주기적으로 검토해 비인가 변경·열람을 탐지하고 시정 조치를 기록		
인증심사원 중점사항	• 접근제어·권한 검증 ✓ RBAC 설정, 사용자·그룹 권한 표, 무단 접근 시도 로그를 샘플링해 권한 체계 적정성 평가 • 백업·복구 테스트 기록 ✓ 백업 주기·매체·오프사이트 보관 여부와 복구 테스트 성과 로그 확인 • 변경·삭제 추적성 ✓ 문서 변경·폐기 요청서, 승인 로그, 아카이브 위치를 검증해 추적 가능성 확인		

	• 무결성·전자서명 검증 ✓ 중요 기록의 해시·서명 값, WORM 스토리지 설정과 검증 로그 샘플링 • 물리적 보호 확인 ✓ 문서 보관실 출입통제, 방재 설비 점검표, CCTV 로그 등 물리적 보호 증적 확인 • 외부 제공 절차 준수 ✓ 최근 외부 요청 사례에서 승인·제공·로그 보존 절차가 SOP와 일치하는지 검토 • 로그 모니터링·시정 ✓ 접근·변경 로그 분석 결과, 비정상 이벤트 대응·시정 기록이 존재하는지 점검
결함사례	• 사례 1. (무단 접근 가능) ✓ 결함 : 모델 테스트 기록 폴더가 ‘읽기/쓰기: Everyone’으로 설정돼 편집·삭제 가능. ✓ 심사원 관찰 : ACL 설정 미흡, 변경 로그에 비인가 수정 흔적. ✓ 권고/시정 : RBAC 재구성, 최소 권한 원칙 적용, 무단 변경 시 알림 설정. • 사례 2. (백업·복구 미검증) ✓ 결함 : DMS 주간 백업은 수행하나 복구 테스트를 1년 넘게 미 실시. ✓ 심사원 관찰 : 재난 복구 계획서에 ‘테스트 주기 6개월’ 규정 불이행. ✓ 권고/시정 : 복구 시나리오 테스트 즉시 수행, 결과 보고서·교훈 등록. • 사례 3. (폐기 추적 불가) ✓ 결함 : 구버전 절차서가 삭제됐으나 폐기 승인·아카이브 로그 없음. ✓ 심사원 관찰 : DMS ‘Deleted’ 기록만 남고 승인·이유 필드 공란. ✓ 권고/시정 : 폐기 요청·승인 워크플로 강화, 폐기 문서 WORM 아카이브로 자동 이동 및 로그 보존.

4.8 운용

4.8.1 운용 기획 및 관리

구분	분류번호	영역	법적/의무/권고사항
	• 8.1	• 운용	• 의무 요구사항
요구정의	• ISO/IEC 42001 8.1. 운용 기획 및 관리 참조		
조직담당자 중점사항	• 운용 범위 및 기준 설정 ✓ 인공지능 시스템(데이터 취득-개발-검증-배포-운영-폐기) 전 단계별 입력·활동·출력 기준과 허용 오차를 절차서로 정의 • 요구사항 수용 및 매핑 ✓ 이해관계자 요구·법규·정책·리스크 통제를 운영 SOP·체크리스트에 연결해 실행 가능하도록 문서화 • 프로세스·자원 계획 ✓ 일정, 인력, 인프라, 품질게이트, 변경·릴리스 캘린더를 포함한 Operation Plan을 수립하고 승인 • 외부 프로세스·공급자 관리 ✓ 클라우드, 데이터 라벨링 등 외주 활동에 대해 SLA·보안·품질 기준을 계약서에 명시하고 성과를 모니터링 • 운영 기준·절차 실행 ✓ 코드-데이터 형상관리, CI/CD, 운영 모니터링, 로그 수집, 보안 패치 등 절차를 실행하고 실행 로그를 기록 • 변경·이벤트 대응 ✓ 장애, 성능 저하, 법규 변경 등 이벤트 발생 시 비상 절차(Incident Response), 변경관리(6.3) 프로세스를 즉시 발동 • 검토·개선 피드백 루프 ✓ KPI·사고·감사 결과를 월간/분기 운영 리뷰에서 분석하고 개선안·교훈을 SOP와 툴체인에 반영		
인증심사원 중점사항	• 운영 계획 문서화 ✓ 입력-활동-출력 기준, 일정, 자원, 품질게이트가 Operation Plan에 명시되고 승인됐는지 확인 • 요구사항 매핑 완전성 ✓ 법규·정책·리스크 통제가 운영 체크리스트와 일대일 매핑돼 있는지 검토		

	• 실행·로그 증적 ✓ 배포 로그, 모니터링 대시보드, 형상관리 기록으로 SOP가 실제 이행됐는지 샘플링 • 외부 공급자 통제 ✓ SLA·보안·품질 요구가 계약서에 포함되고, 공급자 성과 평가·교정조치 로그가 존재하는지 확인 • 변경·사고 대응 절차 ✓ 장애 티켓·사고 보고, 변경관리 승인 로그를 통해 대응 프로세스 작동 여부 검증 • 피드백·개선 반영 ✓ 운영 리뷰 회의록, 개선 조치 실행 로그, SOP·툴 업데이트 기록으로 PDCA 루프 확인
결함사례	• 사례 1. (운용 기준 미정의) ✓ 결함 : 모델 배포 승인 기준·품질게이트가 문서화되지 않아 개발자가 임의 배포. ✓ 심사원 관찰 : Operation Plan에 배포 체크리스트·승인 단계 공란. ✓ 권고/시정 : 품질게이트·승인 책임자 명시, 배포 전 자동 테스트 스크립트 추가. • 사례 2. (외부 공급자 관리 부재) ✓ 결함 : 데이터 라벨링 외주사와 SLA·보안 조항 없이 구두 계약 진행. ✓ 심사원 관찰 : 계약서 미존재, 라벨 품질 오류율 15% 기록. ✓ 권고/시정 : 표준 계약서·SLA 채택, 성과 지표·교정조치 절차 문서화. • 사례 3. (사고 대응 지연) ✓ 결함 : 모델 오류로 사용자 피해 발생 후 4시간 동안 사고 보고 미착수. ✓ 심사원 관찰 : 비상 연락망 부재, 사고 보고가 다음날 이루어짐. ✓ 권고/시정 : 24/7 대응팀 지정, 사고 보고 기준 30분 내 보고·대응 SOP 교육.

4.8.2 인공지능 위험평가

구분	분류번호	영역	법적/의무/권고사항
	• 8.2	• 운용	• 의무 요구사항
요구정의	ISO/IEC 42001 8.2. 인공지능 위험평가 참조		
조직담당자 중점사항	- 사전 위험평가 실시 시점 정의 ✓ 데이터 취득, 모델 설계, 검증, 배포 전 단계마다 'Gate'로 지정해 위험 평가를 수행하고 기록 - 위험 시나리오 업데이트 ✓ 새로운 데이터 소스, 아키텍처 변동, 사용 사례 확장 등 변경사항을 반영해 위험 시나리오 목록을 주기적으로 갱신 - 평가 방법·지표 표준화 ✓ Impact×Likelihood 점수체계와 편향 지수, 설명가능성 점수, 환경 지표 등 정량·정성 지표를 표준 템플릿에 포함 - 다부서 협업 평가 ✓ 기술, 윤리, 법무, 보안, 환경 전문가가 교차 검토하도록 팀 구성을 명시하고 회의록을 보관 - 위험평가 보고서 작성·승인 ✓ “인공지능 Risk Assessment Report”에 범위, 시나리오, 점수, 대응 계획, 책임자 서명을 포함해 중앙 저장소에 보관 - 대응 조치 연계 ✓ 평가 결과가 ‘고’·‘중’ 이상이면 6.1.3 위험 대응 프로세스를 자동 트리거하고 Action Plan을 생성 - 재평가 주기·트리거 ✓ 모델 재학습, 성능 저하, 규제 변경, 사고 발생 시 즉시 재평가하고 버전·승인 로그를 업데이트		
인증심사원 중점사항	- Gate 기반 평가 실행 증적 ✓ 각 단계(데이터, 설계, 검증, 배포)에서 평가 보고서와 승인 기록이 존재하는지 샘플링 - 위험 시나리오 완전성 ✓ 편향, 프라이버시, 보안, 안전, 환경, 법적·윤리 리스크가 누락 없이 포함됐는지 확인		

	• 점수체계·지표 근거 ✓ Impact·Likelihood 정의, 지표 계산 공식, 임계값 문서화 여부 검토 • 다부서 교차 검토 로그 ✓ 평가 회의록, 체크리스트, 코멘트 해결 기록으로 협업 절차 실효성 확인 • 대응 조치 연계성 ✓ ‘고’ 위험 항목이 6.1.3 Action Plan으로 연결되고 실행 로그가 있는지 확인 • 재평가·버전 관리 ✓ 변경·사고 후 재평가 수행 기록, 이전 버전·변경 사유·승인 로그 점검
결함사례	• 사례 1. (평가 생략) ✓ 결함 : 신규 모델 배포 일정 압박으로 위험평가 단계 건너뛰. ✓ 심사원 관찰 : Gate 승인 로그 공란, 리스크 레지스터 항목 ‘TBD’. ✓ 권고/시정 : 배포 중지, 즉시 평가 수행 후 승인·Action Plan 완료 뒤 재배포. • 사례 2. (시나리오 누락) ✓ 결함 : 프라이버시·보안 위험만 평가, 모델 편향·환경 영향 누락. ✓ 심사원 관찰 : 보고서 항목 편향·환경 칸 ‘N/A’, 근거 없음. ✓ 권고/시정 : 시나리오 목록 갱신, 누락 항목 점수화·대응 계획 수립. • 사례 3. (재평가 미이행) ✓ 결함 : 데이터 소스 변경 후 3개월간 위험평가 업데이트 안 됨. ✓ 심사원 관찰 : 재평가 트리거 발생 로그 있으나 보고서 버전 불변. ✓ 권고/시정 : 변경 감지 알림→재평가 자동 워크플로 활성화, 재평가 완료 후 승인 로그 저장.

4.8.3 인공지능 위험 대응

구분	분류번호	영역	법적/의무/권고사항
	• 8.3	• 운용	• 의무 요구사항
요구정의	• ISO/IEC 42001 8.3. 인공지능 위험 대응 참조		
조직담당자 중점사항	• 위험 대응 옵션 선정 ✓ 평가 결과(8.2) 기반으로 회피(Avoid), 완화(Mitigate), 전이(Transfer), 수용(Accept) 네 가지 중 적합한 옵션을 선택하고 선택 근거를 Risk Register에 기록 • 완화 통제 설계 · 우선순위 부여 ✓ ‘고’ 및 ‘중’ 위험 항목에 대해 Annex A/B 기술·조직 통제, 모니터링 KPI, 실행 기한을 포함한 Action Plan을 작성하고 예산·책임자를 지정 • 전이·보험·계약 실행 ✓ 전이 옵션이 선택된 위험(예: 책임 소송)에는 보험 가입, 파트너 계약의 책임 한도·SLA 조항 삽입 등 실제 이전 수단을 시행하고 증빙 문서를 보관 • 수용 절차 및 승인 ✓ 완화 후 잔여 위험이 허용 기준 이하일 경우 경영층 서면 승인으로 공식 수용하고, 재검토 주기를 지정 • 이행 모니터링 · CAPA(시정 및 예방조치) ✓ Action Plan 진행 상황을 Action Log로 추적하고, KPI·내부감사·테스트 결과로 통제 효과를 검증하며 CAPA(시정 및 예방조치)를 기록 • 변경·사고 트리거 연동 ✓ 통제 실패, 모델 변경, 사고 발생 시 위험 대응 계획을 자동 재평가·수정하도록 SOP에 포함		
인증심사원 중점사항	• 대응 계획 존재 · 승인 ✓ ‘고’·‘중’ 위험마다 서면 Action Plan이 작성되고 경영층 승인 서명이 있는지 확인 • 옵션 적절성·우선순위 ✓ 위험 등급·허용도에 비해 선택한 대응(회피·완화 등)이 합리적이고 긴급도가 반영됐는지 검토 • 통제 구현 증적 ✓ Annex A/B 통제, 기술 조치, 보험·계약 문서가 실제 이행·보관되는지 샘플링		

	• 잔여 위험 수용 근거 ✓ 수용 임계값, 경영층 서명, 재검토 일정이 문서화돼 있는지 확인 • 모니터링·CAPA(시정 및 예방조치) 실효성 ✓ KPI 추세, 내부감사 보고서, 교정조치 완료 로그를 통해 통제 효과 평가 • 변경관리 연계 ✓ 변경·사고 후 Action Plan이 갱신되고 Action Log가 업데이트됐는지 점검
결함사례	• 사례 1. (대응 계획 부재) ✓ 결함 : ‘고’ 위험인 데이터 편향 항목에 대해 Action Plan이 작성되지 않음. ✓ 심사원 관찰 : Risk Register에 ‘To Do’만 표시, 책임자·기한·통제 상세 없음. ✓ 권고/시정 : 즉시 대응 옵션 선택, 통제·책임자·기한 포함한 Action Plan 승인·배포. • 사례 2. (통제 효과 미검증) ✓ 결함 : 모델 모니터링 스크립트 배포 후 KPI 검증·로그 리뷰가 실시되지 않아 효과 불명. ✓ 심사원 관찰 : 배포 로그만 존재, KPI 추세·테스트 결과 문서 부재. ✓ 권고/시정 : KPI 정의·측정 주기 설정, 월간 효과성 보고서 작성·검토 절차 추가. • 사례 3. (잔여 위험 무단 수용) ✓ 결함 : 잔여 위험이 허용 기준 초과인데 부서장이 구두로 “수용” 결정, 서면 근거 없음. ✓ 심사원 관찰 : 경영층 서명·수용 기준 문서 부재, 재평가 일정 미설정. ✓ 권고/시정 : 수용 임계값·승인 권한 재확인, 경영층 서면 승인 및 정기 재평가 일정 확립.

4.8.4 인공지능 시스템 영향도 평가

구분	분류번호	영역	법적/의무/권고사항
	• 8.4	• 운용	• 의무 요구사항
요구정의	• ISO/IEC 42001 8.4. 인공지능 시스템 영향도 평가 참조		
조직담당자 중점사항	• 평가 목적 · 범위 정의 ✓ 평가가 적용될 시스템, 데이터, 사용 사례, 이해관계자를 명시하고 경영층 승인으로 확정 • 영향도 등급 체계 수립 ✓ 사용자 규모, 자동화 수준, 잠재 피해(법적·윤리·안전·환경·경제)를 점수화해 ‘낮음/중간/높음/매우 높음’ 등급을 문서화 • 데이터 수집 · 분석 ✓ 로그, 사고·컴플레인 기록, 성능 지표, 비용·환경 데이터 등 정량 정보와 전문가 의견을 통합 분석 • 이해관계자 참여 확보 ✓ ‘높음’ 이상 등급 예상 시 사용자, 규제기관, 내부 윤리위원회 의견 수렴 워크숍을 개최하고 회의록을 보존 • 평가 보고서 작성 · 승인 ✓ 범위, 지표, 점수, 등급, 권장 통제, 책임자 서명을 포함한 “인공지능 Impact Assessment Report”를 작성·중앙 저장소에 등록 • 재평가 · 변경관리 연동 ✓ 모델 변경, 서비스 확장, 규제 개정, 사고 발생 시 즉시 재평가해 버전·승인 로그를 갱신 • 투명성 및 공개 ✓ ‘높음/매우 높음’ 결과는 요약본·대응 계획을 웹사이트·투명성 보고서로 외부에 공개		
인증심사원 중점사항	• 범위 · 등급 기준 적정성 ✓ 목적·범위·등급 기준이 절차서에 명확히 정의되고 적용 대상 시스템을 포괄하는지 확인 • 지표·점수 산정 근거 ✓ 산정 공식, 임계값, 데이터 원천이 문서화돼 있으며 일관성 있게 적용됐는지 검토		

	• 이해관계자 의견 중적 ✓ ‘높음’ 이상 사례에서 사용자·규제기관 의견 수렴 로그와 공개 자료 존재 여부 샘플링 • 보고서 승인 · 버전 관리 ✓ Impact Assessment Report가 최신 버전·경영층 서명을 갖추고 중앙 저장소에 보관됐는지 확인 • 결과 활용·통제 연계 ✓ 등급 결과가 위험 통제(§ 8.3), KPI, 외부 보고, 개선 계획에 반영됐는지 추적 • 재평가·변경관리 이행 ✓ 모델 변경·사고 후 재평가 로그, 버전·승인 기록이 있는지 점검
결함사례	• 사례 1. (평가 미실시) ✓ 결함 : 대규모 사용자 대상 얼굴인식 서비스 배포 전에 영향도 평가를 건너뛴. ✓ 심사원 관찰 : 절차서에 ‘사전 평가 필수’ 규정 있으나 보고서·승인 로그 부재. ✓ 권고/시정 : 배포 중지 후 즉시 영향도 평가 수행, 결과 기반 위험 통제·공개 조치 실행. • 사례 2. (등급 기준 불명확) ✓ 결함 : “중간” 등급 산정에 사용된 임계값·근거 문서 누락, 평가자마다 편차 발생. ✓ 심사원 관찰 : 보고서에 공식·데이터 출처 미기재, 회의록 근거 없음. ✓ 권고/시정 : 산정 공식·임계값·데이터 원천 문서화, 평가자 교육 후 재평가. • 사례 3. (결과 미반영) ✓ 결함 : ‘매우 높음’ 등급을 받은 챗봇에 추가 통제·보고·사용자 안내가 미적용. ✓ 심사원 관찰 : 위험 통제 계획 항목 존재하지만 실행 로그·KPI 업데이트 없음. ✓ 권고/시정 : 지정 통제·사용자 고지 즉시 이행, KPI·모니터링 대시보드 업데이트 및 완료 로그 저장.

4.9 성과평가

4.9.1 모니터링, 측정, 분석 및 평가

구분	분류번호	영역	법적/의무/권고사항
	• 9.1	• 성과평가	• 의무 요구사항
요구정의	• ISO/IEC 42001 9.1. 모니터링, 측정, 분석 및 평가 참조		
조직담당자 중점사항	• 모니터링 체계 설계 ✓ 정책·목표(6.2)·리스크 대응(8.3)과 연계한 KPI·KRI 목록을 작성하고 측정 주기·책임자를 지정 • 데이터 수집·품질 관리 ✓ 로그·대시보드·설문 등 데이터 소스별 정확성·완전성·무결성을 검증하며, 자동 수집 파이프라인을 구축 • 도구·플랫폼 구축 ✓ 인공지능Ops/ML 모니터링 툴, BI 대시보드, 로그 분석기(ELK, Grafana 등)를 배포하고 접근권한·백업을 설정 • 분석 방법 정의 ✓ 추세 분석, 경계값 알림, 편향 지수 계산, 환경 지표(탄소 배출) 산출 등 통계·ML 기법을 절차서에 명시 • 정보·대응 워크플로 ✓ 임계값 초과·이상 탐지 시 Incident Response·변경관리(6.3)를 자동 트리거하도록 SOP에 포함 • 성과 보고 및 검토 ✓ 월간 팀 리포트, 분기 경영회의, 연간 지속가능성 보고서 등 다층 보고 채널을 운영 • 지속적 개선 연계 ✓ 분석 결과를 내부감사·CAPA(시정 및 예방조치)·목표 재설정 등에 반영하고, 교훈(lessons learned)을 레지스터에 기록		
인증심사원 중점사항	• KPI·KRI 목록·정합성 ✓ 목표·리스크와 일치하며 SMART 요건을 충족하는지 확인 • 데이터 품질·무결성 ✓ 샘플 로그·데이터셋에서 무결성 해시, 결측·중복 검증 절차 존재 여부 확인		

	• 도구 설정·접근제어 ✓ 모니터링 플랫폼 접근권한·백업·보안 패치 로그 검토 • 알림·대응 실행성 ✓ 임계값 초과 시 알림·Incident Report·변경 승인 로그로 워크플로 작동 여부 검증 • 보고·검토 이력 ✓ 월간·분기 보고서, 경영검토(§ 9.3) 회의록에서 지표 해석·결정 사항 확인 • 개선 조치 추적 ✓ KPI 악화 → CAPA(시정 및 예방조치) → 지표 회복 과정이 로드맵·로그로 추적되는지 샘플링
결함사례	• 사례 1. (지표 누락) ✓ 결함 : 편향 지수·환경 지표가 KPI 목록에 없어 위험 감지 불가. ✓ 심사원 관찰 : 목표·리스크 문서에는 항목 존재, 모니터링 대시보드엔 미 표시. ✓ 권고/시정 : KPI 목록 갱신, 대시보드·알림 규칙 추가, 책임자 지정. • 사례 2. (데이터 무결성 미확보) ✓ 결함 : 로그 손상으로 3일치 모니터링 데이터 공백 발생. ✓ 심사원 관찰 : 백업·해시 검증 절차 누락, 복구 실패. ✓ 권고/시정 : 무결성 해시·오프사이트 백업 도입, 복구 테스트 주기 설정. • 사례 3. (경보 미대응) ✓ 결함 : 설명가능성 지수 임계값 초과 알림을 48 시간 방치. ✓ 심사원 관찰 : Incident 티켓 미생성, 대응·교정조치 로그 없음. ✓ 권고/시정 : 알림→Incident 자동 생성 연동, SLA 2 시간 내 초기 대응 규정·교육.

4.9.2 내부 심사

구분	분류번호	영역	법적/의무/권고사항
	• 9.2	• 성과평가	• 의무 요구사항
요구정의	• ISO/IEC 42001 9.2. 내부심사 참조		
조직담당자 중점사항	• 내부 심사 프로그램 수립 ✓ 연간·분기 일정, 심사 범위(조직 전반·제품 ·프로세스·표준 조항)·방법(현장·문서 검토·인터뷰)을 프로그램 문서로 작성하고 경영층 승인 • 심사팀 자격·독립성 보장 ✓ 심사원에게 ISO 42001·감사 기술 교육을 이수시키고, 자기 부서·자기 작업에 대한 심사 배제를 RACI로 명시 • 심사 계획·통보 ✓ 각 심사 1~4 주 전 감사 계획(목적·기준·일정·팀)을 관련 부서에 통보하고 준비 체크리스트를 제공 • 심사 수행·증거 수집 ✓ 인터뷰·기록·샘플링 방법을 절차서에 규정하고, 증거 시트·사진·로그를 전자 시스템에 저장 • 보고·부적합 등급화 ✓ 부적합을 ‘주요·경미·관찰’로 분류하여 “Internal Audit Report”에 기록, 담당 부서에 전달 • CAPA(시정 및 예방조치) 추적 ✓ 부적합에 대한 원인 분석·시정 계획·기한·책임자·검증 결과를 CAPA(시정 및 예방조치) 시스템에서 추적·완료 • 프로그램 검토·개선 ✓ 연간 심사 결과·추세를 경영검토(§ 9.3)에 제출하고, 빈도·범위·심사 기술을 보완		
인증심사원 중점사항	• 프로그램·계획 존재 ✓ 연간 프로그램, 개별 심사 계획서가 승인·버전 관리돼 있는지 확인 • 자격·독립성 증적 ✓ 심사원 교육 이수증, 이해상충 체크리스트, 심사 배정표에서 독립성 검증 • 증거 기반성 ✓ 샘플 Internal Audit Report에서 객관적 증거(로그·사진·인터뷰 노트)가 첨부됐는지 검토		

	• 부적합 등급·정의 ✓ 주요·경미 기준이 문서화돼 있고 보고서에 일관성 있게 적용됐는지 확인 • CAPA(시정 및 예방조치) 실효성 ✓ 부적합→시정→검증 완료 로그, 기한 준수, 재발 방지 효과를 평가 • 프로그램 개선 루프 ✓ 연간 결과 분석, 경영검토 기록, 다음 연도 프로그램 조정 여부 점검
결함사례	• 사례 1. (심사 프로그램 부재) ✓ 결함 : 연간 내부 심사 계획이 수립되지 않아 일부 부서 2년 연속 미심사. ✓ 심사원 관찰 : 프로그램 문서 공백, 심사 일정 스프레드시트 없음. ✓ 권고/시정 : 연간 프로그램 즉시 작성·승인, 위험 기반 우선순위로 부서 배정. • 사례 2. (독립성 부족) ✓ 결함 : 개발 팀장이 자사 모델 운영 절차를 직접 심사. ✓ 심사원 관찰 : RACI 표에서 ‘심사원’과 ‘책임자’ 동일 인물, 이해상충 체크 미수행. ✓ 권고/시정 : 심사 배정 재조정, 이해상충 선언서 필수화, 외부/다른 팀 교차 심사 도입. • 사례 3. CAPA(시정 및 예방조치) 미추적 ✓ 결함 : 주요 부적합 3건이 ‘시정 중’ 상태로 4 개월 경과, 검증 기록 없음. ✓ 심사원 관찰 : CAPA(시정 및 예방조치) 시스템에 완료 날짜·검증 서명 공란, 리마인더 기능 미활성. ✓ 권고/시정 : 기한 재설정, 담당 임원 보고, 자동 알림·에스컬레이션 설정 후 검증 로그 저장.

4.9.3 경영검토

구분	분류번호	영역	법적/의무/권고사항
	• 9.3	• 성과평가	• 의무 요구사항
요구정의	• ISO/IEC 42001 9.3. 경영검토 참조		
조직담당자 중점사항	• 경영검토 연간·분기 일정 수립 ✓ 최고경영층이 주관하는 정기 회의를 캘린더에 고정하고, 임시 검토(중대 사고·규제 변경 시) 트리거를 절차서에 명시 • 의제(Agenda)·자료 준비 ✓ 정책·목표 달성도, KPI·KRI 추세(9.1), 내부심사·외부심사 결과(9.2), CAPA(시정 및 예방조치) 상태, 리스크·기회(6.1), 자원 적합성(7.1), 이해관계자 피드백(7.4)을 표준 의제 템플릿에 포함 • 입·출력 문서화 ✓ 회의 자료·프레젠테이션을 “Management Review Input Pack”으로 사전 배포하고, 결정 사항·책임자·기한을 “Management Review Minutes”에 기록 • 의사결정 및 개선 지시 ✓ 정책·목표 수정, 자원 재배정, CAPA(시정 및 예방조치) 우선순위 조정, 교육·문화 강화 등 구체적 Action을 승인하고 Action Log에 등록 • 후속 조치 추적 ✓ 의사결정 사항을 담당 부서에 할당하고, 진행 상태·완료 검증·효과 확인을 다음 검토 때 Follow-up 항목으로 보고 • 이해관계자 커뮤니케이션 ✓ 경영검토 주요 결과를 요약하여 임직원·규제기관·고객 등 관련 이해관계자에게 적절히 공유 • 기록 보존 및 보호 ✓ Minutes·Action Log·자료 팩을 중앙 DMS에 버전·접근 관리 상태로 보존		
인증심사원 중점사항	• 검토 주기·참석 여부 ✓ 연간·분기 일정이 준수되고 최고경영자·핵심 책임자가 참석했는지 회의록 확인 • 의제 범위 충족 ✓ 표준 의제 항목(정책, 목표, KPI, 리스크·기회, 자원, 감사 결과 등)이 모두 다뤄졌는지 검토		

	• 입력 자료의 충분성 ✓ 최신 KPI 보고, 내부심사 결과, CAPA(시정 및 예방조치) 현황, 외부 변화 분석이 회의비용에 포함됐는지 확인 • 결정 사항·책임·기한 명확성 ✓ Minutes에 Action, 담당자, 완료 기한이 구체적으로 기록됐는지 검증 • 후속 조치 이행 ✓ 이전 회의 Action Item이 완료·검증됐는지 Action Log·증적 샘플링 • 기록·보존·보안 ✓ Minutes·자료 팩이 중앙 DMS에 저장되고 버전·접근·백업 관리가 이루어졌는지 점검
결함사례	• 사례 1. (검토 미개최) ✓ 결함 : 계획된 분기 경영검토가 업무 압박으로 취소, 대체 회의 미진행. ✓ 심사원 관찰 : 캘린더 공란, Minutes·Action Log 부재. ✓ 권고/시정 : 일정 재조정·고정, 불참 시 CEO 승인 의무화, 대체 회의 30 일 내 개최. • 사례 2. (의제 누락) ✓ 결함 : 회의에서 KPI·자원 논의만 진행, 내부심사 결과·CAPA(시정 및 예방조치) 상태 미검토. ✓ 심사원 관찰 : Minutes에 감사 결과·부적합 항목 없음. ✓ 권고/시정 : 표준 의제 템플릿 강제 사용, 의제 누락 시 회의 연기 규칙 설정. • 사례 3. (후속 조치 미추적) ✓ 결함 : 전 회의에서 승인된 교육 예산 증액 Action이 6 개월간 미이행·미보고. ✓ 심사원 관찰 : Action Log ‘In Progress’ 상태, 담당자·기한 업데이트 없음. ✓ 권고/시정 : 자동 리마인더·에스컬레이션 기능 활성화, 진행 상황 월간 보고 의무화.

4.10 개선

4.10.1 지속적 개선

구분	분류번호	영역	법적/의무/권고사항
	• 10.1	• 개선	• 의무 요구사항
요구정의	• ISO/IEC 42001 10.1. 지속적 개선 참조		
조직담당자 중점사항	• 지속적 개선 정책 수립 ✓ 인공지능 경영시스템 전 영역을 대상으로 하는 PDCA·DM인공지능C 기반 지속적 개선(Continual Improvement) 정책을 문서화하고 경영층 승인 • 개선 기회 식별 루프 ✓ 내부·외부 감사 결과(9.2), 경영검토 Action(9.3), KPI·KRI 추세(9.1), 사고·Near-miss, 이해관계자 피드백(7.4) 등 모든 소스를 개선 목록(Improvement Input Register)에 통합 • 우선순위 및 자원 배정 ✓ 효과(리스크 감소, 성능 향상) × 긴급도 × 자원 현실성으로 점수화해 Prioritization Matrix를 작성하고 책임·예산·기한을 지정 • 개선 실행·검증 프로세스 ✓ 문서 개정, 프로세스 최적화, 기술 도구 도입, 교육 보강 등 개선 조치 실행 → KPI·테스트로 효과 검증 → 경영층 승인 절차를 SOP에 포함 • 개선 레지스터 유지 ✓ “인공지능 경영시스템 Improvement Log”에 개선안, 책임자, 기한, 진행률, 효과 검증 결과를 실시간 업데이트 • 교훈(Lessons Learned) 공유 ✓ 완료된 개선 사례를 위키·브라운백·리포트로 조직 전반에 공유하고, 정책·절차 템플릿에 반영 • 정기 검토 및 갱신 ✓ 개선 프로그램 자체를 연 1회 이상 평가하여 빈도·기법·우선순위 기준을 최신화		
인증심사원 중점사항	• 정책·절차 존재 여부 ✓ 지속적 개선 정책, SOP, 우선순위 기준 문서가 승인·버전 관리돼 있는지 확인 • 개선 목록(Improvement Input Register) 완전성 ✓ 감사·사고·KPI 등 모든 입력이 레지스터에 통합되고 최신 로그가 존재하는지 검토		

	• 우선순위·자원 배정 타당성 ✓ 점수화 기준, 책임자·예산·기한 지정 근거가 합리적으로 적용됐는지 샘플링 • 개선 실행·검증 증적 ✓ Action 완료 로그, KPI 개선 그래프, 테스트 결과로 효과 검증이 이루어졌는지 확인 • 교훈 및 시사점(Lessons Learned) 확산 ✓ 완료 사례가 위키·교육·정책 개정 등을 통해 조직에 공유됐는지 증적 검토 • 프로그램 자체 개선 ✓ 연간 리뷰 회의록에서 지속적 개선 프로세스의 효율성·성과 분석 및 보완 결정이 있었는지 점검
결함사례	• 사례 1. (개선 프로세스 부재) ✓ 결함 : 인공지능 경영시스템 결과를 개선하기 위한 공식 정책·레지스터·우선순위 기준이 없음. ✓ 심사원 관찰 : KPI 악화와 감사 부적합이 반복되지만 Action 계획 미작성. ✓ 권고/시정 : 지속적 개선 정책·레지스터·우선순위 매트릭스 수립, 경영층 승인 후 실행. • 사례 2. (효과 미검증) ✓ 결함 : 모델 편향 완화 스크립트 배포 후 KPI 재측정·A/B 테스트 미실시. ✓ 심사원 관찰 : Improvement Log에 ‘완료’ 표시, 검증 컬럼 공란. ✓ 권고/시정 : 효과 검증 단계 필수화, KPI 변화·통계 검증 결과 기록 의무. • 사례 3. (교훈 미공유) ✓ 결함 : 성공적 자동화 개선 프로젝트 결과가 팀 내부 문서에만 보관. ✓ 심사원 관찰 : 위키·교육 자료, 정책 템플릿에 반영되지 않음. ✓ 권고/시정 : Lessons Learned 템플릿 사용, 완료 후 30 일 내 전사 공유 프로세스 도입.

4.10.2 부적합 및 시정 조치

구분	분류번호	영역	법적/의무/권고사항
	• 10.2	• 개선	• 의무 요구사항
요구정의	• ISO/IEC 42001 10.2. 부적합 및 시정 조치 참조		
조직담당자 중점사항	• 부적합(Non-conformity) 정의·식별 ✓ 정책·절차·법규·계약·목표·기준 불일치 사례를 “부적합”으로 정의하고, 발견 즉시 Incident/NC 티켓을 생성 • 원인 분석(RCA) 수행 ✓ 5 Why, Fishbone, Fault-tree 등 기법으로 근본 원인을 규명하고 분석 결과를 보고서에 첨부 • 시정(Correction) 및 시정조치(Corrective action) 구분 ✓ 즉각적인 대처(시정) vs. 재발 방지 활동(시정조치)을 구분해 계획·기한·책임자를 설정 • CAPA(시정 및 예방조치) 워크플로 관리 ✓ 부적합(NC) 등록 → 원인 분석 → 조치 계획 승인 → 실행 → 효과 검증 → 종결까지 상태·로그를 CAPA(시정 및 예방조치) 시스템에 기록 • 조치 효과 검증 ✓ 재테스트, KPI 추적, 샘플링 감사를 통해 조치 효과를 확인하고 ‘효과 불충분’ 시 추가 조치 • 지식 전파·문서 갱신 ✓ 교훈(Lessons learned)을 위키·교육·절차 개정 등 반영해 조직 전반의 재발 방지 체계를 구축 • 경영층 보고·모니터링 ✓ 주요·반복 부적합, 기한 초과 CAPA(시정 및 예방조치) 현황을 월간 보고·경영검토(9.3)에 상정		
인증심사원 중점사항	• 부적합 등록·분류 체계 ✓ NC 정의, 등급(주요·경미·관찰) 기준이 문서화돼 있고, 실제 NC 티켓에 적용됐는지 샘플링 • 원인 분석 적정성 ✓ RCA 보고서에 논리적 근거·데이터·책임자 서명이 있는지 확인 • 시정·시정조치 계획 ✓ 조치 구분, 책임자, 기한, 자원, 승인 로그가 CAPA(시정 및 예방조치) 시스템에 존재하는지 검토		

	• 조치 실행·검증 증적 ✓ 실행 로그, KPI 개선, 재테스트 결과로 효과 확인·승인 절차가 완료됐는지 확인 • 재발 방지·지식 공유 ✓ 절차 개정, 교육, Lessons learned 게시 등 확산 활동 증적을 샘플링 • 기한 준수·에스컬레이션 ✓ 기한 초과 NC리스트, 알림·에스컬레이션 기록, 경영층 보고 여부를 점검
결함사례	• 사례 1. (원인 분석 미실시) ✓ 결함 : 부적합 등록 후 ‘시정 완료’ 체크만 하고 근본 원인 분석 보고서 미작성. ✓ 심사원 관찰 : CAPA(시정 및 예방조치) 티켓에 RCA 필드 공란, 책임자·방법 미기재. ✓ 권고/시정 : RCA 템플릿 의무화, 분석 후 경영층 승인 단계 추가. • 사례 2. (조치 효과 미검증) ✓ 결함 : 편향 완화 스크립트 적용 후 KPI 측정 없이 CAPA(시정 및 예방조치) 종결. ✓ 심사원 관찰 : 효과 검증 컬럼 ‘N/A’, 재테스트 로그 없음. ✓ 권고/시정 : 검증 절차 필수화, KPI 전·후 비교 결과 첨부 후 종결 승인. • 사례 3. (기한 초과·에스컬레이션 부재) ✓ 결함 : 주요 부적합 2건이 기한 60 일 초과, 담당자 미조치. ✓ 심사원 관찰 : CAPA(시정 및 예방조치) 시스템 알림 기능 미사용, 경영층 보고 누락. ✓ 권고/시정 : 알림·에스컬레이션 자동화, 기한 관리 KPI 설정, 경영회의 정례 보고.

<참조 문서>

1. ISO/IEC 42001 : 2023 인공지능 경영시스템-요구사항
2. ISO/IEC 22989 : 인공지능(인공지능) 기본사항과 용어
3. ISO/IEC 23053 : 기계학습(ML) 프레임워크
4. ISO 품질경영원칙
5. ISO 9001 : 2015 품질경영시스템-요구사항
6. ISO 19011 : 2013 품질경영시스템 심사 가이드라인

초판 전자출판 2025년 5월 8일

편저자 오 명 섭

펴낸이 오 명 섭

디자인 오 명 섭

펴낸곳 한국사이버리터러시연구원

출판사 등록번호 No.2023-000095

전화 070-8768-4192

팩스 0504-422-4192

이메일 roknaoms@hanmail.net

네이버 밴드

<https://band.us/band/51969157>

©오명섭 2024

ISBN 9791198532220

이 책은 저작권법에 따라 보호를 받는 저작물이므로 무단 전재와 무단 복제를 금지하며,
이 책의 전부 또는 일부를 이용하려면 반드시 저작권자와 한국사이버리터러시연구원의
사전 동의를 받아야 합니다.

